Tema 30 · Bloque II | 60 preguntas de test

Administración de redes de área local. Gestión de usuarios. Gestión de dispositivos. Monitorización y control de tráfico

Diseño jerárquico, VLAN y redundancia · DHCP y DNS · Directorio, autenticación y directivas · Inventario, parches y control de admisión · Monitorización, calidad de servicio, flujos y ENS

Enunciado oficial del programa (BOAM n.º 10.032, de 23 de diciembre de 2025): Administración de redes de área local. Gestión de usuarios. Gestión de dispositivos. Monitorización y control de tráfico.

EXTENSIÓN
~22.500 palabras · 15 diagramas · 60 preguntas de test

TIEMPO ESTIMADO DE ESTUDIO
19–21 horas (primera vuelta completa, sin contar repasos)

Índice

- [ ] 1. Administración de redes de área local
  - [ ] 1.1. Fundamentos y arquitectura de administración de redes LAN
  - [ ] 1.2. Servicios de red fundamentales para la administración LAN
- [ ] 2. Gestión de usuarios y servicios de directorio
  - [ ] 2.1. Arquitectura de directorio activo e identidad digital
  - [ ] 2.2. Autenticación, autorización y políticas de gestión
- [ ] 3. Gestión y administración de dispositivos de red y puestos de trabajo
  - [ ] 3.1. Administración de equipos e infraestructura de red
  - [ ] 3.2. Gestión del ciclo de vida del puesto de trabajo y dispositivos finales
- [ ] 4. Monitorización, análisis y control del tráfico de red
  - [ ] 4.1. Monitorización y gestión del rendimiento de red
  - [ ] 4.2. Análisis de tráfico, auditoría y control de seguridad
- [ ] Cierre: las cuatro preguntas del tema

Conceptos clave para memorizar

Concepto	Dato clave
Dominio de colisión / difusión	Cada **puerto de conmutador** es un dominio de **colisión**; cada **VLAN** (o cada interfaz de encaminador) delimita un dominio de **difusión**. Segmentar en VLAN reduce el dominio de difusión, no el de colisión
Etiqueta 802.1Q	Se inserta en la trama Ethernet: **TPID 0x8100** + **PCP (3 bits)** + **DEI (1 bit)** + **VID (12 bits)**. VID útiles **1-4094**; **0** y **4095** están reservados. La trama etiquetada mide **4 bytes más** [IEEE8021Q]
Acceso frente a troncal	Puerto de **acceso**: una sola VLAN, tramas **sin etiqueta** hacia el equipo final. Puerto **troncal**: varias VLAN **etiquetadas** más, opcionalmente, una **VLAN nativa sin etiquetar**
Enrutamiento entre VLAN	Dos VLAN **nunca** se comunican en el nivel 2: hace falta un **encaminador** o un **conmutador de nivel 3** con interfaz virtual (SVI). Es el punto natural donde aplicar listas de control de acceso
STP / RSTP / MSTP	**STP** (802.1D) evita bucles bloqueando puertos; converge en decenas de segundos. **RSTP** (802.1w, integrado en 802.1D-2004) converge en **segundos**. **MSTP** (802.1s, integrado en **802.1Q**) agrupa VLAN en **instancias** para repartir la carga
Agregación de enlaces	**802.1AX** (antes **802.3ad**) con **LACP**: varios enlaces físicos actúan como **uno lógico**; suma capacidad y aporta redundancia **sin** que STP bloquee. El reparto se hace **por flujo**, no paquete a paquete
DHCP	Ciclo **DORA**: *Discover* (difusión del cliente) → *Offer* → *Request* → *Ack*. Puertos UDP **67** (servidor) y **68** (cliente). Renovación al **50 %** (T1) y **87,5 %** (T2) del tiempo de concesión [RFC2131]
Agente de retransmisión DHCP	El *relay* (`ip helper-address`) convierte la difusión del cliente en **unidifusión** hacia el servidor: permite un servidor DHCP central para muchas VLAN. La **opción 82** añade puerto y conmutador de origen [RFC3046]
DNS	Espacio jerárquico de nombres dividido en **zonas**. Registros: **A/AAAA** (nombre→IP), **PTR** (IP→nombre, zona `in-addr.arpa`), **CNAME** (alias), **MX**, **NS**, **SOA**, **SRV** (localización de servicios: base del inicio de sesión en el dominio) [RFC1034] [MS-DNS]

Concepto	Dato clave
DNSSEC	Firma las zonas: aporta **autenticidad e integridad**, **no confidencialidad**. La confidencialidad la dan **DoT** (puerto 853) y **DoH** [RFC4033] [RFC7858]
LDAP / X.500	Directorio jerárquico (**DIT**) optimizado para **lectura**. Entradas identificadas por **DN**; puertos **389** y **636** (sobre TLS). LDAP es la simplificación de **X.500** sobre TCP/IP [RFC4511] [X500]
Bosque / árbol / dominio / UO	**Bosque** = límite de **seguridad** y de **esquema**; **dominio** = límite de **replicación** y de **directiva**; **unidad organizativa** = contenedor de **administración delegada** y de **aplicación de GPO**. La UO **no** es un límite de seguridad [MS-AD]
Sitio (*site*)	Elemento de la estructura **física**: agrupa subredes bien conectadas. Determina a **qué controlador se autentica** el usuario y cómo se **replica**. Es independiente de la estructura lógica
Kerberos	Autenticación por **tiques** (TGT del KDC y tique de servicio), con **sello de tiempo**: exige relojes sincronizados (tolerancia habitual **5 minutos**). Puerto **88**. La contraseña **no viaja** por la red [RFC4120]
Orden de aplicación de GPO	**L-S-D-UO**: Local → Sitio → Dominio → Unidad organizativa. **Gana la última** que se aplica, salvo que una superior esté **forzada** (*enforced*), que prevalece sobre el bloqueo de herencia [MS-GPO]
RBAC y mínimo privilegio	Los permisos se asignan a **roles**, no a personas. Cada cuenta recibe **solo** lo imprescindible y **solo** el tiempo necesario; se completa con **segregación de funciones** y **cuenta administrativa separada** de la de trabajo [NIST-RBAC] [ENS `op.acc.3`]
802.1X	**Suplicante** (equipo) — **autenticador** (conmutador o punto de acceso) — **servidor de autenticación** (RADIUS). El puerto solo deja pasar **EAPOL** hasta que la autenticación tiene éxito. Alternativas de respaldo: **MAB** por MAC y **VLAN de invitados** [IEEE8021X] [RFC2865]
SNMP	**Gestor** consulta al **agente** (UDP **161**); el agente envía **notificaciones** no solicitadas (*trap*/*inform*, UDP **162**). Datos organizados en la **MIB** por **OID**. Solo **SNMPv3** autentica y cifra: v1 y v2c usan **comunidad en claro** [RFC3411]
Dentro / fuera de banda	**Dentro de banda**: se gestiona por la misma red que transporta los datos; si la red cae, se pierde la gestión. **Fuera de banda**: vía independiente (puerto de consola, red de gestión dedicada, acceso celular) que sobrevive a la caída

Concepto	Dato clave
Espejo de puertos (SPAN)	Copia el tráfico de un puerto o VLAN hacia un puerto de análisis. **RSPAN/ERSPAN** lo llevan a otro conmutador o lo encapsulan sobre IP. Alternativa pasiva: **TAP** físico, que no consume capacidad del conmutador
Flujo	Conjunto de paquetes con **misma clave**: IP y puerto de origen, IP y puerto de destino, y protocolo (**quíntupla**). **NetFlow v9** (RFC 3954) es de Cisco; **IPFIX** (RFC 7011) es su versión **normalizada** por el IETF; **sFlow** funciona por **muestreo**
Paquete frente a flujo	La **captura de paquetes** da el **contenido** completo pero es cara de almacenar y muy sensible en protección de datos; el **flujo** da **quién habló con quién, cuánto y cuándo**, sin contenido, y escala a toda la red
DSCP	**6 bits** del campo DS de la cabecera IP (**nivel 3**). **EF = DSCP 46** para voz; **AF41** para vídeo interactivo; **CSO/BE = 0** para mejor esfuerzo. En el **nivel 2** el equivalente es **PCP**, 3 bits de la etiqueta 802.1Q [RFC2474] [RFC4594]
Confianza del marcado	El marcado que llega del equipo de usuario **no es de fiar**: se **clasifica y remarca en el borde** de la red (nodo frontera DiffServ). El núcleo se limita a **encolar** según lo marcado [RFC2475]
Umbrales de voz	Valores de referencia habituales para voz sobre IP: **retardo unidireccional ≤ 150 ms**, **fluctuación (*jitter*) ≤ 30 ms** y **pérdida < 1 %**. Son objetivos de diseño, no cifras normativas
Syslog	Mensajes con **facility** y **severity 0–7** (0 *emergency* … 7 *debug*). UDP **514** en el uso clásico; **TCP 6514 sobre TLS** cuando se exige integridad y confidencialidad. Exige **NTP** para ser correlacionable [RFC5424] [RFC5905]
ENS y red	Medidas nucleares: `mp.com.1` perímetro seguro · `mp.com.2` confidencialidad · `mp.com.3` integridad y autenticidad · `mp.com.4` **separación de flujos de información en la red** · `op.mon.1` detección de intrusión · `op.mon.2` sistema de métricas · `op.mon.3` vigilancia · `op.exp.8` registro de la actividad [ENS]
Registros y RGPD	Una dirección IP asociada a un usuario es **dato personal**: el registro de tráfico exige **finalidad determinada**, **minimización**, **plazo de conservación** e **información previa** a la plantilla. Los arts. **87–90 LOPDGDD** limitan el control del uso de dispositivos [RGPD] [LOPDGDD]

Contenido

Convenciones del documento

Este tema incluye cuatro tipos de **cajas callout** para facilitar el estudio:

> **DATO CLAVE**
> Información de alta densidad memorística: puertos, números de norma, valores de campos y definiciones.

> **EJERCICIO RESUELTO**
> Problema con solución paso a paso: cálculo de una subred, dimensionado de un rango DHCP, lectura de una etiqueta VLAN, interpretación de un contador o de un registro.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
> Aplicación de la teoría al entorno municipal: sedes de distrito, Oficinas de Atención a la Ciudadanía, red corporativa, puesto del empleado, sede electrónica.

> **RELACIÓN CON OTROS TEMAS**
> Enlace conceptual a otros temas del temario oficial.

El enunciado oficial de este tema enumera **cuatro materias** que en la práctica de un departamento de sistemas son cuatro tareas del mismo puesto de trabajo: **administrar la red local**, **gestionar quién entra en ella**, **gestionar qué equipos la componen** y **vigilar lo que circula por ella**. Conviene leerlas en ese orden, porque cada una se apoya en la anterior: no se puede autenticar a un usuario si el equipo no tiene dirección IP; no se puede aplicar una directiva de seguridad si el puesto no está en el dominio; y no se puede interpretar una gráfica de tráfico si no se sabe qué VLAN es cada cosa.

La frontera con los temas vecinos es importante y está deliberadamente vigilada a lo largo del texto. El **Tema 37** trata las **redes locales** desde el punto de vista de la *tipología, las técnicas de transmisión, los métodos de acceso y los dispositivos de interconexión*; este tema no repite esa materia, sino que la da por sabida y se ocupa de **administrarla**. El **Tema 34** desarrolla el modelo TCP/IP y sus protocolos; aquí solo se usan los que son instrumentos de administración. El **Tema 36** cubre la seguridad perimetral, el acceso remoto seguro y las VPN; aquí la seguridad aparece únicamente en cuanto es una decisión de administración de la red local: segmentar, admitir, cifrar la gestión y registrar. Y el **Tema 39** desarrolla el ENS en su conjunto; aquí se citan solo las medidas que un administrador de red aplica con sus propias manos.

Los nombres de **productos concretos** (Cisco, Aruba, Zabbix, Wireshark, Active Directory, Intune) aparecen como ejemplos ilustrativos y nunca como contenido a memorizar por marcas: lo que importa es el **mecanismo**. Sí conviene memorizar, en cambio, los **puertos, números de norma y valores de campo** citados, porque son datos discretos; están concentrados en los diagramas **D5** (protocolos y puertos de gestión) y **D12** (marcado de calidad de servicio) para permitir el repaso rápido.

Caso de referencia usado en todo el tema (contexto Ayuntamiento de Madrid, supuesto simplificado): la **red de área local de una sede de distrito** que alberga una **Oficina de Atención a la Ciudadanía**, oficinas administrativas de tramitación, una sala de reuniones con videoconferencia, telefonía IP en todos los puestos, algunas impresoras y escáneres compartidos, cámaras de videovigilancia y una red inalámbrica con una parte corporativa y otra para visitantes. Ese edificio concentra prácticamente todas las decisiones del tema: cómo se segmenta, quién entra en cada segmento, cómo se identifican y mantienen los equipos, y cómo se vigila lo que circula. Se irá retomando sección a sección.

---

1. Administración de redes de área local

1.1. Fundamentos y arquitectura de administración de redes LAN

Una **red de área local (LAN)** es la infraestructura de comunicaciones que interconecta los equipos de un ámbito geográfico reducido —un edificio, un campus, una sede— bajo una única autoridad administrativa. **Administrarla** no es lo mismo que construirla: administrar es el conjunto de actividades continuadas que mantienen esa red disponible, segura, medible y evolucionable a lo largo de los años.

La distinción tiene consecuencias prácticas. Un instalador entrega una red que funciona el día de la puesta en marcha; un administrador responde de que siga funcionando el día 900, cuando se han añadido cuatrocientos dispositivos que nadie inventarió, se han creado VLAN que nadie documentó y se ha jubilado el técnico que sabía por qué aquel puerto estaba configurado de aquella manera. Casi todas las buenas prácticas de este tema —inventario, documentación, normalización, automatización, registro— existen para evitar exactamente ese escenario.

Las **funciones clásicas de la administración de redes** se resumen en el modelo **FCAPS**, formulado por ISO y ampliamente adoptado como esquema mental:

Letra	Función	Contenido	Dónde se desarrolla aquí
F	*Fault* — **Fallos**	Detección, aislamiento y corrección de averías; alarmas y notificaciones	§4.1, §4.2
C	*Configuration* — **Configuración**	Inventario, control de versiones de configuración, cambios, altas y bajas	§3.1, §3.2
A	*Accounting* — **Contabilidad**	Registro de uso de recursos; en el sector público, más «rendición de cuentas» que facturación	§4.2.2, §4.2.3
P	*Performance* — **Rendimiento**	Métricas, umbrales, capacidad, calidad de servicio	§4.1.2, §4.1.3
S	*Security* — **Seguridad**	Control de acceso, segmentación, cifrado de la gestión, auditoría	§2.2, §3.2.3, §4.2.4

DATO CLAVE

FCAPS: **F**allos, **C**onfiguración, **A**dministración contable o de uso, **P**restaciones o rendimiento, **S**eguridad. Es el modelo funcional de referencia de la gestión de redes. No confundir con las fases de un proyecto: FCAPS describe **funciones permanentes**, no etapas.

Toda administración de red descansa sobre tres piezas que se citan poco y se echan de menos mucho:

- **Un inventario fiable** de lo que hay: equipos, direcciones, VLAN, enlaces, versiones de software y ubicaciones físicas. Sin inventario no hay diagnóstico posible, porque no se sabe qué se está mirando ni qué falta [IPAM] [NETMGMT-TOOLS].
- **Una documentación viva** de por qué está cada cosa como está: una VLAN sin propósito documentado se convierte en un elemento intocable al que nadie se atreve a poner la mano.
- **Un esquema de nombres y de direccionamiento normalizado**: si los conmutadores se llaman `SW-DIS-01`, `switch3` y `elnuevo`, la automatización y la monitorización se vuelven imposibles.

EJEMPLO DE APLICACIÓN EN EL AYTO

En una organización con **21 Distritos** [ROGA] y centenares de sedes —oficinas de atención, bibliotecas, centros culturales, polideportivos, instalaciones deportivas y dependencias administrativas—, la normalización no es una preferencia estética: es la única forma de que un técnico que nunca ha pisado un edificio pueda entender su red en dos minutos leyendo los nombres de los equipos y el plan de direccionamiento. Un patrón habitual identifica sede, tipo de equipo, capa jerárquica y número de orden; y reserva un bloque de direccionamiento por sede, de manera que la dirección delate por sí sola dónde está el equipo.

1.1.1. Modelos de diseño jerárquico y segmentación de red

El modelo de referencia del diseño de una red de campus es el **modelo jerárquico de tres capas**, que ordena la red en niveles con responsabilidades diferenciadas:

Capa	Función	Qué hace	Qué no debe hacer
Acceso	Conectar a los equipos finales	Puertos de usuario, VLAN de acceso, PoE, 802.1X, marcado de calidad de servicio, seguridad de puerto	Encaminar tráfico de tránsito ni concentrar servidores
Distribución	Agregar el acceso y aplicar políticas	Encaminamiento entre VLAN, listas de control de acceso, agregación de enlaces, frontera del árbol de expansión	Conectar equipos de usuario directamente
Núcleo	Transportar rápido y sin política	Conmutación de alta capacidad entre bloques de distribución y hacia el centro de datos	Aplicar filtrados complejos que introduzcan retardo

La regla de oro del modelo es que **la política se aplica en la distribución y el núcleo solo transporta**. En redes pequeñas o de sede única es frecuente el **modelo colapsado de dos capas**, en el que distribución y núcleo se funden en una pareja de conmutadores; es una simplificación legítima, no una chapuza, siempre que se documente como tal.

DATO CLAVE

Modelo jerárquico: **acceso** (conecta usuarios) → **distribución** (agrega y aplica política, encamina entre VLAN) → **núcleo** (transporta a alta velocidad sin política). La variante de dos capas se denomina **núcleo colapsado**. La frontera entre el nivel 2 y el nivel 3 se sitúa normalmente en la **capa de distribución**.

Segmentar una red es dividirla en partes con comunicación controlada entre ellas. Se hace por cuatro motivos, y conviene saberlos separados por su efecto:

1. **Contener el tráfico de difusión**. Toda trama de difusión —peticiones ARP, anuncios de servicios, DHCP *Discover*— llega a **todos** los equipos del mismo dominio de difusión y obliga a cada uno a procesarla. Un dominio de difusión con dos mil equipos degrada a todos.
2. **Aislar por seguridad**. Si las cámaras de videovigilancia están en un segmento propio, un equipo de usuario comprometido no puede hablar con ellas sin pasar por un punto donde hay filtro y registro.
3. **Aplicar políticas distintas**. Calidad de servicio para la voz, restricciones horarias para invitados, filtrado estricto para dispositivos que no admiten agente de seguridad.
4. **Delimitar el impacto de un fallo**. Una tormenta de difusión o un bucle afecta a su segmento, no al edificio entero.

> DATO CLAVE
>
> Un **dominio de colisión** se corresponde con **cada puerto** de un conmutador (por eso la conmutación los eliminó en la práctica). Un **dominio de difusión** se corresponde con **cada VLAN**, o con cada interfaz de encaminador. **Segmentar en VLAN reduce el dominio de difusión, no el de colisión** [IEEE8023] [IEEE8021Q]. Es una de las confusiones más repetidas del temario.

La segmentación puede llevarse mucho más lejos que las VLAN clásicas. La **microsegmentación** aplica políticas entre cargas de trabajo individuales, no entre subredes, siguiendo el principio de que **la posición en la red no otorga confianza**: es la traducción práctica del modelo de **confianza cero** del NIST, que exige verificación explícita en cada acceso, mínimo privilegio y presunción de compromiso [NIST-ZT]. En una red de campus municipal esto se materializa, sobre todo, en dejar de tratar «estar enchufado a la roseta» como una credencial.

> RELACIÓN CON OTROS TEMAS
>
> La **tipología de las redes locales, sus técnicas de transmisión, sus métodos de acceso y los dispositivos de interconexión** (concentrador, puente, conmutador, encaminador) corresponden al **Tema 37**. Los **medios de transmisión y las redes de comunicaciones** en general, al **Tema 33**. La **seguridad perimetral** y las **VPN**, al **Tema 36**. Este tema presupone esa materia y se ocupa de la **administración** de lo que allí se describe.

1.1.2. Redes de área local virtuales (VLAN) y enlace de troncales

Una **VLAN** es un dominio de difusión definido por configuración y no por cableado: dos equipos conectados al mismo conmutador pueden pertenecer a redes lógicas distintas, y dos equipos situados en extremos opuestos del edificio pueden pertenecer a la misma. La norma que lo regula es **IEEE 802.1Q** [IEEE8021Q].

El mecanismo es una **etiqueta de 4 bytes** insertada en la trama Ethernet, entre la dirección MAC de origen y el campo de tipo. Su estructura es la siguiente:

Campo	Tamaño	Contenido
TPID (*Tag Protocol Identifier*)	16 bits	Valor fijo **0x8100**, que marca la trama como etiquetada
PCP (*Priority Code Point*)	**3 bits**	Prioridad de nivel 2, valores **0–7**; es el marcado de calidad de servicio del nivel de enlace (§4.1.4)
DEI (*Drop Eligible Indicator*)	1 bit	Señala que la trama es candidata preferente al descarte en congestión
VID (*VLAN Identifier*)	**12 bits**	Identificador de VLAN. Valores **1–4094** utilizables; **0** y **4095** reservados

DATO CLAVE

La etiqueta **802.1Q** mide **4 bytes**, lleva **TPID 0x8100**, **PCP de 3 bits** (prioridad, 8 niveles), **DEI de 1 bit** y **VID de 12 bits**. Como el VID tiene 12 bits, hay 4096 valores posibles pero solo **4094 VLAN utilizables** (el 0 y el 4095 están reservados). Una trama etiquetada mide **4 bytes más** que una sin etiquetar, de ahí el concepto de trama *baby giant* y la necesidad de admitir un tamaño ligeramente superior en los troncales [IEEE8021Q].

Los puertos de un conmutador se configuran en uno de dos modos, y distinguirlos es imprescindible:

- **Puerto de acceso**: pertenece a **una sola VLAN**. Las tramas salen hacia el equipo final **sin etiqueta**, de modo que el ordenador, la impresora o la cámara ignoran por completo que existen VLAN. Es el modo del 95 % de los puertos de una red de campus.
- **Puerto troncal** (*trunk*): transporta **varias VLAN** por un mismo enlace físico, **etiquetando** cada trama con su VID. Se usa entre conmutadores, hacia encaminadores, hacia servidores de virtualización y hacia puntos de acceso inalámbricos.

En un troncal puede definirse además una **VLAN nativa**: la única cuyo tráfico circula **sin etiquetar**. Es una fuente clásica de problemas —si los dos extremos declaran VLAN nativas distintas, el tráfico de una acaba en la otra sin que ningún indicador lo delate— y también de un ataque conocido, el **salto de VLAN por doble etiquetado**, que consiste en enviar una trama con dos etiquetas para que el primer conmutador retire la exterior y la segunda la introduzca en una VLAN ajena. La buena práctica es fijar como VLAN nativa una VLAN **sin uso y sin salida**, y no dejar la predeterminada.

DATO CLAVE

Un **puerto de acceso** entrega tramas **sin etiqueta** y pertenece a **una** VLAN; un **puerto troncal** entrega tramas **etiquetadas** de **varias** VLAN, salvo la **VLAN nativa**, que viaja **sin etiquetar**. La VLAN **1** es la predeterminada en la mayoría de la electrónica y **no debe usarse** ni para datos ni para gestión ni como nativa [IEEE8021Q] [CCN-STIC].

Un tipo particular de puerto de acceso es el de un **teléfono IP**: el terminal se conecta a la roseta y el ordenador se conecta al teléfono. El puerto se configura entonces con una VLAN de datos sin etiqueta para el ordenador y una **VLAN de voz** etiquetada para el teléfono, que este descubre normalmente por **LLDP-MED** [IEEE8021AB]. Es la única situación habitual en la que un puerto de acceso maneja dos VLAN.

Dos VLAN **nunca** se comunican entre sí en el nivel 2. Para que lo hagan hace falta un dispositivo de **nivel 3**: un encaminador, o —lo habitual en campus— un **conmutador de nivel 3** con una **interfaz virtual de VLAN (SVI)** que actúa como puerta de enlace predeterminada de cada segmento. Esa frontera es exactamente el punto donde conviene aplicar las **listas de control de acceso**, porque es el único lugar por el que el tráfico entre segmentos está obligado a pasar.

DATO CLAVE

El tráfico **entre VLAN** requiere **encaminamiento** (nivel 3). Dos formas clásicas: **encaminador con subinterfaces** sobre un troncal (el llamado *router on a stick*, hoy poco frecuente por su cuello de botella) y **conmutador de nivel 3 con SVI**, que es la solución estándar en campus. La frontera entre VLAN es el punto natural de aplicación de **listas de control de acceso**.

La propagación de la definición de VLAN entre conmutadores puede hacerse a mano —tedioso pero explícito y auditable— o mediante protocolos automáticos. Aquí conviene distinguir el estándar del propietario: **MVRP** (integrado en 802.1Q) es el mecanismo normalizado, mientras que **VTP** es la solución propietaria equivalente [PROPIETARIOS]. Los protocolos automáticos tienen un riesgo bien documentado: un conmutador introducido en la red con una configuración más «reciente» puede **borrar la base de datos de VLAN de todo el dominio**. Por eso muchas organizaciones optan por la definición manual acompañada de automatización controlada (§3.1.1).

EJERCICIO RESUELTO

Diseñar la segmentación de la sede de distrito del caso de referencia. Un esquema razonable separa: **VLAN de datos de tramitación** (puestos administrativos), **VLAN de la Oficina de Atención a la Ciudadanía** (puestos de mostrador, que atienden público y manejan datos de terceros), **VLAN de voz** (telefonía IP, con marcado EF), **VLAN de impresión** (impresoras y escáneres compartidos, que no deben iniciar conexiones hacia ningún sitio), **VLAN de videovigilancia** (cámaras, aisladas y sin salida a internet), **VLAN inalámbrica corporativa**, **VLAN de invitados** (con salida a internet y **ningún** acceso a la red interna) y **VLAN de gestión** (direcciones de administración de la propia electrónica, accesible solo desde la red de administración). Ocho segmentos, cada uno con una justificación distinta: difusión, protección de datos, calidad de servicio, contención de dispositivos no parcheables y separación de la gestión. El ENS respalda expresamente este diseño en la medida `mp.com.4` **— separación de flujos de información en la red** [ENS].

EJEMPLO DE APLICACIÓN EN EL AYTO

La **VLAN de invitados** de una sede municipal es el ejemplo más claro de segmentación con propósito jurídico además de técnico: un ciudadano que se conecta a la red inalámbrica pública de un centro cultural no debe poder alcanzar, ni siquiera por error, la subred donde viajan los expedientes. La separación se realiza en el nivel 2 (VLAN propia), en el nivel 3 (encaminamiento que solo permite salida a internet) y en la política (portal de acceso con condiciones de uso). Los tres niveles son necesarios: quitar cualquiera de ellos deja un agujero.

1.1.3. Protocolos de conmutación y redundancia en el nivel de enlace

Una red conmutada con enlaces redundantes tiene un problema estructural: la trama Ethernet **no lleva contador de saltos**. Si existe un bucle físico, una trama de difusión circula indefinidamente, se multiplica en cada conmutador y satura la red en segundos. Es la **tormenta de difusión**, y es la avería más rápida y más total que puede sufrir una red de área local.

La solución normalizada es el **protocolo de árbol de expansión (STP)**, definido en **IEEE 802.1D** [IEEE8021D]. Su funcionamiento se resume así:

1. Los conmutadores intercambian tramas de control llamadas **BPDU**.
2. Se elige un **puente raíz** (*root bridge*): el de menor **identificador de puente**, formado por una **prioridad configurable** más su dirección MAC. Como la prioridad se puede fijar, la elección del raíz es una **decisión de diseño**, no un azar: debe ser un conmutador de distribución o de núcleo, nunca uno de acceso.
3. Cada conmutador determina su **puerto raíz** (el de menor coste hacia el raíz) y cada segmento su **puerto designado**.

4. Los puertos sobrantes se ponen en estado de **bloqueo**: siguen escuchando BPDU pero no reenvían tramas. El resultado es una **topología lógica sin bucles** superpuesta a una topología física que sí los tiene.

El STP original atraviesa los estados *blocking*, *listening*, *learning* y *forwarding*, con temporizadores que hacen que la convergencia tras un fallo tarde del orden de **30 a 50 segundos**: inaceptable hoy. Por eso se sustituyó por el **protocolo rápido de árbol de expansión (RSTP)**, publicado como **802.1w** e **incorporado a la edición 802.1D-2004**, que reduce la convergencia a **unos pocos segundos** mediante confirmaciones explícitas entre conmutadores adyacentes y los papeles de puerto **alternativo** y **de respaldo**.

La tercera variante es el **protocolo de árbol de expansión múltiple (MSTP)**, publicado como **802.1s** e **integrado en 802.1Q**: permite agrupar VLAN en **instancias**, cada una con su propio árbol y su propio raíz. Así, en lugar de bloquear siempre el mismo enlace para todas las VLAN, se puede repartir la carga haciendo que la instancia 1 use un camino y la instancia 2, otro.

> DATO CLAVE
> Las tres generaciones del árbol de expansión: **STP = 802.1D** (convergencia de decenas de segundos) · **RSTP = 802.1w**, incorporado a **802.1D-2004** (convergencia de segundos) · **MSTP = 802.1s**, incorporado a **802.1Q** (varias instancias, una por grupo de VLAN, con reparto de carga). El **puente raíz** es el de **menor identificador de puente** = prioridad + MAC, y **debe fijarse por configuración** [IEEE8021D] [IEEE8021Q].

Sobre esta base se aplican varias **protecciones de borde** que constituyen buena práctica obligada en el acceso:

Mecanismo	Qué hace	Por qué
Puerto de borde (*portfast*)	El puerto de acceso pasa a reenviar de inmediato, sin recorrer los estados	Un puesto de usuario no forma bucles y no debe esperar 30 segundos para obtener dirección por DHCP
Guarda de BPDU	Deshabilita el puerto si **recibe** una BPDU	Un puerto de usuario nunca debe recibir BPDU: si las recibe, alguien ha enchufado un conmutador no autorizado
Guarda de raíz	Impide que por ese puerto se elija un nuevo puente raíz	Evita que un conmutador introducido por un usuario se convierta en raíz y reordene toda la red
Control de tormentas	Limita el porcentaje de tráfico de difusión, multidifusión o desconocido	Contiene el efecto de un bucle o de un equipo averiado
Seguridad de puerto	Limita cuántas direcciones MAC pueden aprenderse en un puerto	Detecta concentradores clandestinos y ataques de inundación de la tabla MAC

DATO CLAVE

En un puerto de acceso deben activarse **puerto de borde + guarda de BPDU**. La combinación es la respuesta canónica a «¿cómo se evita que un usuario que enchufa un conmutador doméstico tumbe la red?»: el puerto pasa a reenviar rápido para el usuario legítimo, y se apaga solo en cuanto detecta un dispositivo que habla el protocolo de árbol de expansión.

La segunda forma de redundancia en el nivel de enlace es la **agregación de enlaces**, normalizada en **IEEE 802.1AX** —publicada originalmente como **802.3ad**— con su protocolo de control **LACP** [IEEE8021AX]. Varios enlaces físicos entre dos equipos se presentan como **un único enlace lógico**: se suma capacidad, se gana redundancia y, sobre todo, **el árbol de expansión no bloquea nada**, porque ve un solo enlace.

Un detalle importante: el reparto de tráfico entre los enlaces de una agregación se hace mediante una **función de dispersión** sobre campos de la trama (direcciones MAC, IP, puertos), es decir, **por flujo**. Una única transferencia entre dos equipos **no** se reparte entre varios enlaces: cuatro enlaces de 1 Gbit/s dan 4 Gbit/s agregados, pero una sola copia de fichero sigue limitada a 1 Gbit/s.

DATO CLAVE

Agregación de enlaces = 802.1AX (antes 802.3ad), con **LACP** como protocolo de negociación; el equivalente propietario clásico es **PAgP**. Reparte **por flujo**, nunca paquete a paquete, para no entregar los paquetes desordenados. **Suma capacidad agregada, no capacidad por conversación** [IEEE8021AX] [PROPIETARIOS].

Por último, la redundancia de la **puerta de enlace predeterminada** se resuelve con **VRRP** (RFC 5798), estándar, o con sus equivalentes propietarios **HSRP** y **GLBP**: dos encaminadores comparten una dirección IP virtual, de modo que si el activo cae, el otro asume el papel sin que los equipos de usuario tengan que cambiar nada [RFC2328] [PROPIETARIOS].

EJEMPLO DE APLICACIÓN EN EL AYTO

En la sede del caso de referencia, la pareja de conmutadores de distribución se une al núcleo mediante **agregación de enlaces**, uno de ellos se fija como **puente raíz** del árbol de expansión y ambos comparten la puerta de enlace de cada VLAN mediante **VRRP**. Con ese esquema, la avería de un conmutador de distribución, de una fibra o de una fuente de alimentación es transparente para el mostrador de atención a la ciudadanía. La alternativa —un solo conmutador de distribución— ahorra dinero el primer día y cierra la oficina el día del fallo.

1.2. Servicios de red fundamentales para la administración LAN

Una red correctamente cableada, segmentada y libre de bucles sigue siendo inútil para un usuario hasta que dos servicios entran en funcionamiento: **DHCP**, que le da una identidad de red, y **DNS**, que le permite llamar a los servicios por su nombre. Los dos son, en la práctica cotidiana de un administrador, la causa de una fracción enorme de las incidencias, y por eso el temario los sitúa entre los fundamentos.

1.2.1. Configuración y gestión dinámica de direccionamiento (DHCP)

El **protocolo de configuración dinámica de anfitriones (DHCP)**, definido en el **RFC 2131** con sus opciones en el RFC 2132, permite que un equipo obtenga automáticamente su configuración de red al conectarse [RFC2131]. Opera sobre UDP, con el **servidor en el puerto 67** y el **cliente en el 68**.

El intercambio se conoce por el acrónimo **DORA**:

Paso	Mensaje	Quién lo envía	Cómo
D	*Discover*	Cliente	**Difusión**: aún no tiene dirección ni sabe dónde está el servidor
O	*Offer*	Servidor	Ofrece una dirección concreta de su ámbito
R	*Request*	Cliente	**Difusión** de nuevo: solicita formalmente la oferta elegida y así informa a los demás servidores de que las suyas quedan libres
A	*Ack*	Servidor	Confirma y fija el **tiempo de concesión** (*lease*)

La configuración entregada no se limita a la dirección: incluye **máscara de subred**, **puerta de enlace predeterminada** (opción 3), **servidores DNS** (opción 6), **sufijo de dominio** (opción 15), **servidores NTP** (opción 42) y, en despliegues avanzados, opciones específicas de fabricante para teléfonos IP, puntos de acceso o arranque por red.

La **concesión** es temporal, y su ciclo de renovación es el siguiente: el cliente intenta renovar al **50 %** del tiempo concedido (temporizador **T1**, en unidifusión contra el servidor que se la dio) y, si no lo consigue, al **87,5 %** (temporizador **T2**, en difusión, aceptando cualquier servidor). Si tampoco lo logra, al expirar deja de usar la dirección.

> DATO CLAVE
>
> **DHCP: DORA** = *Discover* (difusión) → *Offer* → *Request* (difusión) → *Ack*. Puertos **UDP 67 servidor / 68 cliente**. Renovación al **50 %** (T1) y al **87,5 %** (T2) del tiempo de concesión. Mensajes adicionales que conviene reconocer: **Release** (el cliente devuelve la dirección), **Decline** (el cliente detecta que la dirección ya está en uso), **Nak** (el servidor rechaza una solicitud, típicamente porque el equipo ha cambiado de subred) e **Inform** (el cliente tiene dirección fija pero pide el resto de parámetros) [RFC2131].

Como *Discover* y *Request* son **difusiones**, no atraviesan un encaminador. Esto significa que, sin más, haría falta un servidor DHCP **por cada VLAN**, lo que es inasumible. La solución es el **agente de retransmisión** (*relay*): el conmutador de nivel 3 o el encaminador que actúa de puerta de enlace de la VLAN recibe la difusión, la convierte en **unidifusión** dirigida al servidor central y le indica de qué subred procede para que elija el ámbito correcto. En la práctica se configura con una sola instrucción por interfaz —la clásica `ip helper-address`—, y permite centralizar el servicio.

El agente puede además insertar la **opción 82** (*Relay Agent Information*), definida en el **RFC 3046**, que añade el **identificador del circuito** —conmutador y puerto de origen— y el **identificador remoto**. Su valor administrativo es enorme: convierte el registro de concesiones en una traza que

dice **de qué roseta física** salió cada petición, lo que resuelve en segundos preguntas como «¿desde dónde se conectó este equipo el martes por la tarde?» [RFC3046].

> DATO CLAVE
>
> El **agente de retransmisión DHCP** (*relay*) permite un servidor **central** para muchas VLAN al transformar la **difusión** del cliente en **unidifusión** hacia el servidor. La **opción 82** añade **conmutador y puerto de origen**, y es la base de la trazabilidad de las concesiones [RFC3046].

La administración de DHCP en una red corporativa exige tomar varias decisiones de diseño:

- **Reservas frente a direcciones fijas**. Una **reserva** DHCP asocia permanentemente una dirección a una MAC, pero la sigue entregando el servidor: el equipo se comporta como cualquier cliente y la configuración sigue siendo central. Una **dirección fija** configurada en el propio equipo queda fuera del control del administrador y es una fuente crónica de conflictos y de direcciones «huérfanas». La regla práctica es **reservar, no fijar**, salvo en la propia electrónica de red y en los servidores de infraestructura.
- **Dimensionado del ámbito**. Debe cubrir el pico real de dispositivos simultáneos, no la media, y dejar margen.
- **Duración de la concesión**. En una oficina estable, concesiones largas (días) reducen tráfico y ruido en los registros. En una red inalámbrica de invitados o en una sala de formación, concesiones cortas (horas) evitan agotar el ámbito con dispositivos que ya se han ido.
- **Alta disponibilidad**. Dos servidores en modo de reparto de carga o de conmutación por error; un DHCP caído no se nota inmediatamente —los equipos ya concedidos siguen funcionando— pero se convierte en una avería general a medida que las concesiones vencen.
- **Protección frente a servidores no autorizados**. Un servidor DHCP doméstico enchufado por error a la red corporativa reparte direcciones y puertas de enlace erróneas a quien conteste antes. La contramedida es la **inspección DHCP** (*DHCP snooping*) en el conmutador: los puertos se declaran **no confiables** salvo los que llevan al servidor legítimo, y en los no confiables se descartan los mensajes propios de servidor. Como efecto secundario valiosísimo, la inspección construye una tabla que asocia MAC, IP, VLAN y puerto, sobre la que se apoyan la **inspección ARP dinámica** —contra la suplantación de ARP— y la **guarda de origen IP** —contra la suplantación de dirección.

EJERCICIO RESUELTO

Dimensionar el ámbito DHCP de la VLAN de datos de la sede. La sede tiene 180 puestos, 40 portátiles que van y vienen y una previsión de crecimiento del 20 % a tres años. Total estimado en pico: 180 + 40 = 220 dispositivos, más un 20 % = **264**. Una subred **/24** ofrece 254 direcciones útiles: **insuficiente con el margen**. La elección correcta es una **/23** (510 útiles), dentro del direccionamiento privado que reserva el **RFC 1918** y con las máscaras de longitud variable que permite **CIDR** [RFC1918] [RFC4632], reservando las 20 primeras direcciones para electrónica, servidores locales e impresoras con reserva, y dejando el resto como ámbito dinámico. Nota de diseño: antes de ampliar la subred conviene preguntarse si esos 264 dispositivos deben compartir dominio de difusión, o si el crecimiento es la ocasión para **separar en dos VLAN** por área funcional. Con frecuencia la segunda respuesta es mejor.

EJEMPLO DE APLICACIÓN EN EL AYTO

En una sede con Oficina de Atención a la Ciudadanía, la **opción 82** combinada con la **inspección DHCP** da respuesta inmediata a una consulta que llega tarde o temprano: ante un incidente de seguridad, saber qué equipo tenía una IP determinada a una hora determinada **y en qué roseta estaba enchufado**. Sin esos dos mecanismos, la respuesta exige rastrear tablas MAC conmutador por conmutador, cuando aún no se han sobrescrito.

1.2.2. Servicio de resolución de nombres de dominio (DNS)

El **sistema de nombres de dominio (DNS)**, definido en los **RFC 1034 y 1035**, traduce nombres legibles en direcciones IP —y viceversa— mediante una base de datos **jerárquica y distribuida** [RFC1034]. Opera en el **puerto 53**, sobre **UDP** para las consultas ordinarias y sobre **TCP** cuando la respuesta excede el tamaño admisible o para las **transferencias de zona**.

Sus piezas conceptuales son cuatro:

- **Espacio de nombres**: un árbol invertido cuya raíz se denota con un punto, bajo el que cuelgan los dominios de primer nivel y, por debajo, los dominios de la organización.
- **Zona**: la porción del árbol de la que un servidor concreto es **autoritativo**. Una zona no es lo mismo que un dominio: un dominio puede repartirse en varias zonas mediante **delegación**.
- **Servidores**: **autoritativos** (custodian los datos de una zona, en modalidad principal o secundaria) y **recursivos** o resolutores (no poseen datos propios, pero saben preguntar en cadena por el cliente y **almacenan en caché** las respuestas).
- **Registros de recurso**: las entradas concretas de la base de datos.

Registro	Función	Ejemplo de uso en una LAN corporativa
A / AAAA	Nombre → dirección IPv4 / IPv6	`sede-distrito.interno` → 10.20.30.40
PTR	Dirección → nombre (**resolución inversa**, zona `in-addr.arpa`)	Imprescindible para que los registros de eventos y las herramientas de red muestren nombres en lugar de números
CNAME	Alias de otro nombre	`intranet` como alias del servidor real, para poder cambiar el servidor sin tocar a los clientes
MX	Servidor de correo del dominio	Entrega de correo
NS	Servidores autoritativos de la zona	Delegación
SOA	Inicio de autoridad: servidor principal, contacto, número de serie y temporizadores	Control de la replicación entre principal y secundarios
SRV	**Localización de un servicio** (protocolo, puerto y anfitrión)	**Cómo un equipo encuentra los controladores de dominio**: sin registros SRV correctos no hay inicio de sesión
TXT	Texto libre	Verificaciones de propiedad, políticas de correo

DATO CLAVE

DNS = puerto 53, UDP para consultas y **TCP** para respuestas grandes y **transferencias de zona**. **A** es nombre→IPv4, **AAAA** nombre→IPv6 y **PTR** IP→nombre (zona **`in-addr.arpa`**). El registro **SRV** publica **dónde está un servicio**, y es el mecanismo por el que un equipo localiza a los **controladores de dominio**: un DNS mal configurado en una red con directorio produce el síntoma clásico de «no puedo iniciar sesión, pero navego bien» [RFC1034] [MS-DNS].

La resolución de una consulta encadena dos comportamientos distintos que conviene contraponer: el cliente formula una consulta **recursiva** a su resolutor («dame la respuesta final, no me mandes a otro sitio»), y el resolutor formula consultas **iterativas** a la raíz, al dominio de primer nivel y al servidor autoritativo, cada uno de los cuales le indica a quién preguntar después. La respuesta se guarda en **caché** durante el tiempo indicado por el **TTL** del registro.

El **TTL** es una herramienta de administración que se infrautiliza: antes de migrar un servicio a otra dirección conviene **bajarlo** con antelación —de horas a unos minutos— para que el cambio se

propague rápido, y **subirlo** de nuevo cuando la migración se ha consolidado.

La administración del DNS en una red corporativa plantea cuestiones propias:

- **DNS interno y externo separados** (la llamada *vista dividida*): los nombres internos no deben publicarse en internet, porque revelan la topología y facilitan el reconocimiento previo a un ataque. Los usuarios internos deben resolver un mismo nombre hacia la dirección interna, y los externos hacia la publicada.
- **Actualización dinámica** (**RFC 2136**): permite que los clientes o el servidor DHCP registren y actualicen sus nombres automáticamente [RFC2136]. Es lo que evita que el DNS interno se llene de nombres obsoletos, pero debe configurarse en modalidad **segura** —solo actualizaciones autenticadas—, porque abierta permite que cualquiera sobrescriba el nombre de un servidor.
- **Depuración** (*scavenging*): eliminación periódica de los registros dinámicos caducados. Sin ella, la resolución inversa deja de ser fiable en pocos meses.
- **DNSSEC** (**RFC 4033-4035**): firma criptográficamente las zonas y establece una cadena de confianza. Aporta **autenticidad e integridad** de la respuesta, pero **no confidencialidad**: las consultas siguen viajando en claro [RFC4033].
- **DNS cifrado** (**DoT**, puerto 853, y **DoH**, sobre HTTPS): aporta la confidencialidad que DNSSEC no da, pero plantea un problema real de administración, porque un navegador que resuelve por su cuenta mediante DoH **elude el resolutor corporativo** y con él el filtrado, el registro y la resolución de los nombres internos. La respuesta habitual es configurar la política corporativa que desactiva ese comportamiento en los navegadores gestionados y, si procede, ofrecer el propio resolutor interno por DoT [RFC7858].

> DATO CLAVE
>
> **DNSSEC** garantiza **autenticidad e integridad**, **no** confidencialidad. La confidencialidad del canal la aportan **DoT** (DNS sobre TLS, puerto **853**) y **DoH** (DNS sobre HTTPS, puerto 443). Conviene distinguir ambas cosas [RFC4033] [RFC7858].

EJERCICIO RESUELTO

Diagnóstico: un usuario dice «no me funciona internet». Se comprueba por capas. **(1)** El equipo tiene dirección IP y no es del rango de autoconfiguración `169.254.x.x` —si lo fuera, el problema sería DHCP, no DNS—. **(2)** Responde la puerta de enlace: el nivel 3 está bien. **(3)** Responde una dirección IP pública conocida: hay conectividad. **(4)** Falla la resolución de un nombre: **el problema es DNS**. **(5)** Se consulta directamente al resolutor corporativo y responde, pero el equipo tiene configurado otro servidor: la causa está en la configuración del cliente, probablemente una dirección de DNS fijada a mano por alguien. La lección de método: **«no funciona internet» casi nunca es internet**; el orden de comprobación —dirección, puerta de enlace, encaminamiento, resolución de nombres— es siempre el mismo y descarta una capa cada vez.

EJEMPLO DE APLICACIÓN EN EL AYTO

El DNS interno es la pieza que sostiene, sin que se vea, el inicio de sesión de todos los empleados. Cuando en una sede de distrito «nadie puede entrar en el equipo» pero la red funciona, la primera hipótesis debe ser que los equipos de esa sede no están resolviendo los **registros SRV** que localizan a los controladores de dominio: un servidor DNS caído, un servidor DNS incorrecto entregado por DHCP o una regla de filtrado nueva que bloquea el puerto 53 hacia el resolutor interno.

---

2. Gestión de usuarios y servicios de directorio

2.1. Arquitectura de directorio activo e identidad digital

Gestionar usuarios en una red de una sola decena de equipos puede hacerse creando cuentas locales en cada uno. A partir de ahí, el modelo se rompe: cambiar una contraseña obliga a tocar todos los equipos, dar de baja a un empleado deja cuentas olvidadas por todas partes y nadie puede responder a la pregunta «¿a qué tiene acceso esta persona?». La respuesta a ese problema es el **servicio de directorio**: una base de datos central de identidades, grupos, equipos y políticas, consultada por todos los sistemas de la organización.

Un servicio de directorio tiene cuatro rasgos que lo distinguen de una base de datos convencional:

1. Está **optimizado para la lectura**: se consulta miles de veces por cada escritura.
2. Su información es **jerárquica**, con forma de árbol, no tabular.
3. Está **distribuido y replicado**: varias copias en varias ubicaciones, para que una caída no impida trabajar.
4. Está **normalizado**: cualquier aplicación puede consultarlo porque habla un protocolo común.

El modelo conceptual procede de la recomendación **X.500** de la ITU-T, que definió el **árbol de información del directorio (DIT)** y sus agentes [X500]. X.500 resultó demasiado pesada —se apoyaba en la pila OSI completa—, y de su simplificación sobre TCP/IP nació el **protocolo ligero de acceso a directorio (LDAP)**, definido hoy en los **RFC 4510-4519** [RFC4511].

En LDAP, cada entrada se identifica por su **nombre distinguido (DN)**, que es la ruta completa desde la entrada hasta la raíz, escrita de la hoja hacia arriba. Por ejemplo, `cn=Ana Torres,ou=Tramitacion,ou=Distrito-Centro,dc=ejemplo,dc=local`. El fragmento que identifica la entrada dentro de su contenedor — `cn=Ana Torres` — es el **nombre distinguido relativo (RDN)**. Las operaciones del protocolo son pocas y conviene reconocerlas: `bind` (autenticarse), `search` (buscar con un filtro), `compare`, `add`, `delete`, `modify`, `modifyDN` (mover o renombrar) y `unbind`.

> DATO CLAVE
>
> **LDAP** usa el puerto **389** en claro o con STARTTLS, y el **636** para LDAPS (sobre TLS). Las entradas se identifican por su **DN** (nombre distinguido, ruta completa) y dentro de su contenedor por su **RDN**. Los atributos disponibles los define el **esquema**. LDAP es la simplificación sobre TCP/IP del modelo **X.500** de ITU-T [RFC4511] [X500].

La implementación de directorio más extendida en las administraciones públicas españolas es **Active Directory Domain Services**, que combina en un solo producto un directorio LDAP, un servicio de autenticación **Kerberos**, un mecanismo de distribución de políticas (**directivas de grupo**) y una dependencia estructural del **DNS** para la localización de servicios [MS-AD]. Existen alternativas libres —**OpenLDAP**, **FreeIPA**, **Samba AD**— que implementan las mismas piezas con distinto grado de integración [OPENLDAP]. El tema se explica sobre el modelo de Active Directory por ser el de referencia práctica, pero los conceptos son transferibles.

> DATO CLAVE
>
> Un dominio de directorio moderno descansa sobre **cuatro pilares**: **LDAP** (consulta del directorio), **Kerberos** (autenticación), **DNS** (localización de los controladores mediante registros **SRV**) y un **mecanismo de directivas** (GPO). Si falla el DNS, falla el inicio de sesión aunque el directorio esté perfectamente sano [MS-AD] [RFC4120].

2.1.1. Estructura lógica y física de servicios de directorio

Un directorio tiene **dos estructuras superpuestas e independientes**, y confundirlas es el error conceptual más frecuente de esta parte del temario.

La **estructura lógica** responde a la pregunta *¿cómo se organiza la información?*: bosque, árbol, dominio y unidad organizativa. Es una decisión **administrativa y de seguridad**, y no tiene por qué guardar relación alguna con la geografía.

La **estructura física** responde a *¿dónde están las copias y cómo se comunican?*: **controladores de dominio**, **sitios** y **enlaces de sitio**. Un **sitio** agrupa las subredes IP que están **bien conectadas** entre sí. Su función es doble: determinar a **qué controlador se autentica** cada equipo —al de su propio sitio, no a uno situado al otro extremo de la ciudad— y **regular la replicación**, que dentro de un sitio es prácticamente inmediata y entre sitios se programa y se comprime para no saturar los enlaces.

> DATO CLAVE
>
> **Estructura lógica** (bosque, árbol, dominio, unidad organizativa) = organización de la **información** y de la **administración**. **Estructura física** (controladores, **sitios**, enlaces de sitio) = **replicación** y **localización**. Un **sitio** se define asociándole **subredes IP**, y es lo que hace que un usuario se autentique contra un controlador cercano. Son estructuras **independientes**: un dominio puede abarcar muchos sitios y un sitio puede contener controladores de varios dominios [MS-AD].

Los **controladores de dominio** son los servidores que alojan una copia de la base de datos del directorio y atienden las autenticaciones. En el modelo actual la replicación es **multimaestro**: cualquier controlador acepta escrituras y las propaga a los demás. Aun así se conservan varios papeles **de maestro único** para operaciones que no admiten conflicto —como la asignación de identificadores relativos o la modificación del esquema—, y existe además el **catálogo global**, un índice parcial de todos los objetos del bosque que permite buscar en cualquier dominio sin recorrerlos todos.

Existe también un tipo de controlador pensado para ubicaciones con seguridad física limitada: el **controlador de solo lectura**, que no admite escrituras y almacena en caché únicamente las credenciales que se le autorizan. Es la respuesta clásica para una sede pequeña donde el armario de comunicaciones no está en un centro de proceso de datos.

> EJEMPLO DE APLICACIÓN EN EL AYTO
>
> La estructura física es donde la organización territorial del Ayuntamiento se refleja de verdad: cada sede relevante puede constituir un **sitio** con sus subredes asociadas, de modo que un empleado de un distrito se autentique contra un controlador local. Si un enlace con el centro de proceso de datos se degrada, los usuarios de esa sede siguen iniciando sesión y accediendo a sus recursos locales. La estructura **lógica**, en cambio, no tiene por qué replicar los 21 Distritos: multiplicar dominios multiplica el coste de administración sin aportar seguridad, y la delegación por distrito se resuelve mucho mejor con **unidades organizativas** dentro de un único dominio [ROGA].

2.1.2. Dominios, árboles, bosques y unidades organizativas

Las cuatro piezas de la estructura lógica se definen por lo que **delimitan**, y esa es la clave para no confundirlas:

Pieza	Qué es	Qué delimita
Dominio	Agrupación administrativa de objetos que comparten base de datos, políticas de cuenta y controladores	Límite de **replicación** y de **directiva de cuentas** (longitud y caducidad de contraseña, bloqueo)
Árbol	Conjunto de dominios con **espacio de nombres DNS contiguo** (`ayto.local` , `distritos.ayto.local`)	Continuidad del **nombre**
Bosque	Conjunto de árboles que comparten **esquema**, configuración y catálogo global	Límite de **seguridad** y de **esquema**: la frontera real
Unidad organizativa (UO)	Contenedor **dentro** de un dominio	Ámbito de **delegación administrativa** y de **aplicación de GPO**

> DATO CLAVE
>
> El **límite de seguridad** de un directorio es el **bosque**, no el dominio: dentro de un bosque, quien controla un dominio puede, por las relaciones de confianza y el esquema compartido, alcanzar los demás. El **dominio** es límite de **replicación** y de **política de cuentas**. La **unidad organizativa no es un límite de seguridad**: es un contenedor para **delegar administración** y **aplicar directivas** [MS-AD].

Dentro de un bosque, los dominios mantienen **relaciones de confianza** automáticas, **bidireccionales y transitivas**. Con dominios o directorios externos pueden establecerse confianzas explícitas, que se caracterizan por tres ejes: **dirección** (unidireccional o bidireccional), **transitividad** (si se propaga o no a los dominios confiados por el otro) y **ámbito**. Conviene recordar la asimetría del vocabulario: si A confía en B, los usuarios de **B** pueden acceder a recursos de **A**, y no al revés.

El **diseño de las unidades organizativas** es la decisión de mayor impacto cotidiano, porque de él dependen la delegación y la aplicación de directivas. Los criterios habituales son tres, y suelen combinarse:

- **Por unidad organizativa real** (Área de Gobierno, Distrito, servicio): favorece la delegación a los responsables locales.

- **Por función o perfil** (tramitación, atención al público, dirección, técnico): favorece la aplicación de directivas homogéneas.
- **Por tipo de objeto** (usuarios, equipos, servidores, cuentas de servicio): favorece la claridad y las políticas específicas de equipo.

Un principio de diseño que ahorra muchos problemas: **la estructura de UO debe responder a cómo se administra la organización, no a su organigrama**. Un organigrama cambia con cada legislatura; el modo de administrar la informática, mucho menos. Un árbol de UO calcado del organigrama obliga a reorganizar el directorio cada vez que se reordenan competencias.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> Un diseño razonable para un ayuntamiento grande combina un **único dominio** —con lo que se evita multiplicar controladores y confianzas— y un primer nivel de **unidades organizativas por ámbito territorial o funcional** (los Distritos y las Áreas de Gobierno), con un segundo nivel por **tipo de objeto** (usuarios, equipos, cuentas de servicio, grupos). Sobre esa estructura, un técnico de un distrito puede recibir delegada la capacidad de **restablecer contraseñas y desbloquear cuentas de su ámbito**, sin ser administrador de nada más. Esa delegación —fina, acotada y auditable— es exactamente lo que persigue la medida `op.acc.3` **(segregación de funciones y tareas)** del ENS [ENS] [ROGA].

2.1.3. Objetos de directorio, cuentas de usuario, grupos y esquemas

Todo lo que existe en el directorio es un **objeto**: una instancia de una **clase** definida en el **esquema**, con un conjunto de **atributos**. El **esquema** es el catálogo de clases y atributos posibles, común a todo el bosque; ampliarlo —lo hacen algunas aplicaciones al instalarse— es una operación **irreversible en la práctica** y debe tratarse con la formalidad de un cambio mayor.

Cada objeto de seguridad —usuario, grupo, equipo— tiene un **identificador de seguridad (SID)** único e inmutable. El SID, y no el nombre, es lo que aparece en los permisos: por eso renombrar una cuenta conserva sus accesos, y por eso borrar una cuenta y volver a crearla con el mismo nombre **no** los recupera. Es una fuente habitual de incidencias reales.

> **DATO CLAVE**
>
> Los permisos se conceden al **SID**, no al nombre. Consecuencias: **renombrar** una cuenta **conserva** los permisos; **borrar y recrear** una cuenta con idéntico nombre **los pierde**, porque el SID es nuevo. Ante una baja temporal, la operación correcta es **deshabilitar**, nunca borrar [MS-AD].

Las **cuentas de usuario** deben distinguirse por su naturaleza, porque cada tipo exige un tratamiento distinto:

Tipo de cuenta	Uso	Tratamiento propio
Nominativa de usuario	Trabajo diario de una persona identificada	Obligatoria: sostiene la trazabilidad. Una cuenta = una persona
Administrativa	Tareas privilegiadas	**Separada** de la de trabajo diario, con segundo factor y sin correo ni navegación
De servicio	Ejecución de aplicaciones y procesos	Sin inicio de sesión interactivo, contraseña larga y rotada, permisos mínimos; preferibles las cuentas gestionadas por el propio directorio
Genérica o compartida	Puestos de uso común (mostrador, sala, quiosco)	**A evitar**: destruye la trazabilidad. Si es inevitable, debe estar documentada, acotada y compensada con otros registros
Invitado / temporal	Personal externo, prácticas, contratas	**Fecha de caducidad obligatoria** en la propia cuenta

El **ciclo de vida de la cuenta** —alta, modificación, baja— es el proceso que más se descuida y el que más problemas de auditoría genera. Debe estar **enlazado con el sistema de personal**, de modo que un cambio de destino o un cese se traduzcan automáticamente en el cambio o la retirada de los accesos. Las **cuentas huérfanas** —de personas que ya no están— son un hallazgo recurrente de cualquier auditoría del ENS, y su revisión periódica es exigible por la medida `op.acc.4` **(proceso de gestión de derechos de acceso)** [ENS].

Los **grupos** son el instrumento con el que se asignan permisos de forma sostenible. Se clasifican por dos ejes:

- **Por finalidad**: grupos **de seguridad** (llevan SID y pueden aparecer en permisos) y grupos **de distribución** (solo listas de correo, sin efecto en permisos).
- **Por ámbito**: **local de dominio** (permisos dentro de su dominio), **global** (agrupa cuentas de su propio dominio) y **universal** (puede contener objetos de todo el bosque, pero se publica en el catálogo global y encarece la replicación).

De ahí procede la regla práctica más citada de la administración de directorios, el llamado **anidamiento AGDLP**: las **cuentas (A)** se meten en **grupos globales (G)** que representan **quién es alguien** (perfil, servicio, distrito); esos grupos globales se meten en **grupos locales de dominio (DL)** que representan **a qué da derecho algo** (acceso de lectura a una carpeta, uso de una impresora); y es al grupo local de dominio al que se le conceden los **permisos (P)** sobre el recurso.

DATO CLAVE

AGDLP: **A**ccount → **G**lobal group → **D**omain **L**ocal group → **P**ermission. Los permisos **nunca** se conceden a usuarios individuales ni directamente a grupos globales. Ventaja decisiva: dar de alta a una persona en un puesto se convierte en **una sola operación** —añadirla al grupo global correspondiente— y el acceso a decenas de recursos se resuelve solo. Es la aplicación práctica del control basado en roles (§2.2.4) [MS-AD] [NIST-RBAC].

EJERCICIO RESUELTO

Un tramitador de la Oficina de Atención a la Ciudadanía de un distrito se traslada a otro distrito. Con permisos concedidos **directamente a la cuenta**, el técnico tendría que localizar uno a uno todos los recursos donde aparece esa cuenta —carpetas compartidas, impresoras, aplicaciones, buzones— y modificarlos, con la certeza estadística de olvidar alguno; el resultado típico es un empleado que conserva durante años acceso a la documentación de su destino anterior, que es exactamente el hallazgo que persigue una auditoría. Con **AGDLP**, la operación completa consiste en **quitarlo del grupo global del distrito de origen y añadirlo al del distrito de destino**: dos clics, efecto inmediato sobre todos los recursos, y un registro claro de quién hizo el cambio y cuándo.

RELACIÓN CON OTROS TEMAS

La administración de las bases de datos que sostienen las aplicaciones corporativas —incluida la gestión de usuarios **dentro** del gestor de base de datos— corresponde al **Tema 15**. La **confidencialidad y disponibilidad en los puestos de usuario final** y los conceptos de seguridad en el desarrollo, al **Tema 25**. Aquí se trata la identidad **de red**, no la de las aplicaciones.

2.2. Autenticación, autorización y políticas de gestión

Tres conceptos que el lenguaje corriente confunde y que conviene separar con precisión:

- **Autenticación**: demostrar **quién eres**. Se apoya en factores de tres tipos: algo que **sabes** (contraseña, PIN), algo que **tienes** (tarjeta criptográfica, generador de códigos, teléfono) y algo que **eres** (biometría). Combinar dos de tipos distintos es **autenticación multifactor**; dos contraseñas no son multifactor.
- **Autorización**: determinar **qué puedes hacer** una vez autenticado.
- **Contabilidad o registro** (*accounting*): dejar constancia de **qué hiciste**.

Los tres juntos forman el modelo **AAA**, y su implementación de referencia en redes es **RADIUS** [RFC2865].

DATO CLAVE

AAA = Autenticación (quién eres) + Autorización (qué puedes) + Contabilidad (qué hiciste). **Multifactor** exige factores de **categorías distintas**: conocimiento, posesión e inherencia. **RADIUS** (RFC 2865/2866) es el protocolo AAA de referencia en redes, con puertos UDP **1812** (autenticación) y **1813** (contabilidad); su extensión **CoA** (RFC 5176) permite **cambiar o cortar una sesión ya autorizada** sin esperar a que expire.

2.2.1. Mecanismos y protocolos de autenticación en red

Kerberos (**RFC 4120**) es el protocolo de autenticación de los dominios de directorio modernos, y su lógica merece entenderse porque explica varios síntomas de avería [RFC4120]. Su idea central es que **la contraseña no viaja por la red** y que el usuario se autentica **una sola vez** por sesión:

1. El usuario se autentica ante el **centro de distribución de claves (KDC)** —papel que desempeña el controlador de dominio— y obtiene un **tique de concesión de tiques (TGT)**, cifrado y con vigencia limitada.
2. Cuando quiere acceder a un servicio, presenta el TGT y recibe un **tique de servicio** específico para él.
3. Presenta ese tique al servicio, que lo valida **sin consultar al KDC**.

Cada tique lleva **sello de tiempo**, de donde se sigue una consecuencia importante: Kerberos **exige relojes sincronizados**, con una tolerancia habitual de **5 minutos**. Un servidor con la hora desajustada rechaza autenticaciones válidas, y el síntoma —«este equipo concreto no deja iniciar sesión aunque la contraseña es correcta»— desconcierta hasta que se mira el reloj. Es también la razón por la que **NTP** (§4.2.3) forma parte de la infraestructura crítica de identidad y no solo de la de registro [RFC5905].

DATO CLAVE

Kerberos: puerto **88**, autenticación por **tiques** (**TGT** del KDC + **tique de servicio** por recurso), **la contraseña no viaja** por la red y **requiere relojes sincronizados** (tolerancia típica de **5 minutos**). Frente a él, los protocolos de reto-respuesta más antiguos, como **NTLM**, deben quedar limitados o deshabilitados por sus debilidades conocidas [RFC4120].

Los demás mecanismos que un administrador de red maneja son:

Mecanismo	Para qué sirve	Dónde aparece
LDAP bind	Validar credenciales contra el directorio	Aplicaciones que se integran con el directorio; **siempre sobre TLS**, nunca en claro [RFC4511]
RADIUS	AAA para el acceso a la red y a la propia electrónica	802.1X, red inalámbrica corporativa, VPN, inicio de sesión de administradores en conmutadores [RFC2865] [FREERADIUS]
EAP	Familia de métodos de autenticación transportados por 802.1X	**EAP-TLS** (certificado en ambos extremos, el más robusto), **PEAP** y **EAP-TTLS** (túnel TLS y credenciales dentro) [RFC3748]
Certificados X.509	Identidad basada en clave pública para personas y equipos	Tarjeta criptográfica del empleado, certificado de equipo para 802.1X, firma electrónica
SAML 2.0 / OAuth 2.0 / OpenID Connect	Federación e inicio de sesión único con aplicaciones web y en la nube	Portales, aplicaciones corporativas, servicios externos [RFC6749]
Multifactor	Segundo factor sobre la autenticación primaria	Obligado en accesos administrativos y remotos

Sobre las **contraseñas**, la doctrina se ha movido de forma relevante y conviene conocer el estado actual: se prioriza la **longitud** sobre la complejidad tipográfica, se recomienda comprobar las contraseñas contra listas de credenciales filtradas y se ha abandonado la **caducidad periódica obligatoria** como medida por defecto —induce contraseñas predecibles con un número al final—, reservándola para cuando hay indicio de compromiso. En el sector público, las exigencias concretas las fija la política de seguridad de la organización dentro del marco del ENS y de las guías CCN-STIC [ENS] [CCN-STIC].

EJEMPLO DE APLICACIÓN EN EL AYTO

La **tarjeta criptográfica** del empleado municipal ilustra bien la diferencia entre autenticación y autorización. La tarjeta acredita **quién** es la persona con un factor de posesión más un PIN, es decir, autenticación fuerte de dos factores. Pero **qué** expedientes puede tramitar con ella no lo decide la tarjeta: lo decide su pertenencia a los grupos del directorio, es decir, la autorización. Un empleado puede tener una autenticación impecable y ningún permiso, o —lo que es peor y ocurre más— permisos heredados de tres destinos anteriores que nadie retiró.

2.2.2. Directivas de grupo y gestión centralizada de políticas

Las **directivas de grupo (GPO)** son el mecanismo por el que la configuración deja de aplicarse equipo a equipo y pasa a **declararse una vez y aplicarse a todos** [MS-GPO]. Una GPO es un objeto del directorio que contiene ajustes de dos ramas —**configuración de equipo** y **configuración de usuario**— y que se **vincula** a un contenedor: un sitio, un dominio o una unidad organizativa. Los equipos y usuarios situados bajo ese contenedor la reciben y la aplican.

La regla de precedencia es el dato central de toda la sección:

> DATO CLAVE
>
> Orden de aplicación de las GPO: **L → S → D → UO** (**Local**, **Sitio**, **Dominio**, **Unidad organizativa**, y dentro de las UO anidadas, de la más externa a la más interna). **Gana la última en aplicarse**, es decir, la **más próxima al objeto**, salvo dos excepciones: una GPO marcada como **forzada** (*enforced*) prevalece sobre las posteriores **y** sobre el **bloqueo de herencia**; y una GPO con **deshabilitada** una de sus ramas no aplica esa parte. Si varias GPO están vinculadas al mismo contenedor, se aplica primero la de **orden de vínculo más alto** y gana, por tanto, la de orden **1** [MS-GPO].

Los mecanismos complementarios que modulan esa regla son:

- **Bloqueo de herencia** en una UO: impide que le lleguen las GPO de contenedores superiores… salvo las **forzadas**.
- **Filtrado por seguridad**: la GPO solo se aplica a los usuarios o equipos que tengan permiso de aplicación, lo que permite dirigirla a un grupo concreto sin cambiar la estructura de UO.
- **Filtrado por WMI**: condiciona la aplicación a una consulta sobre el equipo (versión de sistema operativo, tipo de chasis, fabricante). Potente, pero costoso en tiempo de arranque y difícil de depurar.
- **Preferencias** frente a **directivas**: las **directivas** imponen un ajuste y lo bloquean para el usuario; las **preferencias** establecen un valor inicial que el usuario puede cambiar. Distinguirlo evita el malentendido clásico de «la GPO no se aplica» cuando lo que ocurre es que se aplicó y el usuario la modificó.

La aplicación se produce al **arrancar el equipo** (rama de equipo) y al **iniciar sesión el usuario** (rama de usuario), y después se **actualiza periódicamente** —en el orden de 90 minutos con desviación aleatoria— o bajo demanda. Para diagnosticar, la herramienta esencial es el **conjunto resultante de directivas**, que responde a la pregunta real del técnico: no *qué GPO hay*, sino **qué ajuste ha ganado y por culpa de cuál**.

Dos advertencias de administración con consecuencias prácticas: **demasiadas GPO alargan el arranque y el inicio de sesión** de forma perceptible, sobre todo si incluyen guiones o filtrados

WMI; y **una GPO sin documentar es un misterio permanente**, porque su nombre rara vez basta para saber por qué se creó. La disciplina mínima es nombrar las GPO con un patrón que indique ámbito y propósito, y anotar su justificación en el campo de comentario del propio objeto.

En los entornos modernos, parte de esta función se traslada a plataformas de **gestión del dispositivo** basadas en la nube, que aplican perfiles de configuración a equipos que quizá nunca se conectan a la red corporativa [MS-ENTRA] [UEM]. El concepto es el mismo —configuración declarada centralmente y aplicada al puesto—, pero el canal deja de depender de la LAN, lo que en un escenario de teletrabajo es determinante.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> Un uso característico en una sede de distrito es una GPO vinculada a la unidad organizativa de los equipos de la **Oficina de Atención a la Ciudadanía** que fija el **bloqueo automático de pantalla** por inactividad breve, deshabilita el almacenamiento extraíble y configura la impresora del mostrador. La justificación es directa: son puestos **de cara al público**, con documentación de terceros en pantalla y personas al otro lado del mostrador. La misma organización aplicará un tiempo de bloqueo más laxo a un despacho cerrado. Esa capacidad de dar tratamiento distinto a dos conjuntos de puestos **según su exposición real** es precisamente lo que aportan las unidades organizativas junto a las directivas, y responde a las medidas `mp.eq.1` (puesto de trabajo despejado) y `mp.eq.2` (bloqueo de puesto de trabajo) del ENS [ENS].

2.2.3. Aplicación de directivas de seguridad y asignación de derechos

Dentro de las directivas hay un subconjunto específicamente de seguridad, que en la práctica constituye la **línea base** de configuración de todos los puestos y servidores de la organización. Sus bloques principales son:

Bloque	Contenido	Ejemplo de ajuste
Directivas de cuenta	Contraseñas y bloqueo. **Se definen a nivel de dominio** para las cuentas de dominio	Longitud mínima, historial, umbral y duración del bloqueo tras intentos fallidos
Directivas locales — auditoría	Qué sucesos se registran	Inicios de sesión correctos y fallidos, cambios en cuentas y grupos, acceso a objetos
Directivas locales — asignación de derechos de usuario	**Qué puede hacer cada quién en el sistema**, con independencia de los permisos sobre ficheros	Quién puede iniciar sesión localmente, quién por escritorio remoto, quién puede apagar el equipo, quién puede hacer copias de seguridad, a quién se le **deniega** el inicio de sesión
Opciones de seguridad	Comportamientos del sistema	Firma de comunicaciones, nivel de autenticación admitido, mensaje legal previo al inicio de sesión
Cortafuegos y protección	Reglas del cortafuegos local, protección frente a código dañino, control de aplicaciones	Reglas por perfil de red; listas de aplicaciones permitidas

La **asignación de derechos de usuario** merece atención propia porque se confunde constantemente con los permisos. Un **permiso** se refiere a un **objeto** —esta carpeta, esta impresora— y se define en su lista de control de acceso. Un **derecho** se refiere a una **acción sobre el sistema** —iniciar sesión localmente, cambiar la hora, cargar controladores— y se define en la directiva. Una cuenta puede tener permiso de lectura sobre una carpeta y aun así no poder iniciar sesión en el servidor que la aloja: son planos distintos.

> DATO CLAVE
>
> **Permiso** = qué puedo hacer **sobre un objeto** (lista de control de acceso del recurso). **Derecho** = qué puedo hacer **sobre el sistema** (asignación de derechos de la directiva). Además, en las listas de control de acceso la **denegación explícita prevalece** sobre la concesión, y los permisos **se heredan** del contenedor salvo que la herencia se rompa.

Las líneas base de seguridad no deben improvisarse: existen **plantillas** publicadas por los fabricantes y, en el ámbito público español, las **guías CCN-STIC** de configuración segura, que traducen las exigencias del ENS a ajustes concretos por sistema operativo y por producto [CCN-

STIC] [ENS]. El procedimiento correcto consiste en partir de la guía aplicable, documentar **cada desviación** con su justificación y verificar periódicamente que la configuración real sigue coincidiendo con la declarada. Esto último es exactamente lo que exigen las medidas `op.exp.2` **(configuración de seguridad)** y `op.exp.3` **(gestión de la configuración de seguridad)** del ENS.

> RELACIÓN CON OTROS TEMAS
>
> El desarrollo completo del **ENS y del ENI** corresponde al **Tema 39**; los **conceptos generales de seguridad de los sistemas de información**, incluidas amenazas, vulnerabilidades y criptografía, al **Tema 32**. Aquí se citan únicamente las medidas que el administrador de la red local aplica directamente.

2.2.4. Control de accesos basado en roles y principio de mínimo privilegio

Los modelos de control de acceso que conviene distinguir son cuatro:

Modelo	Quién decide	Rasgo característico
DAC — discrecional	El **propietario** del recurso	Flexible, pero difícil de auditar: los permisos se dispersan
MAC — obligatorio	El **sistema**, según etiquetas de clasificación	Rígido; propio de entornos con información clasificada
RBAC — basado en roles	La organización, mediante **roles**	El modelo de referencia en administración pública y empresa [NIST-RBAC]
ABAC — basado en atributos	Una **política** que evalúa atributos del usuario, del recurso y del contexto	Permite decidir por hora, ubicación, estado del dispositivo o nivel de riesgo; base del acceso condicional y de la confianza cero [NIST-ZT]

En **RBAC**, los permisos se asignan a **roles** y las personas se asignan a roles; nunca se asignan permisos a personas. Sus ventajas son las que hacen viable la administración a escala: el alta de un empleado se resuelve asignándole el rol de su puesto; una auditoría puede responder «¿quién puede hacer X?» consultando un rol en lugar de recorrer recursos; y la revisión periódica de accesos se convierte en una tarea acotada [NIST-RBAC]. Su traducción operativa en un directorio es el anidamiento **AGDLP** ya visto (§2.1.3).

El **principio de mínimo privilegio** establece que cada cuenta debe tener **solo** los permisos imprescindibles para su función y **solo** durante el tiempo necesario. Se materializa en un conjunto de prácticas concretas:

- **Cuenta administrativa separada** de la cuenta de trabajo diario, de modo que la navegación y el correo —los dos vectores habituales de compromiso— nunca ocurran bajo una identidad

privilegiada.

- **Elevación temporal**: privilegios concedidos por un tiempo determinado y para una tarea determinada, en lugar de pertenencia permanente a un grupo de administradores.
- **Segregación de funciones**: quien **solicita** un acceso no es quien lo **aprueba**, y quien lo **ejecuta** no es quien lo **audita**. Es la medida `op.acc.3` del ENS [ENS].
- **Revisión periódica de accesos** (**recertificación**): los responsables funcionales confirman por escrito, cada cierto tiempo, que las personas de su ámbito siguen necesitando lo que tienen. Es la única contramedida eficaz contra la **acumulación de privilegios** que produce el paso por varios destinos.
- **Puestos de administración dedicados** para las tareas privilegiadas, y **red de gestión separada** para acceder a la electrónica (§3.1.2).

DATO CLAVE

Mínimo privilegio + segregación de funciones + revisión periódica de accesos son las tres patas del control de acceso exigido por el ENS. La **acumulación de privilegios** por sucesivos cambios de destino es el hallazgo más frecuente de las auditorías, y **solo** se corrige con recertificación periódica, no con buena voluntad al dar de alta [ENS `op.acc.3` , `op.acc.4`] [NIST-RBAC].

EJERCICIO RESUELTO

Diseñar los roles de administración de la red municipal. Una separación razonable distingue: **operador del CAU** —restablecer contraseñas, desbloquear cuentas, consultar el inventario, **sin** capacidad de cambiar configuraciones de red—; **administrador de puesto** —despliegue de software, directivas de puesto, sin acceso a la electrónica—; **administrador de red** — configuración de conmutadores y VLAN, sin acceso a los datos de las aplicaciones—; **auditor** — lectura de todos los registros, **sin** capacidad de modificarlos ni de borrarlos—; y **administrador del directorio** —esquema, dominios y controladores—, el rol más restringido de todos y sujeto a segundo factor y a cuenta separada. Obsérvese que el papel de **auditor** es de **solo lectura sobre los registros**: si el administrador de red pudiera borrar los registros de su propia actividad, la trazabilidad exigida por el ENS sería puramente nominal.

---

3. Gestión y administración de dispositivos de red y puestos de trabajo

3.1. Administración de equipos e infraestructura de red

La red de una organización mediana está formada por centenares de dispositivos —conmutadores, encaminadores, puntos de acceso, controladores inalámbricos, cortafuegos, sistemas de alimentación ininterrumpida— cada uno con su configuración, su versión de software y su ciclo de vida. Administrarlos uno a uno, conectándose a mano, es viable con diez equipos e imposible con quinientos. El salto conceptual de esta sección es el paso de la **administración artesanal** a la **administración sistemática**.

3.1.1. Gestión centralizada de elementos de red y electrónica de conmutación

La administración sistemática de la electrónica de red descansa sobre cinco pilares:

1. Inventario y fuente única de verdad. Un registro de qué equipos hay, dónde están físicamente —edificio, planta, armario, unidad de rack—, qué modelo y número de serie tienen, con qué versión de software funcionan, a qué otros equipos se conectan y hasta cuándo tienen soporte del fabricante. Herramientas como **NetBox** cumplen esta función de *fuente de verdad*, frente a la cual se contrasta la realidad [NETMGMT-TOOLS] [IPAM]. El descubrimiento automático mediante **LLDP** [IEEE8021AB] permite reconstruir la topología real y detectar exactamente lo que más interesa: **la diferencia entre lo documentado y lo que hay**.

2. Normalización de la configuración. Todos los conmutadores del mismo papel deben tener la misma plantilla base: mismos servidores de registro, mismo NTP, misma configuración de acceso administrativo, mismo esquema de VLAN, mismas protecciones de borde. La variedad no aporta nada y multiplica el tiempo de diagnóstico.

3. Control de versiones de la configuración. Un sistema que recoge periódicamente la configuración de cada dispositivo, la almacena versionada y **avisa de los cambios** —quién, cuándo y qué línea— es una de las herramientas de mayor rendimiento por coste en administración de redes [NETMGMT-TOOLS]. Resuelve tres necesidades a la vez: recuperación ante desastre (reponer un equipo sustituido en minutos), auditoría (la medida `op.exp.3`, gestión de la configuración de seguridad, del ENS) y diagnóstico (la pregunta «¿qué cambió ayer?» tiene respuesta inmediata) [ENS].

4. Automatización. La configuración de red como **código**: plantillas parametrizadas aplicadas mediante herramientas de automatización [ANSIBLE], en lugar de sesiones interactivas. Los beneficios son la **repetibilidad**, la **idempotencia** —aplicar dos veces produce el mismo resultado— y la posibilidad de revisar un cambio **antes** de ejecutarlo. Junto a la interfaz de línea de órdenes

tradicional, los dispositivos modernos ofrecen interfaces programáticas: **NETCONF** sobre SSH (puerto **830**) con modelos de datos **YANG**, y **RESTCONF** sobre HTTPS [RFC6241].

5. Gestión del ciclo de vida. Cada dispositivo tiene fechas de fin de venta, de fin de soporte de software y de fin de soporte técnico. Un conmutador fuera de soporte **no recibe parches de seguridad**, y eso lo convierte en un riesgo aceptado que debe estar documentado y planificado, no descubierto el día que aparece una vulnerabilidad. Esta previsión es el contenido de la medida `op.pl.4` **(dimensionamiento y gestión de la capacidad)** y de la planificación de renovación asociada a `op.exp.4` **(mantenimiento y actualizaciones de seguridad)** [ENS].

DATO CLAVE

LLDP (IEEE 802.1AB) es el protocolo **normalizado** de descubrimiento de vecinos en el nivel de enlace; **CDP** es su equivalente propietario. Su extensión **LLDP-MED** permite que un teléfono IP descubra automáticamente su **VLAN de voz** y su política de calidad de servicio. LLDP es la base del inventario automático de topología y del contraste entre la documentación y la realidad [IEEE8021AB] [PROPIETARIOS].

EJEMPLO DE APLICACIÓN EN EL AYTO

En una organización con centenares de sedes, el mayor enemigo de la administración de red no es la avería: es la **deriva de configuración**. Cada intervención urgente deja un ajuste que nadie documenta, y al cabo de unos años ningún conmutador se parece a otro. La contramedida es doble: **plantillas** aplicadas por automatización, de modo que la configuración correcta se pueda **reimponer**, y **recogida diaria** de configuraciones con aviso de cambios, de modo que una modificación no planificada se detecte al día siguiente y no tres años después.

3.1.2. Interfaces de gestión en banda y fuera de banda

Todo dispositivo de red admite ser administrado por varias vías, y conviene clasificarlas correctamente:

Interfaz	Qué es	Ventajas	Límites
Línea de órdenes (CLI) por SSH	Sesión de terminal cifrada contra el equipo	Precisa, universal, automatizable	Requiere conocer la sintaxis de cada fabricante
Interfaz web (GUI)	Consola HTTPS integrada en el equipo	Accesible, buena para consulta y diagnóstico	Poco automatizable; superficie de ataque adicional
SNMP	Consulta y notificación normalizada	Interoperable, base de la monitorización	Escritura poco usada y arriesgada; v1/v2c inseguros
NETCONF / RESTCONF	Configuración programática con modelos YANG	Transaccional, validable, apta para automatización	Soporte desigual según fabricante y versión
Puerto de consola	Conector físico serie o USB en el propio equipo	Funciona **aunque la red esté caída**; imprescindible para recuperación	Exige **presencia física**
Puerto de gestión dedicado	Interfaz Ethernet separada del plano de datos	Aísla la administración del tráfico de usuarios	Necesita su propia red

De aquí surge la distinción central de este epígrafe:

> DATO CLAVE
>
> Gestión **dentro de banda** (*in-band*): se administra el dispositivo **por la misma red** que transporta los datos de usuario. Es sencilla y barata, pero **si la red cae, se pierde también la capacidad de gestionarla** —y esa es exactamente la situación en la que hace falta—. Gestión **fuera de banda** (*out-of-band*): se administra por una **vía independiente** —puerto de consola, red de gestión física o lógicamente separada, servidor de consolas, acceso por red móvil—, que **sobrevive a la caída del plano de datos**. Toda red de la que dependa un servicio público debe tener alguna forma de acceso fuera de banda.

El caso que hace evidente la necesidad es la **configuración remota mal ejecutada**: un administrador aplica desde su despacho una regla de filtrado o cambia la VLAN de gestión de un conmutador situado en otra sede y, en el mismo instante en que la aplica, **pierde la sesión** que le permitía deshacerla. Sin acceso fuera de banda, la solución consiste en desplazar a una persona

con un cable de consola. Con acceso fuera de banda, en reconectar por la otra vía. Existen mecanismos preventivos —confirmación diferida del cambio con reversión automática si el administrador no lo confirma— que algunas plataformas ofrecen y que conviene usar sistemáticamente en intervenciones remotas.

La **red de gestión** debe cumplir además tres condiciones que el ENS respalda: estar **separada** del tráfico de usuarios (medida `mp.com.4`, separación de flujos de información en la red), ser **accesible solo desde puestos de administración autorizados** (`op.acc.2`, requisitos de acceso) y estar **registrada** en su totalidad (`op.exp.8`, registro de la actividad) [ENS].

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> En una sede de distrito con Oficina de Atención a la Ciudadanía, un fallo de configuración que deje incomunicado el conmutador de acceso implica, en el peor caso, que el mostrador no puede atender al público. Con acceso **fuera de banda** —un servidor de consolas en el armario o un acceso por red móvil—, el técnico recupera el equipo desde el centro de proceso de datos en minutos. Sin él, hay que desplazar a alguien con un portátil y un cable de consola, y el tiempo de restablecimiento se cuenta en horas de oficina cerrada.

3.1.3. Protocolos de administración segura

La administración de la propia infraestructura es un objetivo de alto valor: quien controla un conmutador puede desviar tráfico, y quien controla el directorio controla la organización. De ahí que la seguridad de los protocolos de gestión sea una exigencia y no una recomendación.

La regla general es sustituir **todo protocolo en claro** por su equivalente cifrado:

Protocolo inseguro	Puerto	Sustituto seguro	Puerto
Telnet	TCP 23	**SSH**	TCP **22**
HTTP de administración	TCP 80	**HTTPS**	TCP **443**
FTP / TFTP para configuraciones e imágenes	TCP 21 / UDP 69	**SCP / SFTP** sobre SSH	TCP 22
SNMP v1 / v2c (comunidad en claro)	UDP 161/162	**SNMPv3** con autenticación y cifrado	UDP **161/162**
LDAP simple	TCP 389	**LDAPS** o LDAP con STARTTLS	TCP **636** / 389
Syslog sobre UDP	UDP 514	**Syslog sobre TLS**	TCP **6514**

DATO CLAVE

SNMPv3 es la **única** versión de SNMP que ofrece autenticación e integridad (**authNoPriv**) y, además, cifrado (**authPriv**). Las versiones **1 y 2c** se autentican con una **cadena de comunidad que viaja en claro**, equivalente a una contraseña visible en la red; y las comunidades predeterminadas `public` y `private` siguen siendo un hallazgo habitual en auditorías. Puertos: **UDP 161** para consultas del gestor y **UDP 162** para notificaciones del agente [RFC3411].

Más allá de sustituir protocolos, la administración segura de la electrónica exige:

- **Cuentas nominativas** para cada administrador, autenticadas **contra el directorio o contra RADIUS/TACACS+**, no cuentas locales compartidas del equipo. Solo así el registro dice **quién** hizo cada cambio, y solo así una baja de personal se traduce en pérdida de acceso a los quinientos dispositivos a la vez.
- **Cuenta local de emergencia** con contraseña custodiada, para el caso de que el servidor de autenticación no esté disponible: sin ella, una caída del directorio deja la red inadministrable.
- **Segundo factor** en el acceso administrativo, siempre que la plataforma lo permita.
- **Listas de control de acceso de gestión**: el plano de administración solo acepta conexiones desde las direcciones de los puestos de administración.
- **Autenticación por clave pública** en SSH y desactivación del acceso por contraseña donde sea viable.
- **Desactivación de servicios innecesarios** en el propio dispositivo —servidores web sin uso, protocolos de descubrimiento hacia puertos de usuario, servicios heredados—: es la aplicación directa de la medida `op.exp.2` (configuración de seguridad) del ENS [ENS].
- **Registro de toda la actividad administrativa** hacia un servidor de registro externo, de modo que quien administra el equipo no pueda alterar la traza de lo que hizo (§4.2.3).

Un mecanismo específico de nivel 2 que conviene conocer es **MACsec** (**IEEE 802.1AE**), que cifra el tráfico **salto a salto** entre dos dispositivos adyacentes. Se emplea para proteger enlaces que atraviesan zonas no controladas —por ejemplo, la fibra entre dos edificios que pasa por canalización pública— y se distingue de una VPN en que no crea un túnel extremo a extremo, sino que protege cada enlace individualmente [IEEE8021AE].

RELACIÓN CON OTROS TEMAS

El **control remoto del puesto de usuario** —RDP, VNC, herramientas de asistencia, gestión fuera de banda del equipo del usuario— y la **gestión de la resolución de incidencias** corresponden al **Tema 29**. El **acceso remoto seguro y las VPN**, al **Tema 36**. Aquí se trata la administración de la **infraestructura de red**, no la del escritorio del empleado ni el acceso desde el exterior.

3.2. Gestión del ciclo de vida del puesto de trabajo y dispositivos finales

Si la sección anterior trataba de los centenares de dispositivos de infraestructura, esta trata de los millares de dispositivos finales: ordenadores de sobremesa, portátiles, teléfonos IP, impresoras, escáneres, tabletas, terminales de mostrador, cámaras y todo lo que hoy se conecta a una red municipal. Su gestión se ordena en un **ciclo de vida** de cinco fases.

3.2.1. Despliegue, aprovisionamiento e inventariado de dispositivos

El **aprovisionamiento** es el conjunto de operaciones que convierten un equipo recién sacado de su caja en un puesto de trabajo utilizable y gestionado. Hacerlo a mano —instalar, configurar, unir al dominio, instalar aplicaciones— consume entre una y tres horas por equipo y produce resultados desiguales. Los métodos sistemáticos son:

Método	Cómo funciona	Cuándo conviene
Imagen maestra (clonación)	Se prepara un equipo modelo, se captura su disco y se despliega sobre los demás	Lotes grandes y homogéneos; exige mantener la imagen actualizada
Instalación desatendida por red	Arranque **PXE** o **HTTP Boot**, instalación guiada por un fichero de respuestas y configuración posterior	Parque heterogéneo; más lento pero más flexible [PXE]
Aprovisionamiento moderno	El equipo se registra en la plataforma de gestión y esta le aplica perfiles, aplicaciones y directivas por internet	Teletrabajo y equipos que nunca pisan la sede [MS-ENTRA] [UEM]
Puesto virtualizado	No hay que aprovisionar el equipo físico: se le entrega un escritorio del centro de datos	Perfiles muy estandarizados; ver **Tema 28**

El **arranque por red PXE** merece una precisión de administración: exige que el DHCP entregue opciones específicas que indican al equipo dónde está el servidor de arranque, y esa configuración conviene **acotarla a las VLAN donde se despliega**. Un servidor PXE alcanzable desde toda la red permite arrancar cualquier equipo con un sistema operativo ajeno al corporativo, lo que es una vía de compromiso conocida.

El **inventario** es la contrapartida permanente del despliegue, y debe distinguir dos naturalezas complementarias:

- **Inventario administrativo**: número de serie, factura, garantía, centro de coste, persona o puesto asignado, ubicación. Vive en la gestión patrimonial de la organización.

- **Inventario técnico**: hardware detectado, sistema operativo y versión, software instalado, parches aplicados, dirección MAC e IP, última comunicación con la plataforma. Lo recoge un **agente** instalado en el equipo o un descubrimiento activo de red [UEM].

Los dos deben **conciliarse periódicamente**, y la conciliación es una de las tareas más rentables de la administración: revela equipos que están en el inventario administrativo pero llevan meses sin comunicar —¿están rotos, guardados, robados?— y equipos que comunican con la red pero no constan en ningún sitio, que es el hallazgo verdaderamente preocupante.

> DATO CLAVE
>
> El **inventario de activos** es la medida `op.exp.1` del ENS, y es la **primera** de todo el marco operacional por una razón lógica: no se puede proteger, actualizar ni monitorizar lo que no se sabe que existe. Un dispositivo desconocido conectado a la red no se parchea, no se inventaría y no se vigila: para la organización, **está fuera de control** [ENS].

> EJEMPLO DE APLICACIÓN EN EL AYTO
>
> El caso más incómodo de inventario en una red municipal no son los ordenadores, sino todo lo demás: teléfonos IP, impresoras multifunción, escáneres de mostrador, cámaras, pantallas informativas, sistemas de gestión de turnos de espera, controles de acceso, sensores y equipamiento de instalaciones. Son dispositivos que **nadie considera informática**, que llegan por contratos ajenos al departamento de sistemas, que rara vez admiten agente y que casi nunca se actualizan. El ENS los contempla expresamente en la medida `mp.eq.4` **(otros dispositivos conectados a la red)**, y la respuesta de administración es doble: **descubrirlos** con barridos periódicos y con la información del control de admisión, y **confinarlos** en VLAN propias sin capacidad de iniciar conexiones hacia el resto de la red [ENS].

3.2.2. Gestión de parches, actualizaciones y mantenimiento de firmware

Mantener actualizado el parque es la medida de seguridad con mejor relación entre esfuerzo y riesgo evitado, y es una obligación explícita del ENS en la medida `op.exp.4` **(mantenimiento y actualizaciones de seguridad)** [ENS]. El proceso de gestión de parches se articula en seis pasos:

1. **Vigilancia**: seguimiento de los boletines de los fabricantes y de los avisos del CCN-CERT y del INCIBE.
2. **Evaluación**: determinar qué activos del inventario están afectados y con qué criticidad. Aquí se apoya de nuevo todo en `op.exp.1`.
3. **Priorización**: la gravedad teórica de una vulnerabilidad —medida por sistemas de puntuación como CVSS— debe ponderarse por la **exposición real**: una vulnerabilidad crítica en un servicio que solo escucha en la red de gestión es menos urgente que una media en un servidor publicado.

4. **Prueba**: aplicación en un grupo piloto representativo antes de la difusión general.
5. **Despliegue por anillos**: piloto → grupo amplio → parque completo, con ventanas de mantenimiento acordadas.
6. **Verificación**: comprobar en el inventario **qué porcentaje del parque quedó realmente actualizado**. Este es el paso que más se omite y el que convierte el proceso en algo medible: un despliegue lanzado no es un despliegue aplicado.

Las herramientas dependen de la plataforma —servidores de actualización centralizados en Windows, réplicas locales de repositorios en Linux, plataformas unificadas para el parque móvil—, pero el proceso es idéntico [WSUS] [UEM].

El **firmware** de los dispositivos merece tratamiento aparte por tres razones: su actualización es **más arriesgada** (un fallo puede inutilizar el equipo), exige **ventana de indisponibilidad** (un conmutador se reinicia) y suele **olvidarse** (nadie recuerda cuándo se actualizó por última vez el firmware de una impresora o de una cámara). La disciplina mínima consiste en llevar el firmware en el inventario como un dato más, planificar su revisión al menos anualmente y actualizar de inmediato cuando haya un aviso de seguridad con explotación conocida.

Un caso particular que aparece en toda red real es el del **equipo que no se puede parchear**: un sistema que sostiene una aplicación certificada solo para una versión antigua, un dispositivo cuyo fabricante ha desaparecido, una máquina asociada a un equipamiento cuya sustitución implica una inversión mayor. La respuesta profesional no es ignorarlo ni apagarlo sin más: es **documentar el riesgo**, **aislarlo en un segmento propio** con acceso estrictamente filtrado, **reforzar su vigilancia**, y **planificar y presupuestar su sustitución** con fecha. Un riesgo aceptado y documentado es una decisión de gestión; un riesgo desconocido es una avería esperando fecha.

> EJERCICIO RESUELTO
>
> *Se publica una vulnerabilidad crítica con explotación conocida en el firmware de un modelo de impresora multifunción del que hay 90 unidades repartidas por sedes municipales.* Actuación ordenada: **(1)** consultar el **inventario** para saber cuántas hay, dónde y con qué versión; **(2)** comprobar la **exposición**: ¿son alcanzables desde la red de usuarios? ¿desde internet? ¿desde la red de invitados?; **(3) contención inmediata** mientras se prepara la actualización —restringir en el conmutador o en el cortafuegos el acceso a los puertos de administración de esas impresoras, dejando solo la impresión—; **(4) probar** el firmware nuevo en dos unidades de una sede poco crítica; **(5) desplegar por anillos** con ventana pactada, empezando por las más expuestas; **(6) verificar** en el inventario que las 90 quedan actualizadas, e investigar una a una las que no. La lección de método: la **contención por red** es inmediata y no depende del fabricante; el parche llega después. Y el paso que suele faltar es el **(6)**.

3.2.3. Control de admisión a la red y autenticación de dispositivos

Durante décadas, estar enchufado a una roseta equivalía a estar dentro. El **control de admisión a la red (NAC)** invierte ese supuesto: **ningún dispositivo obtiene acceso hasta que se identifica y se comprueba que cumple la política**.

El mecanismo normalizado es **IEEE 802.1X**, control de acceso a la red **basado en puerto** [IEEE8021X]. Sus tres papeles son:

Papel	Quién lo desempeña	Qué hace
Suplicante	El dispositivo que quiere entrar (su cliente 802.1X)	Presenta credenciales: certificado, usuario y contraseña o identidad de equipo
Autenticador	El **conmutador** o el **punto de acceso**	Mantiene el puerto cerrado, retransmite el diálogo y aplica la decisión
Servidor de autenticación	**RADIUS**	Verifica contra el directorio y devuelve la decisión y los atributos aplicables

Antes de la autenticación, el puerto **solo deja pasar tramas EAPOL** (EAP sobre LAN): ni DHCP, ni DNS, ni nada. Una vez autenticado, el servidor RADIUS puede además devolver **atributos** que configuran dinámicamente el puerto: **VLAN asignada**, lista de control de acceso aplicable o límite de caudal. Este es el punto clave del NAC moderno: la red **no solo admite o rechaza, sino que coloca a cada dispositivo donde le corresponde**.

> DATO CLAVE
>
> **802.1X**: **suplicante** (equipo) → **autenticador** (conmutador o punto de acceso) → **servidor de autenticación** (**RADIUS**). Hasta que la autenticación tiene éxito, por el puerto **solo circula EAPOL**. El servidor puede devolver la **VLAN dinámica** y otros atributos. Los métodos **EAP** más usados son **EAP-TLS** (certificado en ambos extremos, el más robusto) y **PEAP** o **EAP-TTLS** (túnel TLS con credenciales en su interior) [IEEE8021X] [RFC3748].

Como no todos los dispositivos admiten un suplicante 802.1X —impresoras antiguas, cámaras, sensores, equipamiento industrial—, existen mecanismos de respaldo que hay que conocer con sus limitaciones:

- **Autenticación por dirección MAC (MAB)**: el conmutador, tras fallar 802.1X, envía la MAC al servidor RADIUS como si fuera una credencial. Es **débil por definición** —una MAC se falsifica en segundos— y debe considerarse un **inventario aplicado**, no una autenticación. Se refuerza combinándolo con perfilado del dispositivo y con VLAN muy restringidas.
- **VLAN de invitados**: destino de los dispositivos que no se autentican, con acceso solo a internet.

- **VLAN de cuarentena o de remediación**: destino de los dispositivos que se autentican pero **no cumplen la política** —antivirus desactualizado, parches ausentes, cifrado de disco apagado—, con acceso únicamente a los servidores necesarios para corregir la desviación.
- **Modo de supervisión** (*monitor mode*): la política se evalúa y se registra pero **no se aplica**. Es la fase imprescindible de todo despliegue de NAC: permite descubrir cuántos dispositivos fallarían **antes** de cortar el acceso a media plantilla un lunes por la mañana.

La identidad del dispositivo puede reforzarse con **IEEE 802.1AR (DevID)**, que define identificadores ligados criptográficamente al equipo: un **IDevID** instalado de fábrica y **LDevID** emitidos localmente por la organización [IEEE8021AR]. Y una vez concedido el acceso, la extensión **CoA** de RADIUS (**RFC 5176**) permite **cambiar la autorización de una sesión activa o cortarla**: si la plataforma de seguridad detecta que un equipo ya admitido se ha comprometido, puede moverse a cuarentena **sin esperar a que se desconecte** [RFC2865].

> DATO CLAVE
>
> **RADIUS CoA** (*Change of Authorization*, RFC 5176) permite **modificar o terminar una sesión ya autorizada**: mover un equipo a cuarentena o desconectarlo en caliente. Es lo que convierte el control de admisión en un control **continuo** y no en una comprobación única en el momento de conectar [RFC2865].

Junto a 802.1X conviene recordar dos controles complementarios de nivel 2 que ya se citaron y que actúan como red de seguridad: la **seguridad de puerto** —límite de direcciones MAC aprendidas— y la **inspección DHCP** con **inspección ARP dinámica** y **guarda de origen IP** (§1.2.1). Ninguno sustituye al control de admisión, pero los tres juntos elevan mucho el coste de un ataque desde el interior del edificio.

> EJEMPLO DE APLICACIÓN EN EL AYTO
>
> El despliegue de control de admisión en una sede con Oficina de Atención a la Ciudadanía debe planificarse con especial cuidado por una razón operativa: **un fallo del servidor RADIUS deja sin red a toda la sede**, y con ella el mostrador de atención al público. Las precauciones profesionales son cuatro: **redundar** el servicio de autenticación en dos servidores de ubicaciones distintas; configurar en el conmutador un **comportamiento de contingencia** definido para cuando ningún servidor responda —normalmente, permitir el acceso en una VLAN restringida en lugar de bloquear—; desplegar en **modo de supervisión** durante semanas antes de aplicar; y **excluir** inicialmente los puestos críticos de mostrador hasta que el resto esté estabilizado. Un control de seguridad que interrumpe un servicio público es, en la práctica, un incidente de disponibilidad, y la disponibilidad es también una **dimensión del ENS** [ENS].

---

4. Monitorización, análisis y control del tráfico de red

4.1. Monitorización y gestión del rendimiento de red

Monitorizar es **saber en qué estado está la red sin tener que preguntárselo a los usuarios**. Una organización sin monitorización se entera de sus averías por el teléfono del Centro de Atención a Usuarios, siempre tarde y siempre con información pobre; una organización con monitorización se entera antes, con datos, y con frecuencia **antes de que el servicio llegue a degradarse**.

Conviene separar desde el principio tres actividades que se confunden:

- **Monitorizar** es observar de forma continua un conjunto de indicadores y comparar con umbrales. Responde a *¿está funcionando?*
- **Analizar** es examinar el tráfico o los registros para entender un comportamiento concreto. Responde a *¿por qué ocurre esto?*
- **Controlar** es actuar sobre el tráfico para que se comporte como se desea: priorizar, limitar, filtrar, reencaminar. Responde a *¿cómo lo hago mejor?*

El enunciado del tema las une bajo «monitorización y control de tráfico» porque en la práctica forman un ciclo: se monitoriza para detectar, se analiza para entender y se controla para corregir; y después se vuelve a monitorizar para comprobar que la corrección funcionó.

4.1.1. Protocolos e instrumentos de monitorización de red

El instrumento clásico y todavía dominante es el **protocolo simple de gestión de red (SNMP)**, cuya arquitectura definen los **RFC 3411-3418** [RFC3411]. Sus piezas son:

- **Gestor**: el sistema de monitorización, que consulta.
- **Agente**: el proceso que se ejecuta en el dispositivo gestionado y responde.
- **MIB** (*Management Information Base*): la estructura jerárquica de los datos disponibles, cuyos elementos se identifican por **OID**. La **MIB-II** (**RFC 1213**) define los grupos comunes a todo dispositivo IP: `system`, `interfaces`, `ip`, `tcp`, `udp` [RFC1213]. Junto a ella, cada fabricante publica sus MIB privadas para datos propios —temperatura, ventiladores, sesiones, alimentación eléctrica—.

Las operaciones son pocas: **GET** y **GETNEXT** (consultar un valor o recorrer un árbol), **GETBULK** (consultar muchos de una vez, introducido en la versión 2), **SET** (escribir, poco usado y desaconsejado en producción) y las notificaciones no solicitadas del agente hacia el gestor: **TRAP** (sin confirmación) e **INFORM** (con confirmación).

DATO CLAVE

SNMP: el **gestor** consulta al **agente** por **UDP 161**; el agente envía **trap** o **inform** por **UDP 162**. Los datos se organizan en la **MIB** y se identifican por **OID**. **TRAP no se confirma; INFORM sí**. Solo **SNMPv3** ofrece autenticación y cifrado; **v1 y v2c** usan **cadena de comunidad en claro**. La **MIB-II** es el RFC **1213** [RFC3411] [RFC1213].

La mayoría de la monitorización de red se apoya en los **contadores de interfaz** de la MIB-II, y entenderlos es imprescindible porque son **acumulativos**: `ifInOctets` e `ifOutOctets` no dan velocidad, sino un total desde el arranque. La velocidad se obtiene calculando la **diferencia entre dos lecturas dividida por el intervalo**. De ahí una precaución práctica: los contadores de 32 bits **desbordan** en pocos minutos a velocidades de gigabit, por lo que en enlaces rápidos deben usarse los **contadores de 64 bits** de las MIB de alta capacidad.

Junto a SNMP conviene conocer el resto del instrumental:

Instrumento	Qué aporta	Observaciones
ICMP (`ping`)	Alcanzabilidad, retardo de ida y vuelta y pérdida	Barato y universal; puede estar limitado o filtrado, y su prioridad en el dispositivo es baja
Sondas sintéticas	Simulan una transacción real (abrir la sede, resolver un nombre, iniciar una llamada) desde varios puntos	Miden lo que **percibe el usuario**, no solo lo que dice el equipo
Syslog	Eventos que el propio dispositivo notifica	Complemento imprescindible: SNMP dice **cuánto**, syslog dice **qué pasó** [RFC5424]
Flujos (NetFlow/IPFIX/sFlow)	Quién habla con quién, cuánto y cuándo	El instrumento de análisis de tráfico por excelencia (§4.2.2)
Telemetría de flujo continuo	El dispositivo **empuja** métricas de forma continua en lugar de esperar a ser consultado	Evolución moderna del sondeo; mucho mayor resolución temporal
Agentes en el sistema operativo	Métricas del anfitrión: CPU, memoria, disco, procesos	Cierran el hueco que la monitorización de red no ve
Analizadores de paquetes	El detalle completo de la conversación	Se reserva para el diagnóstico puntual (§4.2.1)

DATO CLAVE

SNMP mide, syslog narra. SNMP entrega **valores numéricos** consultados periódicamente (caudal, errores, temperatura); syslog entrega **eventos** con marca de tiempo (un enlace que cae, un usuario que se autentica, una configuración que cambia). Un sistema de monitorización serio necesita **los dos**, y ambos exigen **NTP** para que sus tiempos sean comparables [RFC3411] [RFC5424] [RFC5905].

Sobre la construcción del sistema de monitorización, dos criterios de administración con mucho rendimiento práctico. El primero: **monitorizar servicios, no solo dispositivos**. Que un conmutador responda a `ping` no significa que la sede funcione; una sonda que compruebe periódicamente que se resuelve un nombre interno, se obtiene dirección por DHCP y se carga la página de la sede dice mucho más. El segundo: **cuidar los umbrales**. Un sistema que genera cien avisos diarios no se lee, y una monitorización que no se lee es peor que ninguna, porque produce una falsa sensación de control. El objetivo es que **cada aviso exija una acción**; los demás son ruido y deben ajustarse o eliminarse.

4.1.2. Métricas de rendimiento, disponibilidad y calidad de servicio

Las métricas que un administrador de red vigila se agrupan en cuatro familias:

Familia	Métricas	Qué revela
Disponibilidad	Porcentaje de tiempo en servicio, número y duración de las interrupciones	Cumplimiento del compromiso de servicio
Utilización	Caudal de entrada y salida por interfaz, porcentaje sobre la capacidad, percentil 95	Necesidad de ampliar capacidad, cuellos de botella
Errores	Errores de entrada y salida, descartes, colisiones tardías, CRC, restablecimientos de interfaz	**Problemas físicos**: cable, conector, óptica, desajuste de dúplex
Calidad	Retardo, fluctuación (*jitter*), pérdida de paquetes	Aptitud de la red para tráfico en tiempo real

La **disponibilidad** se expresa como porcentaje, y conviene tener presente la traducción a tiempo real de indisponibilidad anual:

Disponibilidad	Indisponibilidad anual aproximada
99 %	~3,65 días
99,9 % («tres nueves»)	~8,8 horas
99,95 %	~4,4 horas
99,99 % («cuatro nueves»)	~52,6 minutos
99,999 % («cinco nueves»)	~5,3 minutos

DATO CLAVE

99,9 % de disponibilidad ≈ 8,8 horas de parada al año; 99,99 % ≈ 53 minutos; 99,999 % ≈ 5 minutos. Cada nueve adicional divide la indisponibilidad **entre diez** y multiplica el coste mucho más que por diez. Términos asociados: **MTBF** (tiempo medio entre fallos), **MTTR** (tiempo medio de reparación o restablecimiento) y **MTTD** (tiempo medio de detección). La monitorización actúa sobre el **MTTD**, y reducirlo es la forma más barata de reducir el MTTR.

Sobre la **utilización**, un criterio de administración importante: no debe medirse por la **media**, que oculta los picos, sino por el **percentil 95** —el valor que solo se supera el 5 % del tiempo—, que es además el criterio habitual de facturación de los operadores. Y una regla de diseño de campus: un enlace que sostiene el **70 % de utilización** en su percentil 95 debe estar **ya planificado** para ampliación, porque el margen restante no absorbe ni el crecimiento ni los picos.

Sobre los **errores**, la lectura importante es cualitativa. Los errores de CRC y las colisiones tardías apuntan a un problema **físico**: latiguillo defectuoso, conector mal crimpado, óptica sucia o degradada, o —el clásico— **desajuste de dúplex** entre dos extremos, uno negociando y otro fijado a mano. El síntoma característico del desajuste de dúplex es una red que «va lenta» pero no falla, con colisiones tardías en un extremo y errores en el otro; y su causa es casi siempre una intervención en la que alguien fijó la velocidad en un solo lado.

EJERCICIO RESUELTO

Un enlace troncal de 1 Gbit/s entre el conmutador de acceso de una planta y el de distribución muestra 0,7 % de errores de entrada y utilización media del 12 %. Interpretación: la utilización es baja, luego **no es un problema de capacidad**; el 0,7 % de errores sobre un enlace de fibra o cobre en buen estado es **anormal** —lo esperable es prácticamente cero—. La hipótesis principal es **física o de negociación**: latiguillo o conector defectuoso, transceptor óptico degradado, o desajuste de dúplex si es cobre. Comprobaciones: mirar los contadores del **otro extremo** (un desajuste de dúplex produce errores asimétricos característicos), revisar los niveles ópticos si es fibra, comprobar la negociación en ambos extremos y, si nada concluye, sustituir el latiguillo, que es la prueba más barata. Lección de método: **utilización baja + errores altos = capa física**, casi siempre. Ampliar capacidad no habría corregido nada.

4.1.3. Parámetros de calidad de servicio en redes de área local

La **calidad de servicio (QoS)** es el conjunto de mecanismos que permiten dar **trato diferenciado** al tráfico para que las aplicaciones sensibles funcionen aunque la red esté cargada. Su premisa suele enunciarse mal, así que conviene fijarla: **la calidad de servicio no crea capacidad**. Solo decide **quién sufre** cuando la capacidad no alcanza. Si un enlace está saturado de forma sostenida, la solución es ampliarlo; la calidad de servicio gestiona la **congestión transitoria**, que es la que ocurre en toda red real varias veces al día.

Los cuatro parámetros que la definen son:

Parámetro	Qué mide	A quién afecta	Referencia habitual para voz
Ancho de banda (caudal)	Capacidad disponible para el flujo	A todos	Según códec
Retardo (latencia)	Tiempo de tránsito extremo a extremo	Conversación y aplicaciones interactivas	**≤ 150 ms** en un sentido
Fluctuación (*jitter*)	**Variación** del retardo entre paquetes consecutivos	Voz y vídeo: obliga a usar memorias intermedias	**≤ 30 ms**
Pérdida de paquetes	Porcentaje de paquetes descartados	Voz (cortes), TCP (retransmisiones)	**< 1 %**

DATO CLAVE

Distinguir **retardo** de **fluctuación**: el retardo es **cuánto tarda**; la fluctuación es **cuánto varía** ese retardo entre paquetes. Una red con retardo alto pero constante permite una conversación incómoda pero inteligible; una red con retardo bajo pero muy variable produce **voz entrecortada**, que es peor. Valores de referencia habituales para voz sobre IP: **retardo unidireccional ≤ 150 ms, fluctuación ≤ 30 ms y pérdida < 1 %** —son objetivos de diseño ampliamente aceptados, no cifras de una norma jurídica—.

El retardo total se compone de cuatro sumandos, y saber cuál domina orienta la solución: retardo de **propagación** (distancia física, irreducible), de **serialización** (tiempo de poner los bits en el cable, relevante solo en enlaces lentos), de **procesamiento** (el equipo decide qué hacer con el paquete) y de **encolamiento** (espera en la cola de salida). En una red de área local moderna, **el retardo que importa es el de encolamiento**, y es precisamente sobre el que actúan los mecanismos de calidad de servicio.

Un fenómeno que conviene conocer porque explica muchas quejas es la **hinchazón de memorias intermedias** (*bufferbloat*): colas excesivamente grandes que, en lugar de descartar, acumulan paquetes y disparan el retardo. El resultado típico es una descarga que satura el enlace y deja la videoconferencia inservible pese a que «no se pierde nada». Las contramedidas son los algoritmos de gestión activa de colas, que descartan de forma anticipada e inteligente para mantener las colas cortas.

EJEMPLO DE APLICACIÓN EN EL AYTO

El escenario cotidiano en la sede del caso de referencia es una **sala de videoconferencia** que se usa a la vez que veinte puestos sincronizan documentos y se ejecuta una copia de seguridad hacia el centro de proceso de datos. Sin calidad de servicio, la videoconferencia compite en igualdad con la copia y pierde: el resultado es la reunión que se corta. Con calidad de servicio, la voz se coloca en la **cola de prioridad**, el vídeo en una clase garantizada, y la copia de seguridad en **mejor esfuerzo** con límite de caudal, de modo que utiliza toda la capacidad libre pero cede en cuanto hay tráfico prioritario. El coste de esta configuración es una tarde de trabajo; el beneficio, que las reuniones dejen de cortarse.

4.1.4. Mecanismos de clasificación, marcado y priorización de tráfico

El modelo de calidad de servicio dominante es **DiffServ** (**RFC 2474** y **RFC 2475**), que evita mantener estado por flujo: cada paquete lleva una **marca** y cada nodo decide **por salto** cómo tratarlo, según su clase [RFC2474] [RFC2475]. La alternativa histórica, **IntServ** con reserva por flujo mediante RSVP, no escaló y hoy tiene un papel residual.

El marcado se realiza en dos niveles distintos, y confundirlos es un error frecuente:

Nivel	Campo	Tamaño	Dónde vive
Nivel 2 (enlace)	**PCP** (*Priority Code Point*), a veces llamado CoS	**3 bits** (valores 0-7)	Dentro de la **etiqueta 802.1Q**: solo existe en tramas etiquetadas, y **se pierde** al cruzar un encaminador
Nivel 3 (red)	**DSCP** (*Differentiated Services Code Point*)	**6 bits** (valores 0-63)	En el campo DS de la **cabecera IP**: **sobrevive** de extremo a extremo

DATO CLAVE

PCP = 3 bits en la etiqueta 802.1Q (nivel 2), se pierde al encaminar. DSCP = 6 bits en la cabecera IP (nivel 3), sobrevive extremo a extremo. Valores que hay que reconocer: **EF = DSCP 46** (*Expedited Forwarding*, **voz**), **AF41 = DSCP 34** (vídeo interactivo), **CS3 = 24** (señalización de llamadas), **AF21 = 18** (transaccional) y **BE/CS0 = 0** (mejor esfuerzo). Las clases **AF** se nombran **AFxy**, donde **x** es la clase (1-4) e **y** la precedencia de descarte (1-3, a mayor número mayor probabilidad de ser descartado) [RFC2474] [RFC2597] [RFC4594].

El proceso completo consta de cinco operaciones, que conviene distinguir:

1. **Clasificación**: identificar a qué clase pertenece un paquete, por puerto de entrada, por dirección, por protocolo, por inspección profunda o —lo más eficiente— por su marca previa.
2. **Marcado**: escribir el valor de DSCP o de PCP.
3. **Vigilancia** (*policing*): comprobar que un flujo no excede su caudal contratado y, si lo excede, **descartar** o **remarcar** los paquetes sobrantes. Actúa **sin memoria intermedia**, luego es abrupta pero no añade retardo.
4. **Modelado** (*shaping*): retener el exceso en una memoria intermedia y entregarlo más tarde de forma suavizada. Añade **retardo** pero evita descartes.
5. **Encolamiento y planificación**: repartir la capacidad de salida entre las colas. Los esquemas habituales son la **cola de prioridad estricta** —la clase de voz sale siempre primero, con un límite para que no ahogue al resto— y el **reparto ponderado**, que asigna un porcentaje de capacidad a cada clase.

DATO CLAVE

Vigilancia (*policing*) frente a modelado (*shaping*): la vigilancia **descarta o remarca** el exceso y **no introduce retardo**; el modelado **almacena y retrasa** el exceso, evita descartes pero **añade retardo**. Regla práctica: se vigila en la **entrada**, se modela en la **salida**. La **cola de prioridad estricta** se reserva a la **voz** y debe llevar **límite máximo**, porque de lo contrario un flujo malicioso o averiado marcado como voz puede dejar sin servicio a todo lo demás [RFC2475].

La decisión de administración más importante de todo el epígrafe es **dónde se confía en el marcado**. La respuesta es clara: el marcado que llega de un equipo de usuario **no es de fiar**, porque cualquier aplicación puede marcar sus paquetes como voz. Por eso DiffServ sitúa el acondicionamiento del tráfico en el **borde** del dominio: los conmutadores de acceso **clasifican y remarcan** —confiando, todo lo más, en el teléfono IP identificado por LLDP-MED—, y el núcleo se limita a **encolar** según lo que llega marcado, sin volver a clasificar. Este esquema, llamado **frontera de confianza**, es a la vez el más eficiente y el más seguro [RFC2475] [IEEE8021AB].

EJERCICIO RESUELTO

Diseñar el esquema de calidad de servicio de la sede. **(1) Frontera de confianza** en el puerto de acceso: se confía en el marcado del **teléfono IP** (identificado por LLDP-MED) y **no** en el del ordenador conectado tras él, cuyo tráfico se remarca a mejor esfuerzo salvo el de aplicaciones corporativas identificadas. **(2) Clases**: voz **EF (46)** en cola de prioridad limitada al 30 % del enlace; vídeo interactivo **AF41 (34)**; señalización de telefonía **CS3 (24)**, pequeña pero crítica —sin señalización no hay llamada, aunque la voz tenga prioridad—; aplicaciones de tramitación **AF21 (18)**; copias de seguridad y actualizaciones, **BE (0)** con modelado en ventana laboral. **(3) Aplicación**: marcado en el acceso, encolamiento en distribución y en el enlace hacia el centro de proceso de datos, que es **el punto de congestión real** —dentro del edificio sobra capacidad; el cuello de botella es la salida—. **(4) Verificación**: sondas sintéticas de voz que midan retardo, fluctuación y pérdida antes y después, porque una configuración de calidad de servicio que no se mide es una creencia.

4.2. Análisis de tráfico, auditoría y control de seguridad

4.2.1. Captura, inspección y análisis de paquetes de red

Cuando la monitorización dice *qué* ocurre pero no *por qué*, el instrumento definitivo es la **captura de paquetes**: obtener una copia exacta de las tramas que circulan por un punto de la red y examinarlas [WIRESHARK].

Para capturar hay que resolver primero un problema físico: en una red conmutada, **un puerto solo ve su propio tráfico**. Las tres soluciones son:

Técnica	Cómo funciona	Ventajas	Inconvenientes
Espejo de puertos (SPAN)	El conmutador copia el tráfico de uno o varios puertos, o de una VLAN, hacia un puerto de análisis	No requiere hardware adicional; se activa por configuración	Consume recursos del conmutador; **descarta** si el origen supera la capacidad del puerto destino; puede no copiar tramas con error
SPAN remoto (RSPAN / ERSPAN)	Lleva la copia a otro conmutador por una VLAN dedicada, o encapsulada sobre IP	Permite analizar desde un punto central	Consume capacidad de la red de transporte
TAP (derivación física)	Dispositivo pasivo intercalado en el enlace que duplica la señal	Fiel al 100 %, incluidas tramas con error; no consume recursos del conmutador	Hardware adicional; exige cortar el enlace para instalarlo

DATO CLAVE

SPAN = espejo de puertos configurado en el conmutador, **software**, puede descartar si se satura. **TAP** = derivación **física y pasiva**, fiel al 100 % y sin consumir recursos del conmutador. Para prueba pericial o para análisis de alta exigencia se prefiere **TAP**; para diagnóstico cotidiano basta **SPAN** [WIRESHARK] [SWITCH-VENDORS].

Al capturar hay que distinguir dos tipos de filtro que se confunden sistemáticamente: el **filtro de captura**, que se aplica **antes** de guardar y determina qué entra en el fichero —usa la sintaxis BPF, del estilo `host 10.20.30.40 and port 53` —, y el **filtro de visualización**, que se aplica **después** sobre lo ya capturado y solo cambia lo que se muestra. El primero reduce el tamaño y es irreversible; el segundo es reversible pero exige haber capturado todo.

El **método de análisis** es tan importante como la herramienta. Un procedimiento eficaz sigue siempre el mismo orden: **capturar en el punto correcto** —lo más cerca posible del síntoma, y a ser posible en ambos extremos a la vez—; **acotar en el tiempo**, reproduciendo el fallo mientras se captura y anotando la hora exacta; **partir de lo general a lo particular**, mirando primero los resúmenes de conversaciones y de protocolos antes que los paquetes uno a uno; y **buscar patrones conocidos**: retransmisiones TCP (pérdida), restablecimientos de conexión (rechazo del extremo), tiempos de espera agotados (no llega respuesta), consultas DNS sin respuesta, tramas de negociación TLS fallidas, o el tiempo transcurrido entre la petición y la respuesta, que responde a la pregunta más frecuente de todas: **¿quién tarda, el cliente, la red o el servidor?**

La captura tiene, sin embargo, dos límites serios que un administrador debe tener presentes:

- **Volumen**: capturar todo el tráfico de una sede genera terabytes en poco tiempo. La captura es un instrumento **puntual y dirigido**, no un régimen permanente; para lo permanente están los flujos (§4.2.2).
- **Contenido y protección de datos**: una captura completa contiene **el contenido** de las comunicaciones, incluidos datos personales de ciudadanos y comunicaciones de empleados. No es una herramienta neutra: requiere **finalidad determinada**, **autorización**, **minimización** —capturar solo el tráfico necesario, y cuando sea posible solo las cabeceras—, **custodia restringida** y **borrado** cuando deja de ser necesaria [RGPD] [LOPDGDD]. Además, la mayor parte del tráfico moderno viaja **cifrado**, de modo que lo que se obtiene son metadatos: quién, con quién, cuándo y cuánto.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> Ante una queja de que «la aplicación de expedientes va lenta desde la Oficina de Atención a la Ciudadanía», una captura simultánea en el puesto y en el servidor permite responder la única pregunta que importa: si entre la petición del cliente y la respuesta del servidor transcurren 8 milisegundos, la red está bien y el problema es la aplicación; si transcurren 900 milisegundos con retransmisiones, el problema está en el camino. Es la diferencia entre una reunión con datos y una discusión de tres semanas entre el equipo de red y el de aplicaciones. Eso sí: la captura debe acotarse al tráfico de esa aplicación —filtro de captura por dirección y puerto—, porque capturar todo el tráfico del puesto significaría recoger el correo y la navegación de la trabajadora, y eso no es proporcionado.

4.2.2. Monitorización basada en flujos de tráfico de red

Un **flujo** es un conjunto de paquetes que comparten una misma clave, tradicionalmente la **quíntupla**: dirección IP de origen, puerto de origen, dirección IP de destino, puerto de destino y protocolo. En lugar de guardar los paquetes, el dispositivo mantiene una tabla de flujos con contadores —paquetes, bytes, marcas de tiempo de inicio y fin, interfaces de entrada y salida, marcado DSCP— y, cuando el flujo termina o vence un temporizador, **exporta un registro** hacia un colector.

Las tres tecnologías que hay que distinguir son:

Tecnología	Origen	Norma	Cómo trabaja
NetFlow v9	Cisco	**RFC 3954** (informativo)	Registros con **plantillas** que definen los campos; exporta el flujo **completo**
IPFIX	IETF	**RFC 7011–7015** (norma)	**Normalización abierta** de NetFlow v9; extensible con elementos propios
sFlow	InMon / consorcio	**RFC 3176**	**Muestreo**: exporta 1 de cada N paquetes más contadores de interfaz; implementado en el circuito integrado

DATO CLAVE

NetFlow v9 (RFC 3954) es de origen Cisco; IPFIX (RFC 7011) es su versión normalizada por el IETF, y por eso se dice que IPFIX es «NetFlow v10». **sFlow (RFC 3176) funciona por muestreo estadístico**, no por seguimiento de flujos completos: es más barato de implementar y menos exacto en tráfico de bajo volumen, pero muy fiable para tendencias. Puertos de recolección convencionales: **UDP 2055** para NetFlow e IPFIX, **UDP 6343** para sFlow [RFC3954] [RFC7011] [SFLOW].

La diferencia entre flujo y paquete es el eje conceptual de este epígrafe:

Aspecto	Captura de paquetes	Registros de flujo
Qué obtiene	**Contenido completo**	**Metadatos**: quién, con quién, cuánto, cuándo, por dónde
Volumen generado	Enorme (terabytes)	Muy reducido (una fracción del 1 %)
Cobertura	Un punto concreto	**Toda la red**, de forma continua
Uso natural	Diagnóstico puntual y profundo	**Vigilancia continua**, tendencias, investigación retrospectiva
Protección de datos	Muy sensible: contiene comunicaciones	Sensible, pero **sin contenido**; más fácil de justificar

Los usos administrativos de los flujos son de alto valor y conviene conocerlos enumerados: **saber quién consume** un enlace saturado y con qué destino; **planificar capacidad** con datos históricos en lugar de intuiciones; **detectar anomalías** como barridos de puertos, comunicaciones hacia destinos inusuales o exfiltración de volúmenes atípicos fuera de horario; **investigar**

retrospectivamente un incidente —con flujos guardados se puede responder «¿con quién habló este equipo la semana pasada?», algo imposible con capturas puntuales—; y **verificar la segmentación**, comprobando si existe tráfico entre segmentos que la política prohíbe, que es una de las comprobaciones más reveladoras que puede hacerse en una red madura. Todas ellas se realizan sobre un **colector** que almacena y consulta los registros exportados [FLOW-TOOLS].

EJERCICIO RESUELTO

El enlace de una sede hacia el centro de proceso de datos se satura todas las mañanas entre las 8:30 y las 9:15. Con SNMP se sabe **cuánto** —la interfaz alcanza el 100 %—, pero no **quién**. Los **flujos** de esa franja, ordenados por volumen, muestran que el 70 % del tráfico son conexiones desde 150 direcciones de la VLAN de datos hacia un mismo destino externo por el puerto 443. El perfilado del destino lo identifica como el servicio de actualizaciones del sistema operativo: los equipos, al encenderse todos a la misma hora, descargan parches simultáneamente. **Soluciones posibles**, de menor a mayor coste: desplazar la ventana de actualización a horario nocturno mediante directiva; desplegar un **servidor de actualizaciones local** o una caché en la sede, de modo que la descarga se haga una vez; limitar el caudal de esa clase de tráfico mediante calidad de servicio; y solo en último término, ampliar el enlace. La lección: **la ampliación de capacidad es la solución más cara y con frecuencia la menos necesaria**; sin datos de flujo, habría sido la primera propuesta.

4.2.3. Auditoría, registro de eventos y gestión de logs

Un **registro de eventos** (*log*) es la anotación, con marca de tiempo, de algo que ha sucedido en un sistema. Su valor es triple: **operativo** (diagnosticar averías), **de seguridad** (detectar e investigar incidentes) y **jurídico-administrativo** (acreditar quién hizo qué, que es la dimensión de **trazabilidad** del ENS).

El protocolo normalizado es **syslog** (**RFC 5424**), que estructura cada mensaje con una **prioridad** compuesta por dos elementos: el **recurso** (*facility*), que indica el subsistema de origen, y la **severidad** (*severity*), en una escala de **0 a 7**:

Valor	Severidad	Significado
0	*Emergency*	El sistema es inutilizable
1	*Alert*	Requiere acción inmediata
2	*Critical*	Condición crítica
3	*Error*	Error
4	*Warning*	Advertencia
5	*Notice*	Normal pero significativo
6	*Informational*	Informativo
7	*Debug*	Depuración

DATO CLAVE

Syslog (RFC 5424): severidad de **0 (*emergency*) a 7 (*debug*)** — a **menor número, mayor gravedad**, que es lo contrario de lo que sugiere la intuición. Transporte clásico **UDP 514** (sin garantía de entrega ni cifrado) y **TCP 6514 sobre TLS** cuando se exigen integridad y confidencialidad. Un dispositivo configurado en severidad 7 hacia un servidor central puede **inundarlo**: el nivel debe elegirse [RFC5424].

La **gestión de registros** en una organización se estructura en cinco decisiones:

1. **Centralización**. Los registros deben enviarse a un servidor **externo al dispositivo que los genera**. La razón es doble: un equipo que se apaga o se sustituye pierde sus registros locales, y —más importante— quien compromete un equipo **puede borrar los registros que lo delatan**. Enviarlos fuera en el momento de producirse rompe esa posibilidad. Es lo que exige la medida `op.exp.8` **(registro de la actividad)** del ENS [ENS].
2. **Sincronización horaria**. Sin **NTP** (**RFC 5905**) en todos los dispositivos, los registros de distintos equipos no son comparables y la correlación de un incidente es imposible: un desfase de minutos basta para invertir el orden aparente de los hechos. La sincronización es un **prerrequisito**, no una mejora [RFC5905].
3. **Normalización y correlación**. Un **SIEM** recoge registros de orígenes heterogéneos, los normaliza a un formato común y aplica reglas de correlación que detectan lo que ningún registro dice por separado: por ejemplo, un mismo usuario autenticándose desde dos sedes distantes en pocos minutos, o cien autenticaciones fallidas seguidas de una correcta [SIEM].

4. **Conservación e integridad**. El plazo debe fijarlo la política de la organización, ponderando la necesidad de investigación retrospectiva y la **limitación del plazo de conservación** que impone la normativa de protección de datos. La integridad se protege con almacenamiento de solo anexado, firma o sellado, y acceso restringido: un registro que el administrador puede modificar no acredita nada.
5. **Revisión**. Un registro que nadie mira nunca solo sirve después de un incidente. La monitorización de seguridad —la medida `op.mon.1` **(detección de intrusión)** y la nueva `op.mon.3` **(vigilancia)** del ENS— exige revisión activa, con alertas definidas [ENS].

Los **eventos que deben registrarse** en el ámbito de este tema son, como mínimo: autenticaciones correctas y fallidas contra el directorio y contra los dispositivos de red; cambios de configuración de la electrónica, con autor y contenido; cambios en cuentas, grupos y pertenencias; concesiones DHCP (con opción 82); autenticaciones y rechazos del control de admisión, con puerto y VLAN asignada; cambios de estado de enlaces e interfaces; y activaciones de las protecciones de borde, como un puerto deshabilitado por guarda de BPDU.

> DATO CLAVE
>
> Sin **NTP** no hay auditoría posible: la correlación de registros de varios sistemas exige **una misma referencia temporal**. NTP (RFC 5905) usa **UDP 123** y organiza las fuentes en **estratos** (estrato 0 = reloj de referencia; estrato 1 = servidor conectado a él directamente). Es, junto con el DNS, la infraestructura invisible de la que depende todo lo demás [RFC5905].

La dimensión jurídica es ineludible. Los registros de red que permiten atribuir una actividad a una persona identificada o identificable son **datos personales**, y su tratamiento exige [RGPD] [LOPDGDD]:

- **Base jurídica y finalidad determinada**: la seguridad del sistema y el cumplimiento del ENS la sostienen; la curiosidad o el control laboral encubierto, no.
- **Minimización**: registrar lo necesario para esa finalidad, y no más.
- **Limitación del plazo de conservación**, definido y aplicado de verdad.
- **Información previa a la plantilla y a la representación de los trabajadores** sobre qué se registra y con qué fin, requisito reforzado por los arts. **87-90 de la LOPDGDD** en materia de intimidad frente al uso de dispositivos digitales, videovigilancia y geolocalización.
- **Inclusión en el registro de actividades de tratamiento** del art. 30 del RGPD.
- **Acceso restringido y trazado**: quién consulta los registros también debe quedar registrado.

RELACIÓN CON OTROS TEMAS

El **procedimiento administrativo** y el régimen de la actividad administrativa se estudian en los **Temas 6 y 7**; el **régimen disciplinario del empleado público** —relevante cuando un registro de red revela un uso indebido—, en el **Tema 5**. Aquí se trata únicamente la obligación técnica de registrar y sus límites en protección de datos.

4.2.4. Cumplimiento del Esquema Nacional de Seguridad en la administración LAN

El **Esquema Nacional de Seguridad**, regulado por el **Real Decreto 311/2022**, es de aplicación obligatoria a las entidades del sector público y a los proveedores que les prestan servicios [ENS]. Su fundamento legal está en el **artículo 156 de la Ley 40/2015**, que remite también al **Esquema Nacional de Interoperabilidad** como su norma gemela en materia de interoperabilidad [L40-2015] [ENI]. Este epígrafe no repite el Tema 39: se limita a traducir el ENS a **lo que hace con sus manos** un administrador de red local.

El marco parte de **cinco dimensiones de seguridad** —**disponibilidad, autenticidad, integridad, confidencialidad y trazabilidad**—, cada una valorada en un **nivel** bajo, medio o alto; el nivel más alto de entre las dimensiones determina la **categoría del sistema**: **BÁSICA, MEDIA o ALTA**. De la categoría depende el conjunto de medidas exigibles del **Anexo II**, organizado en tres bloques: **marco organizativo (org)**, **marco operacional (op)** y **medidas de protección (mp)**.

DATO CLAVE

ENS = RD 311/2022. Cinco dimensiones: **disponibilidad, autenticidad, integridad, confidencialidad y trazabilidad**. Tres niveles por dimensión: **bajo, medio y alto**. Tres categorías de sistema: **BÁSICA, MEDIA y ALTA**, determinadas por el nivel más alto alcanzado en cualquier dimensión. Tres bloques de medidas en el Anexo II: **marco organizativo (org)**, **marco operacional (op)** y **medidas de protección (mp)**. Los sistemas de categoría **media y alta** requieren **auditoría al menos bienal**; los de categoría **básica**, **autoevaluación** [ENS].

Las medidas que afectan directamente a la administración de una red de área local son estas, y conviene asociarlas al epígrafe del tema donde se han trabajado:

Medida	Título	Dónde se aplica en este tema
`mp.com.1`	Perímetro seguro	Cortafuegos y filtrado entre segmentos; frontera de la sede (§1.1.1)
`mp.com.2`	Protección de la confidencialidad	Cifrado del tráfico: TLS, MACsec, redes inalámbricas (§3.1.3)
`mp.com.3`	Protección de la integridad y de la autenticidad	Autenticación de los extremos, protección frente a suplantación (§1.2.1, §3.2.3)
`mp.com.4`	**Separación de flujos de información en la red**	**VLAN, segmentación y red de gestión separada (§1.1, §3.1.2)**
`mp.eq.4`	Otros dispositivos conectados a la red	Impresoras, cámaras, sensores y equipamiento no informático (§3.2.1)
`op.acc.1–6`	Control de acceso: identificación, requisitos, segregación de funciones, gestión de derechos y mecanismos de autenticación	Gestión de usuarios y del directorio (§2)
`op.exp.1`	Inventario de activos	Inventario de red y de puesto (§3.1.1, §3.2.1)
`op.exp.2` y `op.exp.3`	Configuración de seguridad y gestión de la configuración de seguridad	Líneas base, plantillas y control de versiones de configuración (§2.2.3, §3.1.1)
`op.exp.4`	Mantenimiento y actualizaciones de seguridad	Gestión de parches y firmware (§3.2.2)
`op.exp.8`	Registro de la actividad	Centralización de registros (§4.2.3)
`op.mon.1`	Detección de intrusión	Sondas, análisis de tráfico y de flujos (§4.2.1, §4.2.2)
`op.mon.2`	Sistema de métricas	Monitorización y cuadros de mando (§4.1)

Medida	Título	Dónde se aplica en este tema
`op.mon.3`	**Vigilancia**	Revisión activa y continua, novedad reforzada en el ENS de 2022 (§4.2.3)

DATO CLAVE

El grupo `op.mon` del ENS — `op.mon.1` **detección de intrusión,** `op.mon.2` **sistema de métricas y** `op.mon.3` **vigilancia**— es la traducción normativa exacta de esta sección del tema: el ENS **obliga** a monitorizar, no lo recomienda. La medida `op.mon.3` (vigilancia) se refuerza notablemente en el RD 311/2022 respecto de la regulación anterior. Y la medida `mp.com.4` se denomina **«separación de flujos de información en la red»**: es el respaldo normativo directo de la segmentación en VLAN [ENS].

Junto a las medidas concretas, el ENS impone **principios básicos** que se traducen en criterios de diseño de red muy reconocibles: **seguridad integral** (la seguridad no es un producto que se añade al final), **gestión de riesgos** (las medidas se justifican por el riesgo, no por la moda), **prevención, detección, respuesta y conservación**, **líneas de defensa** —la traducción literal de la defensa en profundidad: segmentación, control de admisión, cifrado, registro y vigilancia actuando en capas, de modo que el fallo de una no comprometa el conjunto—, **vigilancia continua y reevaluación periódica**, y **diferenciación de responsabilidades** [ENS].

Las guías **CCN-STIC** de la serie 800 concretan todo lo anterior: la **803** para la valoración de los sistemas, la **804** para la implantación de las medidas y la **817** para la gestión de ciberincidentes, con su taxonomía y sus criterios de notificación al CCN-CERT [CCN-STIC].

EJEMPLO DE APLICACIÓN EN EL AYTO

Aplicado a la sede del caso de referencia, el cumplimiento del ENS en la administración de su red se materializa en decisiones concretas y comprobables: la segmentación en VLAN documentada y justificada (`mp.com.4`); la red de gestión separada y accesible solo desde puestos de administración (`mp.com.4` , `op.acc.2`); las cámaras y las impresoras confinadas y con su firmware bajo seguimiento (`mp.eq.4` , `op.exp.4`); el inventario conciliado de todo lo que hay conectado (`op.exp.1`); las cuentas de administración nominativas, separadas de las de trabajo y con segundo factor (`op.acc.3` , `op.acc.6`); los registros de la electrónica y del control de admisión enviados a un servidor central con NTP común (`op.exp.8`); y los cuadros de mando y las alertas efectivamente revisados (`op.mon.2` , `op.mon.3`). El conjunto es exactamente el contenido de este tema, leído desde la norma en lugar de desde la tecnología [ENS].

RELACIÓN CON OTROS TEMAS

El desarrollo íntegro de los **principios básicos del ENS y del ENI** corresponde al **Tema 39**. La **seguridad perimetral, el acceso remoto seguro y las VPN**, al **Tema 36**. Los **conceptos generales de seguridad, amenazas, vulnerabilidades, criptografía y firma digital**, al **Tema 32**. La **gestión de la resolución de incidencias** y el CAU, al **Tema 29**. Este epígrafe se limita a las medidas que ejecuta el administrador de la red local.

Cierre: las cuatro preguntas del tema

El enunciado oficial reúne cuatro materias que, leídas juntas, responden a cuatro preguntas encadenadas sobre una misma red:

1. **¿Cómo está construida y ordenada?** Jerarquía de acceso, distribución y núcleo; segmentación en VLAN con troncales; redundancia sin bucles mediante árbol de expansión y agregación de enlaces; y los dos servicios que la hacen utilizable, DHCP y DNS (§1).
2. **¿Quién entra en ella y con qué permisos?** Un directorio que centraliza identidades, con su estructura lógica y física; autenticación mediante Kerberos, LDAP y RADIUS; configuración impuesta por directivas; y autorización gobernada por roles y por el principio de mínimo privilegio (§2).
3. **¿De qué está hecha y cómo se mantiene?** Inventario, normalización, control de versiones de configuración y automatización de la electrónica; ciclo de vida del puesto y de todo lo demás que se conecta; parches y firmware; y control de admisión que decide qué dispositivo entra y adónde (§3).
4. **¿Qué circula por ella y cómo se gobierna?** Monitorización con SNMP y syslog; métricas de disponibilidad, utilización, errores y calidad; calidad de servicio con clasificación, marcado y encolamiento; análisis por paquetes y por flujos; y registro, auditoría y cumplimiento del ENS (§4).

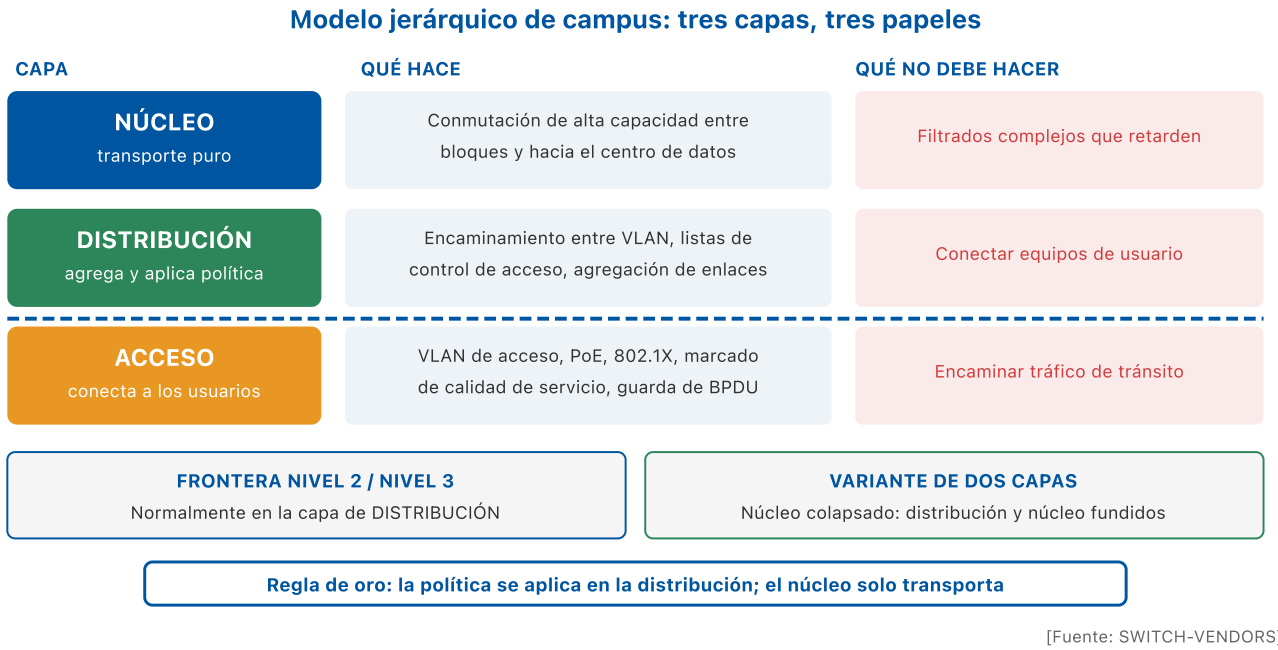
Una regla transversal recorre las cuatro y resume el tema mejor que cualquier lista: **lo que no está inventariado no se puede proteger, lo que no está segmentado no se puede contener, lo que no está registrado no se puede demostrar, y lo que no se mide no se puede mejorar.**

Índice de diagramas

ID	Título	Sección	Tipo
D1	El modelo jerárquico de tres capas y sus responsabilidades	§1.1.1	Capas
D2	Dominios de colisión y de difusión: qué reduce cada cosa	§1.1.1	Comparativa
D3	La etiqueta 802.1Q, campo a campo	§1.1.2	Estructura de trama
D4	Puerto de acceso frente a puerto troncal	§1.1.2	Esquema de red
D5	Redundancia sin bucles: STP, RSTP, MSTP y agregación	§1.1.3	Comparativa
D6	DHCP: el ciclo DORA y el agente de retransmisión	§1.2.1	Flujo
D7	DNS: jerarquía, resolución y tipos de registro	§1.2.2	Árbol y flujo
D8	Directorio: estructura lógica frente a estructura física	§2.1.1	Comparativa
D9	AGDLP y el orden de aplicación de directivas L-S-D-UO	§2.1.3, §2.2.2	Flujo doble
D10	Control de admisión 802.1X: los tres papeles	§3.2.3	Flujo
D11	Mapa de protocolos y puertos de administración y monitorización	§3.1.3, §4.1.1	Tabla visual
D12	Gestión dentro de banda frente a gestión fuera de banda	§3.1.2	Comparativa
D13	Marcado de calidad de servicio: PCP, DSCP y clases	§4.1.4	Tabla visual
D14	Paquetes frente a flujos: qué instrumento para qué pregunta	§4.2.1, §4.2.2	Comparativa
D15	El ENS aplicado a la red de área local	§4.2.4	Mapa de medidas

D1 · El modelo jerárquico de tres capas y sus responsabilidades

Sección: §1.1.1 — Modelos de diseño jerárquico y segmentación de red **Propósito**: Fijar qué hace y qué no debe hacer cada capa, y dónde se sitúa la frontera entre el nivel 2 y el nivel 3.



[Fuente: SWITCH-VENDORS]

D2 · Dominios de colisión y de difusión: qué reduce cada cosa

Sección: §1.1.1 — Modelos de diseño jerárquico y segmentación de red **Propósito**: Deshacer la confusión más repetida del temario: qué delimita un dominio de colisión, qué delimita uno de difusión y qué efecto tiene realmente segmentar en VLAN.

Dominio de colisión frente a dominio de difusión

	DOMINIO DE COLISIÓN	DOMINIO DE DIFUSIÓN
¿QUÉ LO DELIMITA?	Cada PUERTO de conmutador	Cada VLAN, o cada interfaz de encaminador
¿QUÉ TRÁFICO LO SATURA?	Transmisiones simultáneas en el medio	ARP, DHCP Discover, anuncios de servicios
¿CÓMO SE REDUJO O SE REDUCE?	Con la CONMUTACIÓN: en la práctica ya está eliminado en redes modernas	SEGMENTANDO en VLAN: es lo único que reduce el dominio de difusión

Error clásico: «segmentar en VLAN reduce las colisiones». NO: reduce la DIFUSIÓN

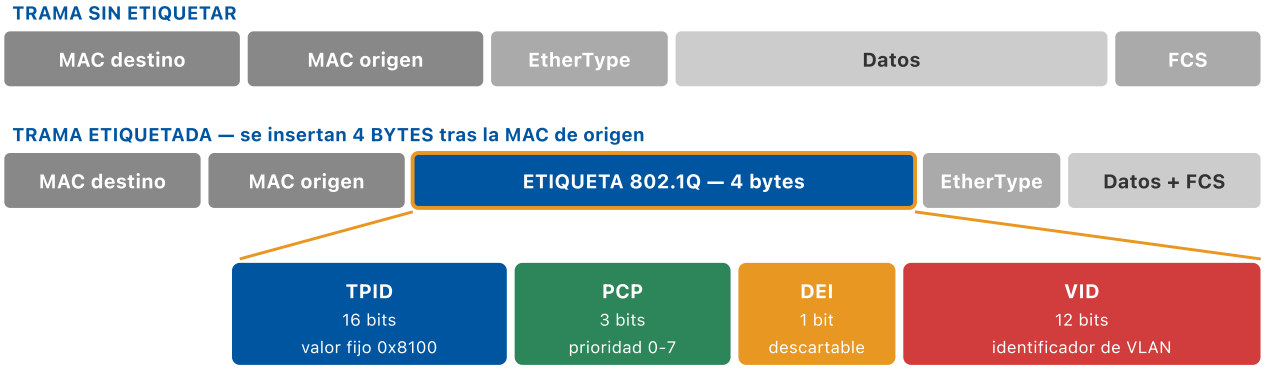
Dos VLAN nunca se comunican en nivel 2: hace falta encaminar (nivel 3)

[Fuente: IEEE8023; IEEE8021Q]

D3 · La etiqueta 802.1Q, campo a campo

Sección: §1.1.2 — Redes de área local virtuales (VLAN) y enlace de troncales **Propósito**: Memorizar la estructura exacta de la etiqueta VLAN, sus tamaños de campo y el porqué de las 4094 VLAN utilizables. Diagrama de memorización directa.

La etiqueta 802.1Q dentro de la trama Ethernet



12 bits = 4096 valores
0 y 4095 reservados → 1-4094 utilizables

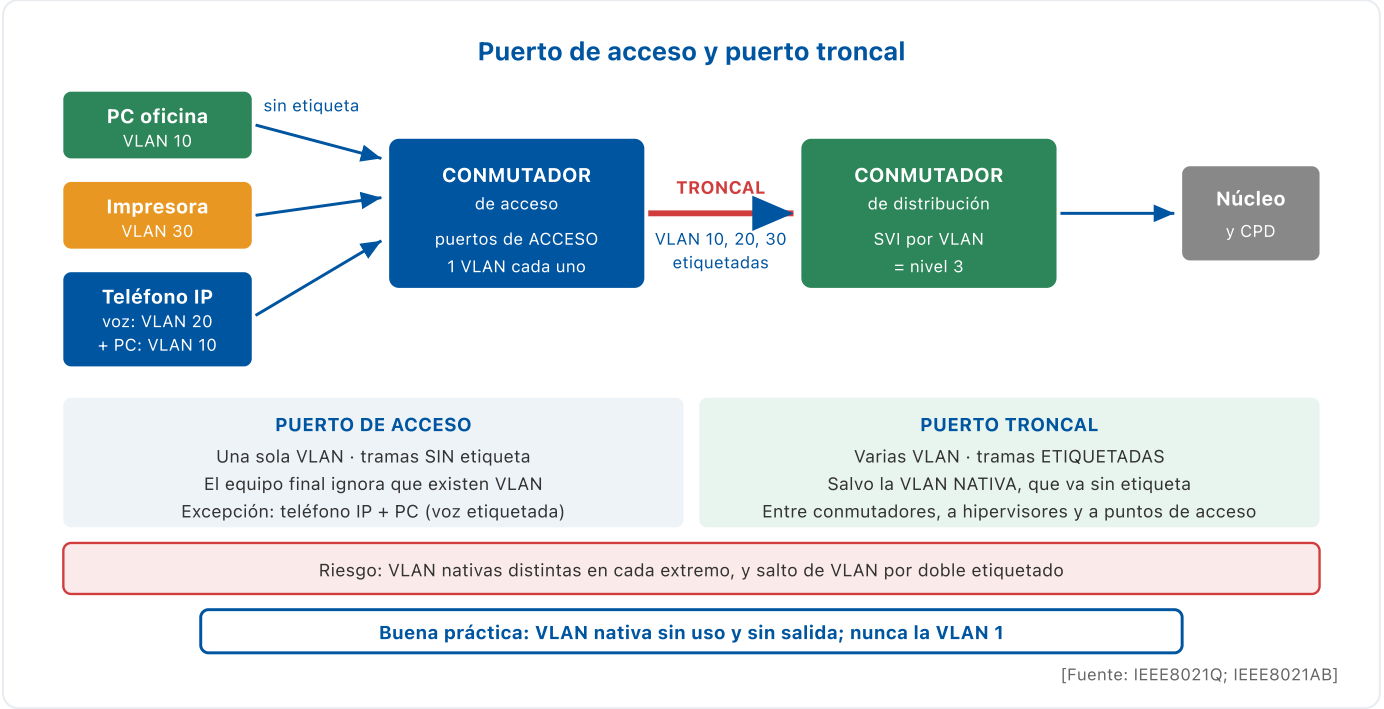
La VLAN 1 es la predeterminada
No usarla ni para datos, ni gestión, ni nativa

La trama etiquetada mide 4 bytes más: los troncales deben admitirlo

[Fuente: IEEE8021Q]

D4 · Puerto de acceso frente a puerto troncal

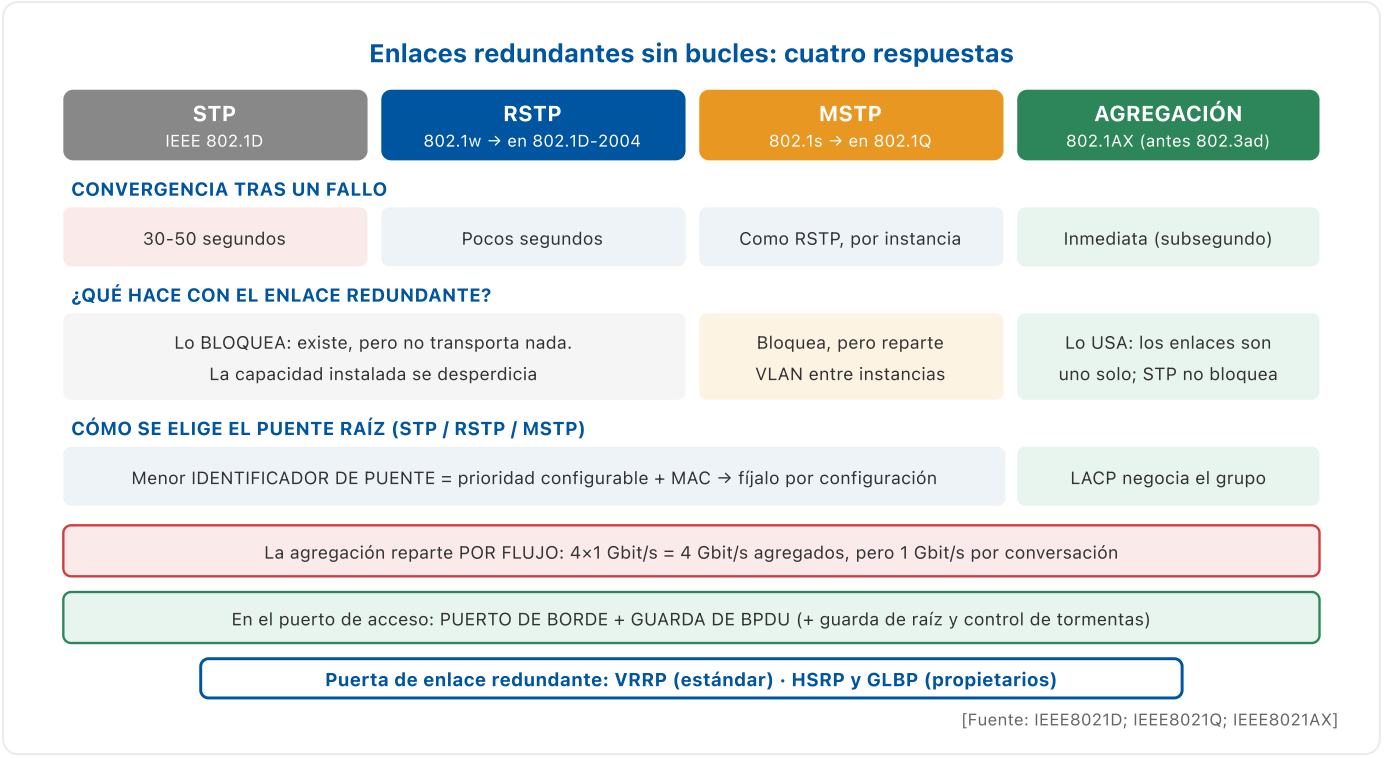
Sección: §1.1.2 — Redes de área local virtuales (VLAN) y enlace de troncales **Propósito**: Distinguir los dos modos de puerto, situar la VLAN nativa y mostrar el caso especial del teléfono IP con ordenador conectado detrás.



[Fuente: IEEE8021Q; IEEE8021AB]

D5 · Redundancia sin bucles: STP, RSTP, MSTP y agregación

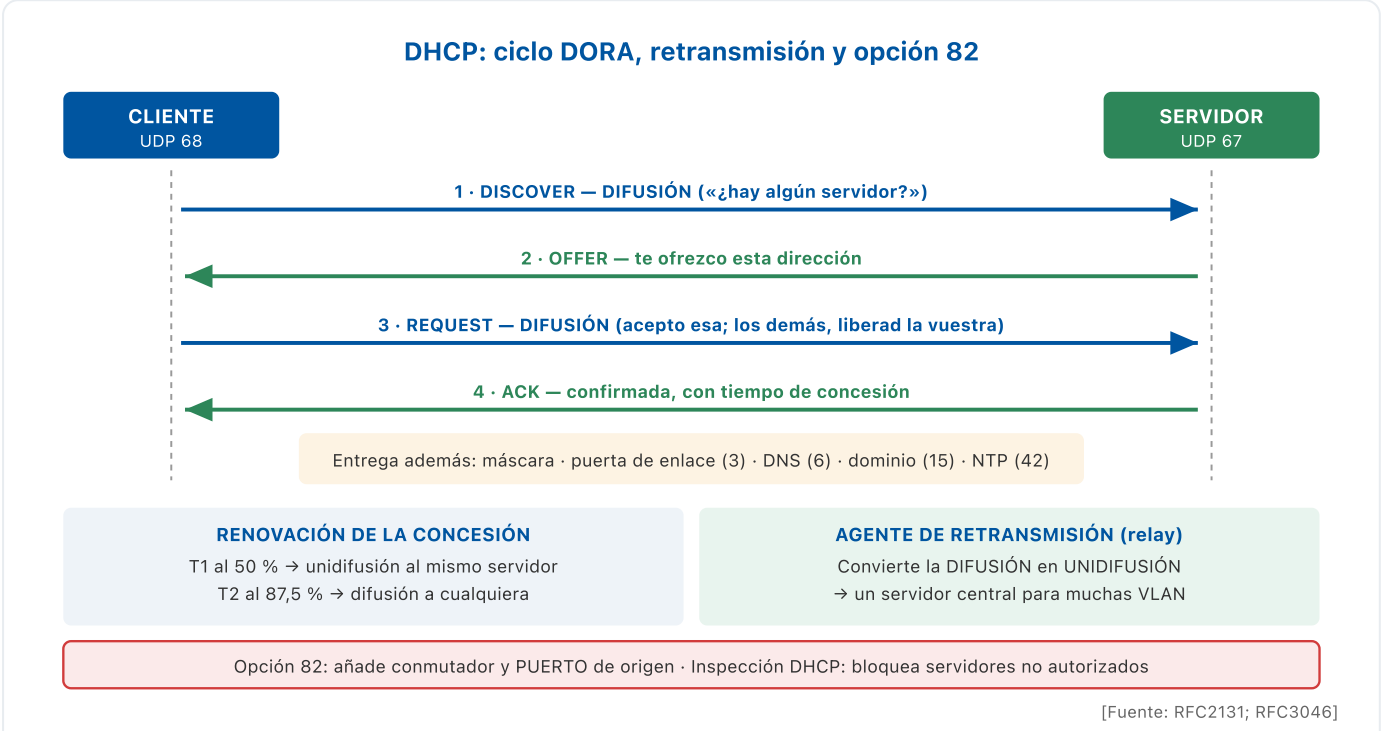
Sección: §1.1.3 — Protocolos de conmutación y redundancia en el nivel de enlace **Propósito**: Ordenar las tres generaciones del árbol de expansión con su norma y su tiempo de convergencia, y contrastarlas con la agregación de enlaces, que resuelve el mismo problema sin bloquear.



[Fuente: IEEE8021D; IEEE8021Q; IEEE8021AX]

D6 · DHCP: el ciclo DORA y el agente de retransmisión

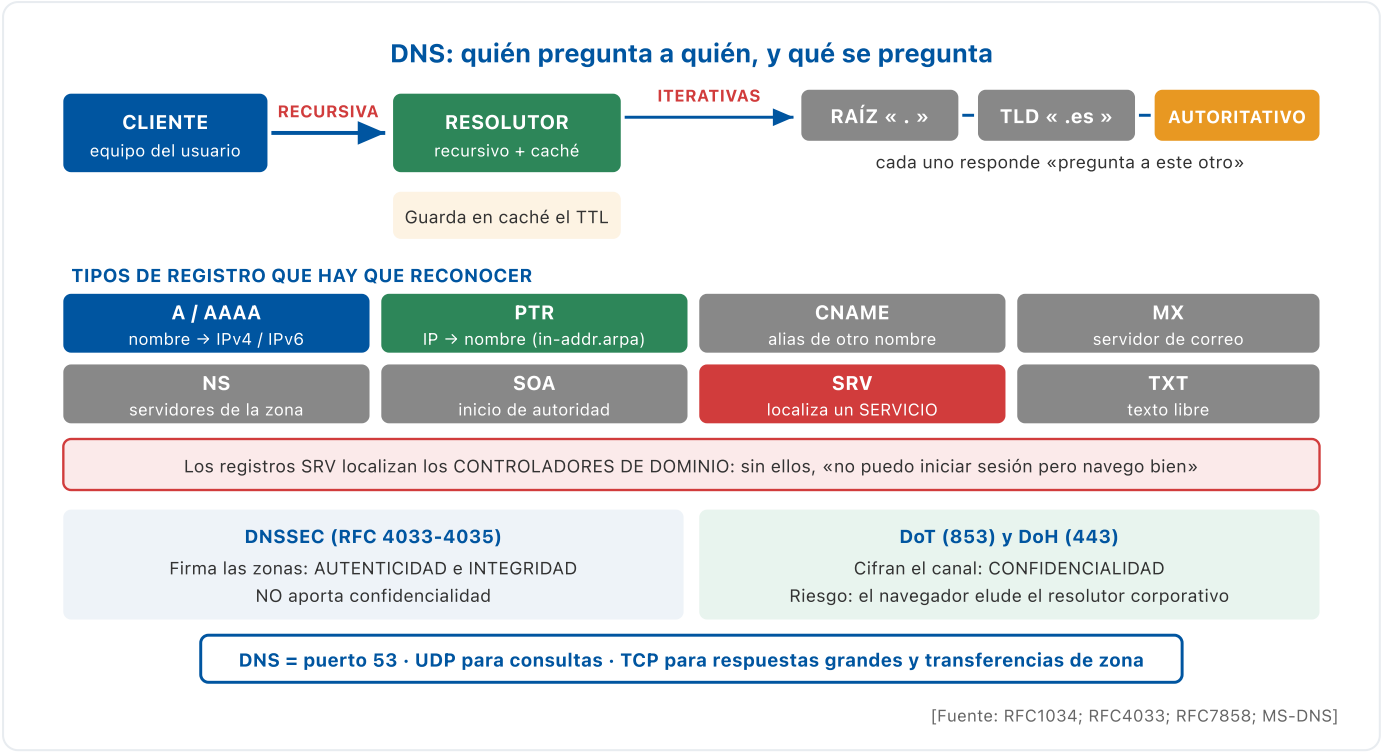
Sección: §1.2.1 — Configuración y gestión dinámica de direccionamiento (DHCP) **Propósito**: Fijar los cuatro mensajes, sus puertos y quién difunde, y explicar por qué un servidor central puede atender muchas VLAN gracias al agente de retransmisión.



[Fuente: RFC2131; RFC3046]

D7 · DNS: jerarquía, resolución y tipos de registro

Sección: §1.2.2 — Servicio de resolución de nombres de dominio (DNS) **Propósito**: Mostrar a la vez la jerarquía del espacio de nombres, la diferencia entre consulta recursiva e iterativa y la tabla de registros que hay que reconocer.



[Fuente: RFC1034; RFC4033; RFC7858; MS-DNS]

D8 · Directorio: estructura lógica frente a estructura física

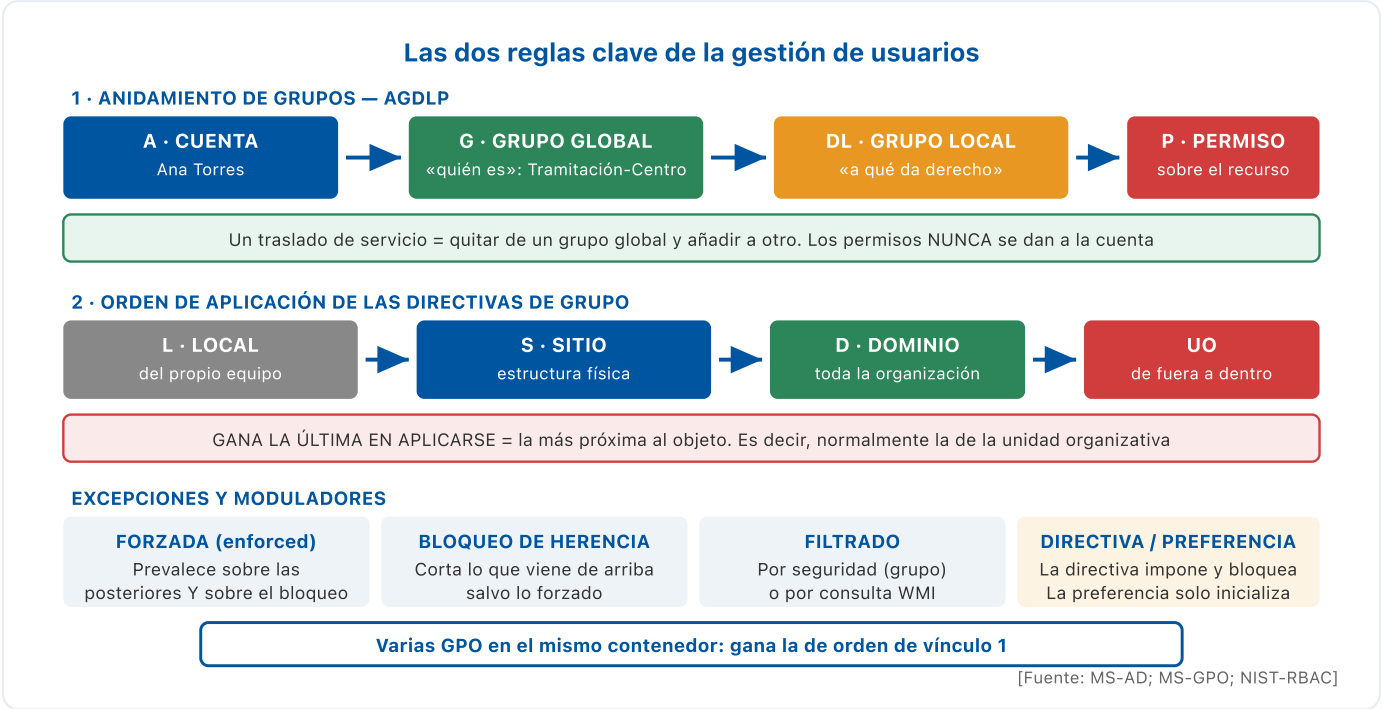
Sección: §2.1.1 — Estructura lógica y física de servicios de directorio **Propósito**: Separar las dos estructuras superpuestas del directorio y fijar qué delimita cada pieza.



[Fuente: MS-AD; RFC4511; RFC4120]

D9 · AGDLP y el orden de aplicación de directivas L-S-D-UO

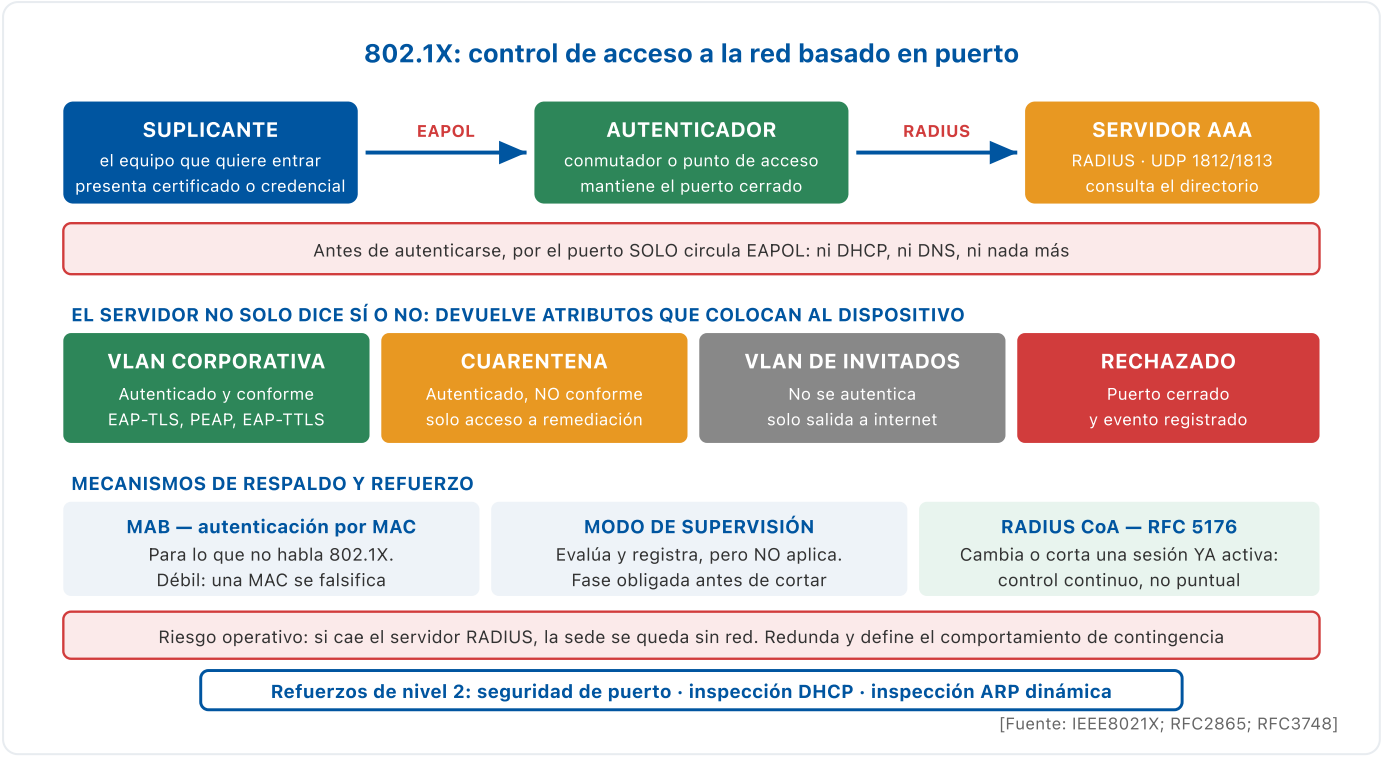
Sección: §2.1.3 y §2.2.2 — Objetos y grupos · Directivas de grupo **Propósito**: Reunir en un solo diagrama las dos reglas clave de la gestión de usuarios: cómo se encadenan los grupos para conceder permisos y en qué orden ganan las directivas.



[Fuente: MS-AD; MS-GPO; NIST-RBAC]

D10 · Control de admisión 802.1X: los tres papeles

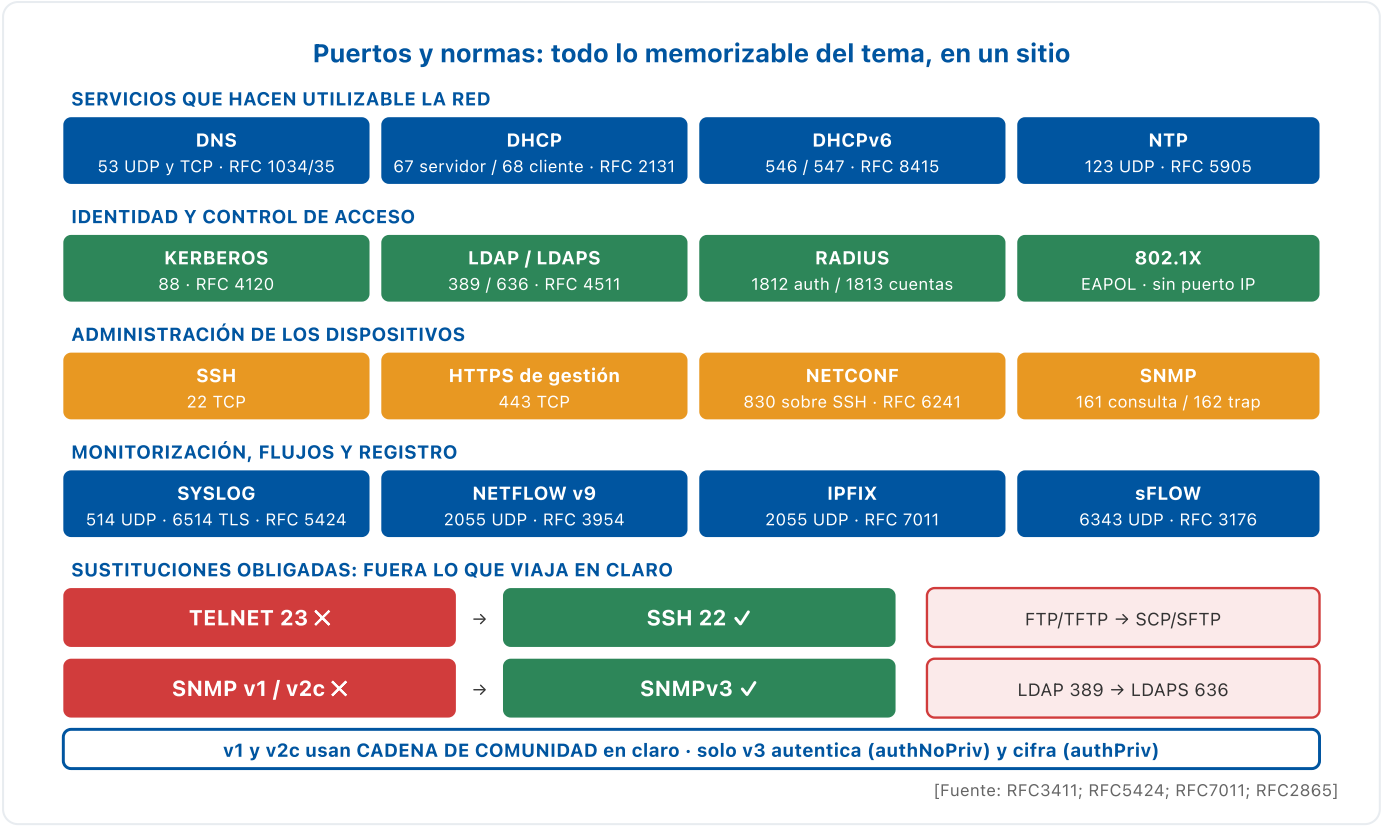
Sección: §3.2.3 — Control de admisión a la red y autenticación de dispositivos **Propósito**: Fijar el triángulo suplicante-autenticador-servidor, qué circula antes de autenticarse y qué destinos posibles tiene un dispositivo según el resultado.



[Fuente: IEEE8021X; RFC2865; RFC3748]

D11 · Mapa de protocolos y puertos de administración y monitorización

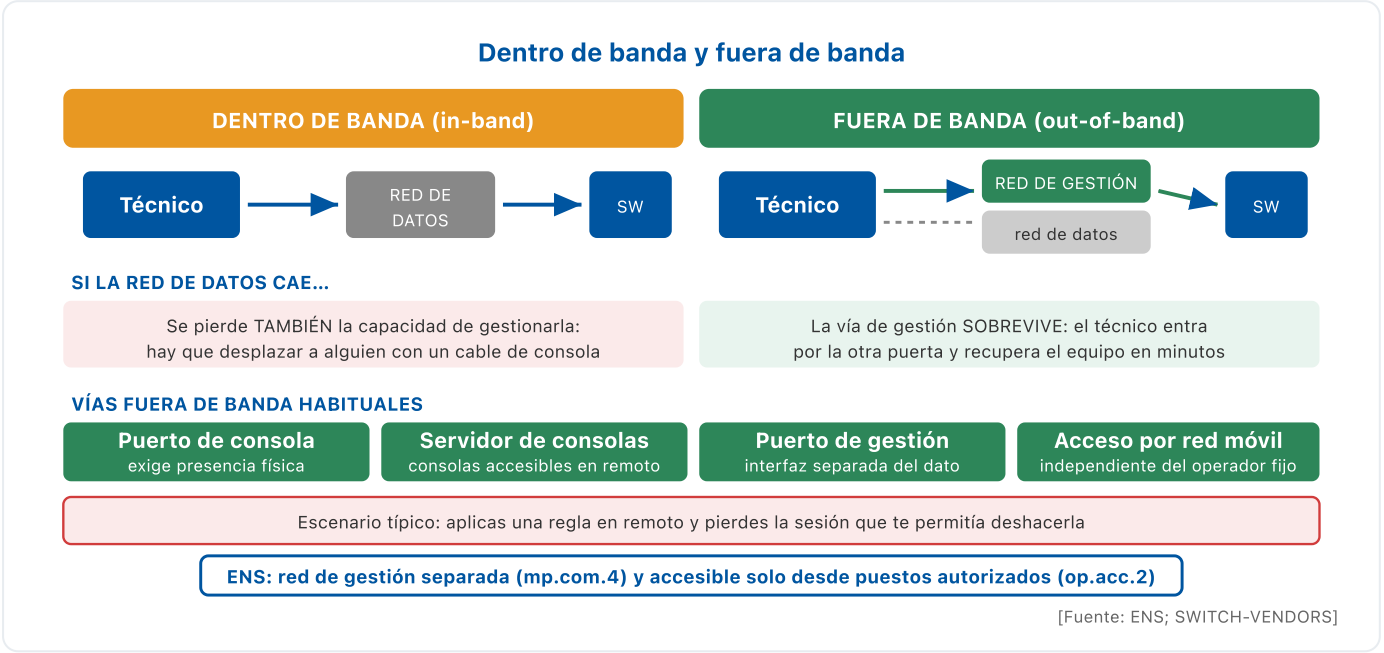
Sección: §3.1.3 y §4.1.1 — Protocolos de administración segura · Instrumentos de monitorización **Propósito**: Reunir en una sola tabla visual todos los puertos y números de norma memorizables del tema. Diagrama de memorización directa.



[Fuente: RFC3411; RFC5424; RFC7011; RFC2865]

D12 · Gestión dentro de banda frente a gestión fuera de banda

Sección: §3.1.2 — Interfaces de gestión en banda y fuera de banda **Propósito**: Fijar la distinción y su consecuencia práctica: la vía por la que se administra no debe depender de aquello que se administra.



[Fuente: ENS; SWITCH-VENDORS]

D13 · Marcado de calidad de servicio: PCP, DSCP y clases

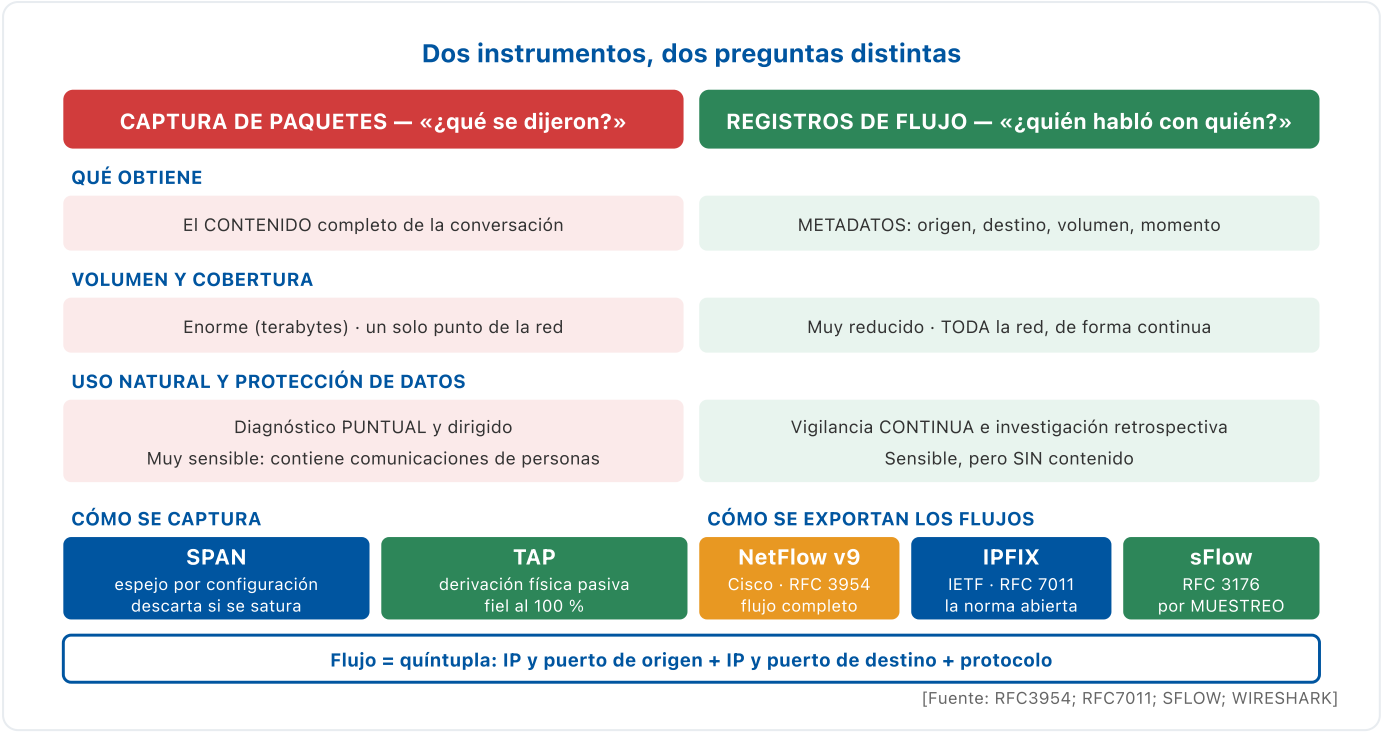
Sección: §4.1.4 — Mecanismos de clasificación, marcado y priorización de tráfico **Propósito**: Distinguir el marcado de nivel 2 del de nivel 3, memorizar los valores de DSCP y ordenar las cinco operaciones de la calidad de servicio. Diagrama de memorización directa.



[Fuente: RFC2474; RFC2597; RFC4594]

D14 · Paquetes frente a flujos: qué instrumento para qué pregunta

Sección: §4.2.1 y §4.2.2 — Captura de paquetes · Monitorización por flujos **Propósito**: Elegir el instrumento correcto según la pregunta, y distinguir SPAN de TAP y NetFlow de IPFIX y de sFlow.

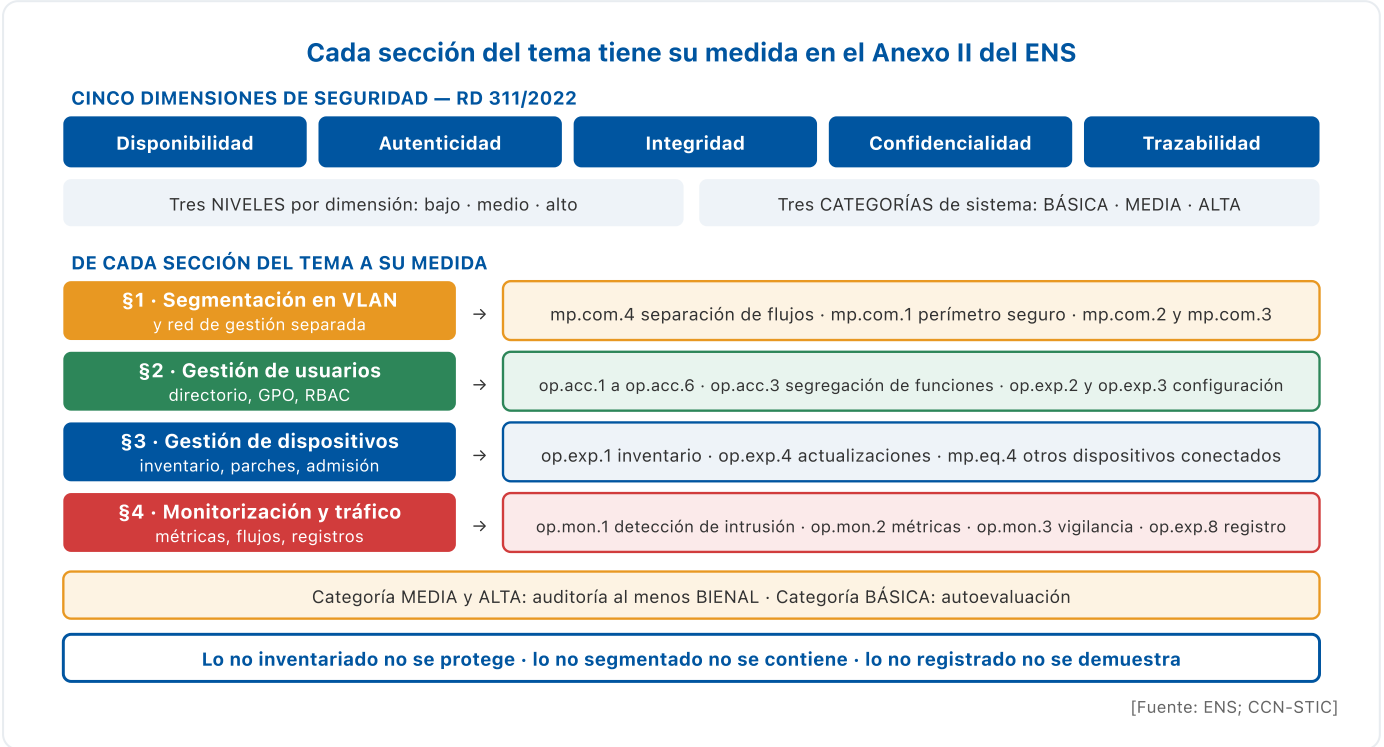


[Fuente: RFC3954; RFC7011; SFLOW; WIRESHARK]

D15 · El ENS aplicado a la red de área local

Sección: §4.2.4 — Cumplimiento del Esquema Nacional de Seguridad en la administración LAN

Propósito: Cerrar el tema traduciendo cada sección a la medida del Anexo II del RD 311/2022 que la respalda, y fijar dimensiones, niveles y categorías.



[Fuente: ENS; CCN-STIC]

Casos prácticos

Los tres casos recorren el supuesto de referencia del tema (ver la pestaña Contenido, «Convenciones»): la **red de área local de una sede de distrito** que alberga una Oficina de Atención a la Ciudadanía. El **Caso 1** trabaja el **diseño de la red y su segmentación**; el **Caso 2**, la **gestión de usuarios y de accesos** tras una reorganización administrativa; y el **Caso 3**, la **monitorización, el análisis del tráfico y el control de admisión** ante un incidente real.

Caso 1 — Diseño y segmentación de la red de una sede de distrito

Enunciado

El Ayuntamiento va a poner en servicio una **sede de distrito** de nueva construcción, con tres plantas y el siguiente equipamiento previsto:

- **180 puestos administrativos** de tramitación en las plantas primera y segunda.
- Una **Oficina de Atención a la Ciudadanía** en planta baja, con **14 puestos de mostrador** que atienden público y manejan documentación de terceros.
- **Telefonía IP** en todos los puestos (unos 200 terminales), alimentada por PoE.
- **6 impresoras multifunción** y **4 escáneres de mostrador** compartidos.
- **22 cámaras de videovigilancia** de un contrato de seguridad ajeno al departamento de sistemas.
- Una **sala de reuniones** con equipo de videoconferencia.
- **Red inalámbrica** con dos usos: personal municipal con portátil, y visitantes en la zona de espera de la planta baja.
- Un **armario de comunicaciones por planta**, más el principal en planta baja.

Se dispone del bloque de direccionamiento privado **10.42.0.0/20** para la sede.

Cuestiones

Cuestión 1 — Segmentación (3 puntos). Proponga el esquema de **VLAN** de la sede, indicando para cada una su **propósito** y la **razón** por la que se separa. Justifique expresamente el tratamiento de las cámaras y de la red de visitantes.

Cuestión 2 — Arquitectura y redundancia (3 puntos). Describa la **arquitectura física y lógica** de la sede: capas, tipo de puerto en cada tramo y mecanismos de redundancia. Indique **qué protecciones** deben activarse en los puertos de acceso y por qué.

Cuestión 3 — Direccionamiento y servicios (2 puntos). Reparta el bloque `10.42.0.0/20` entre las VLAN propuestas, dimensionando la de datos de tramitación con margen de crecimiento. Indique **cómo** se entregará la configuración a los equipos y **qué mecanismo** permite tener un único servidor DHCP central.

Cuestión 4 — Calidad de servicio (2 puntos). Defina el esquema de **calidad de servicio** de la sede: dónde se sitúa la frontera de confianza, qué clases se definen y dónde está el punto real de congestión.

▾ Ver solución orientativa

Solución orientativa

- **C1**: (§1.1.1, §1.1.2) Ocho VLAN, cada una con una justificación distinta:

VLAN	Propósito	Razón de la separación
Datos de tramitación	180 puestos administrativos	Contención del dominio de difusión y política homogénea de puesto
Oficina de Atención a la Ciudadanía	14 puestos de mostrador	Puestos **expuestos al público** que manejan datos de terceros: exigen directivas más estrictas y filtrado propio
Voz	200 teléfonos IP	Calidad de servicio y direccionamiento propios; el terminal la descubre por LLDP-MED
Impresión	Impresoras y escáneres	Dispositivos que **no deben iniciar conexiones** hacia ningún sitio: se les permite recibir, no salir
Videovigilancia	22 cámaras	Contrato ajeno, firmware fuera del control del departamento, sin agente posible: **confinamiento**
Inalámbrica corporativa	Portátiles del personal	Acceso equivalente al cableado, pero con autenticación propia
Invitados	Visitantes en zona de espera	Solo salida a internet y **ningún** acceso a la red interna
Gestión	Direcciones de administración de la electrónica	Separada del plano de datos y accesible solo desde puestos de administración

El tratamiento de las **cámaras** merece justificación expresa: son dispositivos que nadie considera informática, llegan por un contrato ajeno, rara vez admiten agente y casi nunca se actualizan. El ENS los contempla en la medida `mp.eq.4` **(otros dispositivos conectados a la red)**, y la respuesta correcta es confinarlas en una VLAN sin capacidad de iniciar conexiones hacia el resto y con su firmware bajo seguimiento en el inventario. La **red de visitantes** exige separación en tres niveles simultáneos: **nivel 2** (VLAN propia), **nivel 3** (encaminamiento que solo permite salida a internet) y **política** (portal con condiciones de uso). Quitar cualquiera de los tres deja un agujero. Todo el diseño se ampara en la medida `mp.com.4` **— separación de flujos de información en la red** [ENS].

- **C2**: (§1.1.1, §1.1.3) Arquitectura de **dos capas** (núcleo colapsado), que es la adecuada a una sede de este tamaño: un **conmutador de acceso por planta** —o pila de conmutadores,

según densidad de puertos— y una **pareja de conmutadores de distribución** en el armario principal, que asume también la función de núcleo local y la frontera de nivel 3 mediante **interfaces virtuales de VLAN (SVI)**, una por segmento, que actúan como puerta de enlace predeterminada. Tipos de puerto: **acceso** hacia los equipos finales —con la excepción del puerto del teléfono IP, que además transporta la VLAN de voz etiquetada — y **troncal** entre conmutadores, hacia los puntos de acceso inalámbricos y hacia cualquier servidor de virtualización local.

Redundancia en tres planos: **agregación de enlaces (802.1AX con LACP)** entre cada conmutador de planta y la distribución, que suma capacidad y evita que el árbol de expansión bloquee; **árbol de expansión** activo como red de seguridad, con el **puente raíz fijado por configuración** en uno de los conmutadores de distribución y el secundario en el otro; y **VRRP** entre ambos para la puerta de enlace de cada VLAN, de modo que la avería de un conmutador de distribución sea transparente para el mostrador.

Protecciones obligadas en los **puertos de acceso**: **puerto de borde** —para que el usuario obtenga dirección sin esperar la convergencia—, **guarda de BPDU** —que deshabilita el puerto si alguien conecta un conmutador—, **guarda de raíz**, **control de tormentas** de difusión, **seguridad de puerto** limitando las MAC aprendidas, e **inspección DHCP** con los puertos declarados no confiables salvo el que lleva al servidor legítimo, sobre la que se apoyan a su vez la **inspección ARP dinámica** y la **guarda de origen IP**.

- **C3**: (§1.2.1) El bloque `10.42.0.0/20` ofrece 4096 direcciones, más que suficiente. Reparto razonable:

VLAN	Subred	Direcciones útiles	Comentario
Datos de tramitación	`10.42.0.0/23`	510	180 puestos + portátiles + margen del 20 % a tres años
Oficina de Atención a la Ciudadanía	`10.42.2.0/24`	254	14 puestos, holgado
Voz	`10.42.4.0/23`	510	200 teléfonos con margen
Impresión	`10.42.6.0/24`	254	Todas con **reserva** DHCP, no con dirección fija
Videovigilancia	`10.42.7.0/24`	254	22 cámaras
Inalámbrica corporativa	`10.42.8.0/23`	510	Concesiones cortas
Invitados	`10.42.10.0/23`	510	Concesiones muy cortas: los visitantes se van
Gestión	`10.42.15.0/24`	254	Electrónica de red

La configuración se entrega por **DHCP** (máscara, puerta de enlace, servidores DNS internos, sufijo de dominio y servidores NTP). El mecanismo que permite un **único servidor central** para las ocho VLAN es el **agente de retransmisión** configurado en cada interfaz virtual del conmutador de distribución, que convierte la difusión del cliente en unidifusión hacia el servidor e indica de qué subred procede. Conviene además activar la **opción 82**, que añade conmutador y puerto de origen y convierte el registro de concesiones en una traza que dice desde qué roseta se pidió cada dirección. Criterio de administración: **reservar, no fijar** —una dirección configurada a mano en el equipo queda fuera del control del administrador—, salvo en la propia electrónica de red.

- **C4**: (§4.1.3, §4.1.4) **Frontera de confianza** en el puerto de acceso: se confía en el marcado del **teléfono IP**, identificado por LLDP-MED, y **no** en el del ordenador conectado tras él, cuyo tráfico se remarca salvo el de las aplicaciones corporativas identificadas. **Clases**: voz **EF (DSCP 46)** en cola de prioridad estricta **con límite máximo**; vídeo de la sala de reuniones **AF41 (34)**; señalización de telefonía **CS3 (24)** —poco caudal pero crítica: sin

señalización no hay llamada aunque la voz tenga prioridad—; aplicaciones de tramitación **AF21 (18)**; y copias de seguridad y actualizaciones en **mejor esfuerzo (0)**, con modelado en horario laboral. **Punto real de congestión**: dentro del edificio sobra capacidad; el cuello de botella es el **enlace hacia el centro de proceso de datos**, y es ahí donde el encolamiento tiene efecto. El marcado se hace en el acceso; el encolamiento, en la distribución y en ese enlace. Verificación con **sondas sintéticas** que midan retardo, fluctuación y pérdida antes y después: una configuración de calidad de servicio que no se mide es una creencia.

Criterios de evaluación

Criterio	Puntos
Esquema de VLAN completo con justificación por segmento, y tratamiento razonado de cámaras e invitados	3
Arquitectura, tipos de puerto, tres planos de redundancia y protecciones de borde correctas	3
Reparto de direccionamiento coherente con margen, y agente de retransmisión correctamente justificado	2
Frontera de confianza, clases con sus valores y localización correcta del punto de congestión	2

Caso 2 — Gestión de usuarios y accesos tras una reorganización administrativa

Enunciado

Una reorganización traslada a **60 empleados** entre distritos y crea un nuevo **servicio de tramitación electrónica** con 12 personas procedentes de cuatro unidades distintas. En la revisión previa al traslado, una auditoría interna detecta lo siguiente en el directorio corporativo:

- Existen **340 cuentas habilitadas** de personas que causaron baja hace más de un año.
- **Los permisos sobre carpetas compartidas están concedidos, en su mayoría, a cuentas individuales**, no a grupos.
- Varias personas conservan acceso a la documentación de **dos y tres destinos anteriores**.

- El personal técnico de los distritos utiliza **su cuenta ordinaria** para tareas administrativas, y esa misma cuenta tiene correo y navegación.
- Existen **cinco cuentas genéricas** de mostrador, compartidas por los turnos de la Oficina de Atención a la Ciudadanía, cuya contraseña conocen unas veinte personas.

Cuestiones

Cuestión 1 — Diagnóstico normativo (2 puntos). Clasifique los cinco hallazgos e indique, para cada uno, **qué medida del ENS** resulta incumplida o comprometida.

Cuestión 2 — Modelo de permisos (3 puntos). Explique cómo debe rediseñarse la concesión de permisos y **cuánto simplifica** eso el traslado de los 60 empleados. Ilustre con el caso de una persona que pasa del Distrito A al Distrito B.

Cuestión 3 — Estructura y directivas (3 puntos). Proponga la **estructura de unidades organizativas** y el uso de **directivas de grupo** para dar tratamiento diferenciado a los puestos de mostrador. Explique qué ocurre si una directiva del dominio está marcada como forzada y la unidad organizativa tiene el bloqueo de herencia activado.

Cuestión 4 — Cuentas privilegiadas y genéricas (2 puntos). Indique cómo deben tratarse las cuentas del personal técnico y las cinco cuentas genéricas de mostrador.

▾ Ver solución orientativa

Solución orientativa

- **C1**: (§2.1.3, §2.2.4) Diagnóstico y encaje normativo:

Hallazgo	Naturaleza	Medida del ENS comprometida
340 cuentas de personas de baja	Cuentas **huérfanas**: superficie de ataque y trazabilidad falseada	`op.acc.4` proceso de gestión de derechos de acceso
Permisos concedidos a cuentas individuales	Modelo insostenible: imposible auditar y mantener	`op.acc.2` requisitos de acceso; contraviene el modelo RBAC
Acceso a destinos anteriores	**Acumulación de privilegios**: incumple el mínimo privilegio	`op.acc.4`, mediante la revisión periódica de accesos
Cuenta ordinaria usada para administrar	Correo y navegación —los dos vectores de compromiso habituales— bajo identidad privilegiada	`op.acc.3` segregación de funciones y tareas; `op.acc.6` mecanismo de autenticación
Cuentas genéricas compartidas	Destruye la **trazabilidad**, que es una de las cinco dimensiones del ENS	`op.acc.1` identificación; `op.exp.8` registro de la actividad

- **C2**: (§2.1.3, §2.2.4) El rediseño consiste en aplicar el anidamiento **AGDLP**: las **cuentas (A)** se incluyen en **grupos globales (G)** que representan **quién es alguien** —perfil, servicio, distrito—; esos grupos globales se incluyen en **grupos locales de dominio (DL)** que representan **a qué da derecho algo** —lectura de una carpeta, uso de una impresora, acceso a una aplicación—; y es al grupo local de dominio al que se concede el **permiso (P)** sobre el recurso. Los permisos **nunca** se conceden a cuentas ni directamente a grupos globales.

El efecto sobre el traslado es la clave de la respuesta. Con el modelo actual, mover a una persona del Distrito A al Distrito B exige **localizar uno a uno** todos los recursos donde aparece su cuenta —carpetas, impresoras, aplicaciones, buzones compartidos— y modificarlos, con la certeza estadística de olvidar alguno; multiplicado por 60 personas, es un trabajo de semanas cuyo resultado previsible son los accesos residuales que la propia auditoría acaba de detectar. Con **AGDLP**, la operación completa para esa persona consiste en **quitarla del grupo global** `Tramitacion-Distrito-A` **y añadirla al grupo global** `Tramitacion-Distrito-B`: dos operaciones, efecto inmediato y simultáneo sobre todos los recursos, y un registro claro de quién hizo el cambio y cuándo. Los 60 traslados pasan de semanas a una tarde. El nuevo **servicio de tramitación electrónica** se resuelve creando un grupo global propio y añadiendo a las 12 personas, con independencia de sus unidades de procedencia. Es la traducción operativa del modelo **RBAC** [NIST-RBAC].

- **C3**: (§2.1.2, §2.2.2, §2.2.3) **Estructura**: un **único dominio** —multiplicar dominios multiplica el coste de administración sin aportar seguridad, ya que el límite real de seguridad es el **bosque**—, con un primer nivel de **unidades organizativas** por ámbito territorial o funcional (los Distritos y las Áreas de Gobierno) y un segundo nivel por **tipo de objeto** (usuarios, equipos, cuentas de servicio, grupos). Principio de diseño: la estructura de unidades organizativas debe responder a **cómo se administra** la organización, no a su organigrama, que cambia con cada legislatura. Sobre ella se **delega** a los técnicos de cada distrito la capacidad de restablecer contraseñas y desbloquear cuentas **de su ámbito**, sin ser administradores de nada más: es la aplicación de `op.acc.3`.

Directivas: una unidad organizativa propia para los **equipos de la Oficina de Atención a la Ciudadanía**, con una GPO que fije **bloqueo automático de pantalla por inactividad breve**, deshabilite el almacenamiento extraíble y configure la impresora del mostrador. La justificación es que son puestos **de cara al público**, con documentación de terceros en pantalla y personas al otro lado del mostrador; a un despacho cerrado se le aplicará un tiempo de bloqueo más laxo. Se corresponde con las medidas `mp.eq.1` (puesto de trabajo despejado) y `mp.eq.2` (bloqueo de puesto de trabajo) [ENS].

Sobre la pregunta de precedencia: si la directiva del **dominio está marcada como forzada**, **se aplica igualmente** pese al bloqueo de herencia de la unidad organizativa. La marca de forzada prevalece tanto sobre las directivas que se aplican después como sobre el bloqueo de herencia; es precisamente el mecanismo con el que la organización garantiza que sus ajustes mínimos alcanzan a todo el parque, incluidos los ámbitos que han bloqueado la herencia.

- **C4**: (§2.2.4) **Personal técnico**: cada técnico debe disponer de **dos cuentas**, una ordinaria para su trabajo diario —con correo y navegación— y otra **administrativa separada**, sin correo ni navegación, protegida con **segundo factor** y utilizada solo desde puestos de administración. El motivo es directo: el correo y la navegación son los dos vectores habituales de compromiso, y no deben ocurrir nunca bajo una identidad privilegiada. Cuando sea viable, sustituir la pertenencia permanente a grupos de administradores por **elevación temporal** acotada a una tarea y a un plazo.

Cuentas genéricas de mostrador: son el hallazgo más grave en términos de trazabilidad, porque hacen imposible atribuir una consulta a un expediente a una persona concreta. La solución correcta es **suprimirlas y sustituirlas por cuentas nominativas**, apoyadas si es preciso en un mecanismo de inicio de sesión rápido —tarjeta criptográfica del empleado— que haga el cambio de turno ágil y no penalice la atención al público. Si, por una razón operativa acreditada, alguna resultara inevitable, debe quedar **documentada y justificada**, con **ámbito mínimo**, contraseña rotada, **prohibición expresa** de usarla para acceder a datos personales de ciudadanos, y compensada con otros registros que permitan reconstruir quién

estaba en el mostrador en cada franja. En paralelo, las **340 cuentas de personas de baja** deben deshabilitarse de inmediato —no borrarse, para conservar la trazabilidad histórica y no perder los identificadores de seguridad asociados a los permisos— y someterse después al procedimiento de baja definitiva.

Criterios de evaluación

Criterio	Puntos
Los cinco hallazgos clasificados y correctamente asociados a medidas del ENS	2
AGDLP explicado con precisión y efecto sobre el traslado bien argumentado con el ejemplo	3
Estructura de unidades organizativas justificada, uso de GPO diferenciado y regla de la directiva forzada correcta	3
Separación de la cuenta administrativa y tratamiento razonado de las cuentas genéricas	2

Caso 3 — Un incidente en la red: saturación, dispositivo desconocido y respuesta

Enunciado

Durante tres semanas, los usuarios de la sede de distrito se quejan de **lentitud generalizada entre las 9:00 y las 9:45**, y en dos ocasiones se ha cortado una videoconferencia de la sala de reuniones. El sistema de monitorización muestra que el **enlace hacia el centro de proceso de datos alcanza el 100 % de utilización** en esa franja, pero no indica qué lo consume.

Al revisar el asunto, además, se detecta un **equipo con dirección de la VLAN de datos que no consta en el inventario** y que mantiene comunicación continua con una dirección externa.

La sede es un sistema de **categoría MEDIA** conforme al ENS.

Cuestiones

Cuestión 1 — Instrumento de análisis (2 puntos). Indique **qué instrumento** permite averiguar quién consume el enlace y **por qué no sirven** ni SNMP ni una captura completa de paquetes.

Describa el resultado esperable y las soluciones posibles ordenadas por coste.

Cuestión 2 — El dispositivo desconocido (3 puntos). Describa cómo **localizarlo físicamente** y qué **medidas de contención** aplicar. Indique qué mecanismos habrían impedido que un equipo no inventariado obtuviera acceso.

Cuestión 3 — Registros y protección de datos (3 puntos). Enumere los **registros** que deben existir para poder investigar el incidente, y explique los **límites jurídicos** que condicionan tanto el registro del tráfico como una eventual captura de paquetes.

Cuestión 4 — Cierre y mejora (2 puntos). Indique qué debe quedar tras el incidente y qué **medidas del ENS** resultan implicadas, considerando que la sede es de categoría MEDIA.

▾ **Ver solución orientativa**

Solución orientativa

- **C1**: (§4.2.2) El instrumento adecuado son los **registros de flujo** —**NetFlow v9**, **IPFIX** o **sFlow**— exportados desde el conmutador de distribución hacia un colector. **SNMP no sirve** porque ya responde a la pregunta del *cuánto* —la interfaz está al 100 %— y sondearlo con más frecuencia no añade el *quién*: los contadores de la MIB-II son agregados por interfaz y no distinguen conversaciones. Una **captura completa de paquetes no es el instrumento correcto** por tres motivos acumulados: generaría un volumen inmanejable durante tres semanas, la mayor parte del tráfico viaja cifrado —de modo que se obtendrían metadatos que el flujo ya da mucho más barato—, y recogería el contenido de comunicaciones de empleados y de ciudadanos sin necesidad, lo que sería **desproporcionado** [RGPD].

Resultado esperable: los flujos de esa franja, ordenados por volumen, mostrarán un patrón de muchos orígenes de la VLAN de datos hacia un mismo destino externo por el puerto 443, coincidiendo con el encendido simultáneo de los equipos: el servicio de **actualizaciones del sistema operativo**. **Soluciones ordenadas de menor a mayor coste**: **(1)** desplazar la ventana de actualización a horario nocturno mediante directiva; **(2)** desplegar un **servidor de actualizaciones local o una caché** en la sede, de modo que la descarga se haga una vez y no doscientas [WSUS]; **(3)** limitar el caudal de esa clase con **calidad de servicio**, marcándola como mejor esfuerzo con modelado en horario laboral, lo que además impide que vuelva a cortarse la videoconferencia; y **(4)** solo en último término, **ampliar el enlace**. La lección de método es que la ampliación de capacidad es la solución más cara y con frecuencia la menos necesaria: sin datos de flujo habría sido la primera propuesta y no habría resuelto la causa.

- **C2**: (§1.2.1, §3.2.1, §3.2.3) **Localización física** en cuatro pasos: **(1)** obtener la **dirección MAC** asociada a esa IP en la tabla ARP del conmutador de distribución; **(2)** seguir esa MAC en la

tabla de direcciones de los conmutadores hasta el puerto de acceso concreto en el que se aprende; **(3)** contrastar con el registro de **concesiones DHCP**, cuya **opción 82** indica directamente el conmutador y el puerto de origen —esto convierte una investigación de horas en una consulta de segundos—; y **(4)** identificar la roseta correspondiente en la documentación de cableado y acudir físicamente.

Contención inmediata, antes de desplazarse: deshabilitar el puerto de acceso o moverlo a una **VLAN de cuarentena** sin salida; si el control de admisión está desplegado, basta con un **cambio de autorización (CoA)** de RADIUS para mover la sesión a cuarentena en caliente, sin esperar a que el equipo se desconecte. En paralelo, **preservar la evidencia**: registros de flujo del equipo, concesiones DHCP, registros de autenticación y una captura acotada si procede, todo ello con la debida cadena de custodia. Solo después conviene desconectar, porque desconectar primero destruye información.

Qué lo habría impedido: el **control de admisión 802.1X**, que no habría dejado pasar más que EAPOL hasta autenticar el equipo contra el directorio; en su defecto, para dispositivos sin suplicante, **MAB** con la MAC dada de alta en el inventario, sabiendo que es un mecanismo débil que funciona como inventario aplicado y no como credencial; la **seguridad de puerto**, limitando las MAC aprendidas; y la conciliación periódica del **inventario administrativo con el técnico**, que es lo que revela precisamente el caso más preocupante: un equipo que comunica con la red y no consta en ningún sitio [ENS `op.exp.1`].

- **C3**: (§4.2.3) **Registros necesarios** para poder investigar, todos ellos centralizados en un servidor externo a los dispositivos que los generan y con **NTP** común, sin el cual los tiempos de distintos equipos no son comparables y la correlación es imposible:
- **Concesiones DHCP** con opción 82: qué equipo tuvo qué dirección, cuándo y desde qué roseta.
- **Registros de flujo** conservados: con quién habló ese equipo, cuánto y en qué momento, incluidas las tres semanas anteriores.
- **Autenticaciones** contra el directorio y contra el servidor RADIUS, correctas y fallidas.
- **Cambios de configuración** de la electrónica, con autor y contenido.
- **Eventos de las protecciones de borde**: puertos deshabilitados por guarda de BPDU, violaciones de seguridad de puerto, cambios de estado de enlaces.
- **Registros del propio sistema de gestión**, incluido quién consultó los registros.

Límites jurídicos: una dirección IP asociada a un usuario identificado o identificable es **dato personal**, de modo que el registro de tráfico es un tratamiento sujeto al RGPD. Exige **finalidad determinada** —la seguridad del sistema y el cumplimiento del ENS la sostienen; la curiosidad o el control laboral encubierto, no—, **minimización**, **plazo de conservación definido y aplicado**, **inclusión en el registro de actividades de tratamiento** del art. 30, **acceso**

restringido y trazado, e **información previa a la plantilla y a la representación de los trabajadores** sobre qué se registra y con qué fin, requisito reforzado por los **arts. 87-91 de la LOPDGDD** (derechos digitales en el ámbito laboral: intimidad frente al uso de dispositivos digitales, desconexión digital, videovigilancia, geolocalización y derechos digitales en la negociación colectiva). Para una eventual **captura de paquetes** los límites se intensifican, porque contiene el **contenido** de las comunicaciones: debe estar **autorizada**, **acotada** al tráfico estrictamente necesario —filtro de captura por dirección y puerto, y a ser posible solo cabeceras—, **custodiada** con acceso restringido y **borrada** cuando deja de ser necesaria. Capturar todo el tráfico del puesto para diagnosticar un problema de una aplicación concreta no es proporcionado [RGPD] [LOPDGDD].

- **C4**: (§4.2.4) **Qué debe quedar tras el incidente**: la **causa raíz corregida** —ventana de actualización desplazada y caché local desplegada—; la **calidad de servicio configurada y verificada** con sondas sintéticas que midan retardo, fluctuación y pérdida en la sala de reuniones; el **equipo desconocido identificado**, dado de alta o retirado, y su procedencia esclarecida; un **umbral de aviso** sobre la utilización del enlace que dispare antes de llegar al 100 %, para que la próxima vez la organización se entere por su monitorización y no por los usuarios tres semanas después; la **conciliación del inventario** ejecutada y convertida en tarea periódica; y un **plan de despliegue del control de admisión** en modo de supervisión, con redundancia del servidor RADIUS y comportamiento de contingencia definido, porque un control de seguridad que deja sin red al mostrador es en la práctica un incidente de disponibilidad.

Medidas del ENS implicadas: `op.exp.1` (inventario de activos), incumplida de raíz por el equipo desconocido; `op.mon.1` (detección de intrusión) y `op.mon.3` (vigilancia), que es la que falla cuando una anomalía de tres semanas la detectan los usuarios; `op.mon.2` (sistema de métricas), en cuanto a umbrales que no avisaron; `op.exp.8` (registro de la actividad); `mp.com.4` (separación de flujos de información en la red) y `mp.com.1` (perímetro seguro), en cuanto a la contención; y `op.exp.7` (gestión de incidentes), en cuanto al tratamiento del propio incidente y su eventual notificación conforme a la guía **CCN-STIC 817**. Al tratarse de un sistema de **categoría MEDIA**, la sede está sujeta a **auditoría al menos bienal** —no a mera autoevaluación, que corresponde a la categoría básica—, de modo que los hallazgos y su corrección deberán poder acreditarse documentalmente ante el auditor [ENS] [CCN-STIC].

Criterios de evaluación

Criterio	Puntos
Elección correcta del instrumento, descarte razonado de SNMP y de la captura, y soluciones ordenadas por coste	2
Localización física paso a paso, contención con preservación de evidencia y mecanismos preventivos correctos	3
Registros necesarios completos y límites jurídicos del RGPD y de la LOPDGDD bien expuestos	3
Cierre con causa raíz, mejora de la vigilancia y medidas del ENS correctamente citadas, incluida la auditoría bienal	2

Fuentes

Tier 1 — Estándares y normativa

ID	Referencia
[IEEE 802 1Q]	IEEE Std **802.1Q-2022**. *Bridges and Bridged Networks*. Norma consolidada de puentes y redes puenteadas: etiquetado **VLAN** (campo VID de **12 bits**, valores útiles **1-4094**; 0 y 4095 reservados), enlaces troncales, prioridad **PCP** y, desde la edición de 2005, el **protocolo de árbol de expansión múltiple (MSTP)**, publicado antes como 802.1s.
[IEEE 802 1D]	IEEE Std **802.1D-2004**. *Media Access Control (MAC) Bridges*. Puenteado transparente, aprendizaje de direcciones MAC y **protocolo de árbol de expansión**. La edición de 2004 **incorporó el RSTP** publicado como 802.1w-2001.
[IEEE 802 1AX]	IEEE Std **802.1AX-2020**. *Link Aggregation*. **Agregación de enlaces** y protocolo de control **LACP**. Publicada originalmente como **802.3ad** y trasladada al grupo 802.1 en 2008.
[IEEE 802 1X]	IEEE Std **802.1X-2020**. *Port-Based Network Access Control*. Control de admisión a la red basado en puerto: triángulo **suplicante — autenticador — servidor de autenticación** y encapsulado **EAPOL** (EAP sobre LAN).
[IEEE 802 1AB]	IEEE Std **802.1AB**. *Station and Media Access Control Connectivity Discovery* (**LLDP**). Descubrimiento de vecinos en el nivel de enlace; base del inventario automático de la topología, con la extensión **LLDP-MED** para telefonía IP.
[IEEE 802 1AE]	IEEE Std **802.1AE**. *MAC Security* (**MACsec**). Confidencialidad, integridad y autenticidad del origen **salto a salto** en el nivel 2.
[IEEE 802	IEEE Std **802.1AR**. *Secure Device Identity* (**DevID**). Identificador de dispositivo ligado criptográficamente al equipo: **IDevID** de fábrica y **LDevID** local.

ID	Referencia
`1AR]`	
`[IEEE 8023]`	IEEE Std **802.3**. *Ethernet*. Formato de trama, direccionamiento MAC, dominios de colisión y de difusión, y **PoE** (802.3af/at/bt) para alimentar teléfonos, puntos de acceso y cámaras por el propio cable de datos.
`[RFC 2131]`	IETF. *RFC 2131: Dynamic Host Configuration Protocol* y *RFC 2132 (opciones)*. Ciclo **DORA**, concesiones (*leases*), puertos UDP **67** (servidor) y **68** (cliente).
`[RFC 3046]`	IETF. *RFC 3046: DHCP Relay Agent Information Option* (**opción 82**). Inserción por el agente de retransmisión del puerto y el conmutador de origen; base de la trazabilidad de la concesión.
`[RFC 8415]`	IETF. *RFC 8415: Dynamic Host Configuration Protocol for IPv6 (DHCPv6)*. Puertos UDP **546/547**, modos con estado y sin estado.
`[RFC 1034]`	IETF. *RFC 1034 y RFC 1035: Domain Names — Concepts and Facilities / Implementation and Specification*. Espacio de nombres jerárquico, **zonas**, delegación, tipos de registro y transporte UDP/TCP **53**.
`[RFC 2136]`	IETF. *RFC 2136: Dynamic Updates in the Domain Name System (DNS UPDATE)*. Actualización dinámica del DNS, típicamente desde el servidor DHCP o desde el propio cliente.
`[RFC 4033]`	IETF. *RFC 4033-4035: DNS Security Introduction and Requirements* (**DNSSEC**). Firma de zonas y cadena de confianza: aporta autenticidad e integridad, **no confidencialidad**.

ID	Referencia
[RFC7858]	IETF. *RFC 7858 (DNS over TLS, puerto 853)* y *RFC 8484 (DNS over HTTPS)*. Confidencialidad del canal de consulta; relevantes en este tema por el problema de gestión que plantean dentro de una red corporativa.
[RFC1918]	IETF. *RFC 1918: Address Allocation for Private Internets*. Rangos privados 10/8, 172.16/12 y 192.168/16, base del direccionamiento de una LAN corporativa.
[RFC4632]	IETF. *RFC 4632: Classless Inter-Domain Routing (CIDR)* y *RFC 950 (subredes)*. Máscaras de longitud variable y agregación de rutas.
[RFC3411]	IETF. *RFC 3411-3418: An Architecture for Describing SNMP Management Frameworks* (**SNMPv3**). Gestor, agente, **MIB** y OID; puertos UDP **161** (consultas) y **162** (notificaciones); modelo de seguridad basado en usuario (**USM**), con autenticación y cifrado.
[RFC1213]	IETF. *RFC 1213: Management Information Base for Network Management of TCP/IP-based internets: MIB-II*. Grupos `system`, `interfaces`, `ip`; los contadores de interfaz sostienen la mayor parte de la monitorización clásica.
[RFC6241]	IETF. *RFC 6241: Network Configuration Protocol (NETCONF)* y *RFC 6020 (YANG)*. Configuración remota programática sobre SSH (**puerto 830**), con almacenes de configuración y transacciones. Complemento moderno: **RESTCONF** (RFC 8040).
[RFC5424]	IETF. *RFC 5424: The Syslog Protocol*, con *RFC 5425* (sobre TLS) y *RFC 5426* (sobre UDP). Formato del registro, **facility** y **severity** (0-7), puerto UDP **514** en el uso clásico y TCP **6514** sobre TLS.
[RFC5905]	IETF. *RFC 5905: Network Time Protocol Version 4* (**NTP**). Sincronización horaria, estratos y puerto UDP **123**: sin ella ningún registro de eventos es correlacionable.

ID	Referencia
[RFC3954]	IETF. *RFC 3954: Cisco Systems NetFlow Services Export Version 9*. Exportación de **flujos** con plantillas; puerto de recolección convencional UDP 2055.
[RFC7011]	IETF. *RFC 7011-7015: Specification of the IP Flow Information Export (IPFIX) Protocol*. Norma **abierta** de exportación de flujos, evolución de NetFlow v9 y modelo de referencia del análisis de tráfico por flujos.
[SFLOW]	sFlow.org / IETF. *RFC 3176: InMon Corporation's sFlow*. Monitorización por **muestreo** de paquetes y contadores, embebida en el circuito integrado del conmutador; puerto de recolección convencional UDP 6343.
[RFC2474]	IETF. *RFC 2474: Definition of the Differentiated Services Field (DS Field)*. Campo **DSCP** de 6 bits en la cabecera IP, base de la calidad de servicio por clases.
[RFC2475]	IETF. *RFC 2475: An Architecture for Differentiated Services*. Arquitectura **DiffServ**: dominio, nodos frontera y nodos interiores, y acondicionamiento del tráfico en el borde.
[RFC2597]	IETF. *RFC 2597: Assured Forwarding PHB Group* y *RFC 3246: An Expedited Forwarding PHB*. Comportamientos por salto AF11–AF43 y **EF** (DSCP **46**), este último reservado a la voz.
[RFC4594]	IETF. *RFC 4594: Configuration Guidelines for DiffServ Service Classes*. Recomendaciones de marcado por tipo de tráfico: voz, vídeo interactivo, señalización, transaccional y mejor esfuerzo.
[RFC2328]	IETF. *RFC 2328 (OSPFv2)*, *RFC 5340 (OSPFv3)* y *RFC 5798 (VRRP v3)*. Encaminamiento dinámico entre sedes y redundancia de la puerta de enlace predeterminada.
[RFC4	IETF. *RFC 4120: The Kerberos Network Authentication Service (V5)*. Autenticación por **tiques** (TGT y tique de servicio), con sello de tiempo; puerto 88. Base de la autenticación en dominios

ID	Referencia
[120]	de directorio.
[RFC4511]	IETF. *RFC 4510-4519: Lightweight Directory Access Protocol (LDAP)*. Protocolo, modelo de información, nombres distinguidos (**DN**), filtros de búsqueda y esquema. Puertos **389** y **636** (sobre TLS).
[X500]	ITU-T. *Recomendación X.500* — modelo de servicio de directorio (DIT, DSA, DUA), del que LDAP es la simplificación sobre TCP/IP.
[RFC2865]	IETF. *RFC 2865 (RADIUS Authentication)*, *RFC 2866 (Accounting)* y *RFC 5176 (Dynamic Authorization Extensions, **CoA**)*. Modelo **AAA** y capacidad de cambiar o cortar una sesión ya autorizada.
[RFC3748]	IETF. *RFC 3748: Extensible Authentication Protocol (EAP)* y *RFC 5216 (EAP-TLS)*. Métodos de autenticación transportados por 802.1X: EAP-TLS, PEAP y EAP-TTLS.
[RFC6749]	IETF. *RFC 6749 (OAuth 2.0)*, *RFC 7519 (JSON Web Token)* y **SAML 2.0** de OASIS. Federación de identidad e inicio de sesión único, cada vez más presentes junto al directorio clásico.
[NIST–RBAC]	NIST / ANSI INCITS 359. *Role-Based Access Control*. Modelo **RBAC** con usuarios, roles, permisos y sesiones; jerarquía de roles y restricciones de segregación de funciones.
[NIST–ZT]	NIST SP **800-207**: *Zero Trust Architecture*. Verificación explícita, mínimo privilegio y presunción de compromiso; marco de referencia de la microsegmentación.

ID	Referencia
`[ENS]`	Real Decreto **311/2022, de 3 de mayo**, por el que se regula el **Esquema Nacional de Seguridad**. Dimensiones, categorías y medidas del Anexo II; en este tema, especialmente `op.acc.1-6` (control de acceso), `op.exp.1-10` (explotación), `op.mon.1-3` (**detección de intrusión, sistema de métricas y vigilancia**), `mp.com.1-4` (**perímetro seguro; protección de la confidencialidad; protección de la integridad y de la autenticidad; separación de flujos de información en la red**) y `mp.eq.4` (otros dispositivos conectados a la red).
`[CCN-STIC]`	Centro Criptológico Nacional. *Guías CCN-STIC serie 800* — **803** (valoración de sistemas), **804** (medidas de implantación del ENS) y **817** (gestión de ciberincidentes), junto con las guías de configuración segura de electrónica de red.
`[RGPD]`	Reglamento (UE) **2016/679**. Arts. 5 (minimización y limitación de la finalidad), 6 (licitud), 25 (protección desde el diseño y por defecto), 30 (registro de actividades de tratamiento), 32 (seguridad del tratamiento) y 33-34 (notificación de brechas). Aplicable a los registros de red que permiten identificar a personas.
`[LOPDGDD]`	Ley Orgánica **3/2018**, de 5 de diciembre. Deber de confidencialidad y **derechos digitales en el ámbito laboral**: art. **87** (intimidad frente al uso de dispositivos digitales), art. **88** (desconexión digital), art. **89** (videovigilancia) y art. **90** (geolocalización).
`[L40-2015]`	Ley **40/2015**, de 1 de octubre, de Régimen Jurídico del Sector Público. Título preliminar, capítulo V: funcionamiento electrónico del sector público. Y, sobre todo, **artículo 156**, rubricado *«Esquema Nacional de Interoperabilidad y Esquema Nacional de Seguridad»*, cuyo apartado 1 define el **ENI** y cuyo apartado 2 establece que el **ENS** tiene por objeto fijar la política de seguridad en el uso de medios electrónicos, con sus principios básicos y requisitos mínimos (verificado contra el texto consolidado del BOE).
`[ENI]`	Real Decreto **4/2010**, de 8 de enero, por el que se regula el **Esquema Nacional de Interoperabilidad**, y sus Normas Técnicas de Interoperabilidad.

Tier 2 — Implementaciones, productos y herramientas

ID	Referencia
`[MS-AD]`	Microsoft. *Active Directory Domain Services* — estructura lógica (bosque, árbol, dominio, unidad organizativa), estructura física (sitios y controladores de dominio), esquema, catálogo global y replicación multimaestro.
`[MS-GPO]`	Microsoft. *Group Policy* — objetos de directiva de grupo, orden de aplicación **L-S-D-UO**, herencia, bloqueo, aplicación forzada, filtrado por seguridad y por WMI, plantillas administrativas.
`[MS-DNS]`	Microsoft. *DNS Server* y *DHCP Server* en Windows Server — zonas integradas en el directorio, registros **SRV** de localización de servicios y actualización dinámica segura.
`[MS-ENTRA]`	Microsoft. *Entra ID* (antes Azure AD) e *Intune* — identidad en la nube, unión híbrida del dispositivo, acceso condicional y gestión moderna del puesto. Citados como ejemplo de la evolución del directorio clásico.
`[OPENLDAP]`	The OpenLDAP Project. *OpenLDAP Software Administrator's Guide*, junto con los proyectos **FreeIPA** y **Samba AD**. Implementaciones libres de directorio y de dominio.
`[FREERADIUS]`	The FreeRADIUS Project y *PacketFence*. Servidor RADIUS y control de admisión a la red de código abierto.
`[SWITCH-VENDORS]`	Documentación de electrónica de red de campus (Cisco IOS/NX-OS, Juniper Junos, Aruba/HPE, Extreme, MikroTik). Citada para ilustrar conmutación, VLAN, agregación, QoS y espejo de puertos sin atar el tema a un fabricante.
`[NETMGMT-TOOLS]`	Plataformas de monitorización y gestión: **Zabbix**, **Nagios**, **Icinga**, **LibreNMS**, **PRTG**, **Prometheus** con `snmp_exporter`, **Grafana**, **NetBox** (fuente de verdad de la infraestructura) y **Oxidized/RANCID** (respaldo de configuraciones).
`[FLOW-TOOLS]`	Colectores y analizadores de flujos: **nfdump/NfSen**, **pmacct**, **ElastiFlow**, **Akvorado** y colectores comerciales.
`[WIRESHARK`	The Wireshark Foundation. *Wireshark User's Guide*, junto con `tcpdump` y `libpcap`. Captura y análisis de paquetes, filtros de captura (BPF) y de visualización.

ID	Referencia
`]`	
`[SIEM]`	Plataformas de correlación y registro: **Elastic Stack**, **Graylog**, **Wazuh**, **Splunk**, **OpenSearch**; y **Suricata** y **Zeek** como sondas de detección.
`[ANSIBLE]`	Red Hat. *Ansible* y sus colecciones de red; alternativas **NAPALM**, **Nornir** y **Terraform**. Automatización y configuración como código de la electrónica de red.
`[UEM]`	Plataformas de gestión unificada de dispositivos e inventario: **Intune**, **Jamf**, **GLPI** con **FusionInventory**, **OCS Inventory**, **Ivanti**.
`[WSUS]`	Microsoft. *Windows Server Update Services*; en Linux, réplicas locales de repositorios (`apt-mirror`, `dnf reposync`) y **Uyuni/Landscape**. Distribución controlada de actualizaciones.
`[PXE]`	Especificación *Preboot Execution Environment* y **UEFI HTTP Boot**; herramientas de despliegue por red (**FOG**, **MDT**, **Clonezilla**, **Autopilot**).
`[IPAM]`	Herramientas de gestión de direccionamiento (**IPAM**) e inventario de red: **phpIPAM**, **NetBox**, **NIPAP**.
`[PROPIETARIOS]`	Protocolos propietarios y su equivalente abierto, citados por pares para evitar la confusión más habitual: **VTP** frente a **MVRP**; **PAgP** frente a **LACP**; **CDP** frente a **LLDP**; **HSRP/GLBP** frente a **VRRP**; tecnologías de apilado y de chasis virtual frente a la agregación normalizada.

Tier 3 — Marco administrativo y organizativo (contexto)

ID	Referencia
`[IAM-MAD]`	Organismo Autónomo **Informática del Ayuntamiento de Madrid (IAM)** — responsable de los sistemas de información, de la red corporativa y del puesto de trabajo municipal. Contexto institucional de los ejemplos del tema.
`[ROGA]`	Reglamento Orgánico del Gobierno y de la Administración del Ayuntamiento de Madrid, de 31 de mayo de 2004. Áreas de Gobierno y **21 Distritos**: estructura sobre la que se distribuye la red corporativa y el parque de dispositivos. Ver Temas 3 y 4.
`[TRANSP-MAD]`	Portal de Transparencia y sede electrónica del Ayuntamiento de Madrid. Servicios electrónicos municipales que dependen de la red de área local de cada sede.
`[BOAM10032]`	BOAM 10.032 (23-dic-2025). Bases específicas TIC C1 Ayto. Madrid — temario oficial y estructura del ejercicio.

*Las referencias Tier 1 fijan el fundamento del tema en dos familias de estándares. La primera es la del **IEEE 802**, que gobierna cuanto ocurre en el nivel de enlace de una red de área local: etiquetado de VLAN y troncales (802.1Q), árbol de expansión (802.1D y su evolución RSTP/MSTP), agregación de enlaces (802.1AX), control de admisión por puerto (802.1X), descubrimiento de vecinos (802.1AB) y cifrado de nivel 2 (802.1AE). La segunda es la del **IETF**, que aporta los servicios y los protocolos de gestión: DHCP y DNS como servicios que hacen utilizable la red; SNMP y NETCONF como interfaces de administración; syslog y NTP como cimiento del registro de eventos; NetFlow/IPFIX y sFlow como instrumentos de análisis de tráfico; y DiffServ como marco de la calidad de servicio. A ellas se suman los estándares de identidad —X.500 y LDAP, Kerberos, RADIUS y EAP, y el RBAC del NIST— sobre los que descansa la gestión de usuarios, y la normativa española que condiciona cualquier administración de red en el sector público: el ENS, con sus grupos de medidas `op.acc`, `op.exp`, `op.mon` y `mp.com`, y el RGPD junto con la LOPDGDD, que convierten los registros de red y de tráfico en tratamientos de datos personales sujetos a límites. Tier 2 documenta implementaciones y herramientas concretas citadas como ejemplo: el opositor debe reconocer el mecanismo, no memorizar una marca. Tier 3 sitúa el supuesto municipal.*